MCP Security Audit Report

AgentSign

LangGraph

15 March 2026

Report ID: MCPS-MMRZ0M0E

Executive Summary

FAIL

Risk Score

100/100

12	56	941	9
CRITICAL	HIGH	MEDIUM	LOW

SCAN SCOPE	LANGUAGES	MCPS SDK
322 files 132,759 lines	**python (288), json (24), javascript (3), typescript (7)**	Not Found

Risk Comparison: WITHOUT MCPS vs WITH MCPS

CURRENT EXPOSURE			WITH MCPS PROTECTION	
MCP-01	**Rug Pulls** Vulnerable pattern detected, no mitigation	🔴	**MITIGATED** Passport identity binding — tools are tied to verified agent identity `createPassport(), signPassport()`	🟢
MCP-03	**Privilege Escalation via Tool Composition** No evidence of vulnerability or mitigation	🟠	**MITIGATED** Tool integrity signing — each tool definition is cryptographically signed `signTool(), verifyTool()`	🟢
MCP-04	**Cross-Server Request Forgery** Vulnerable pattern detected, no mitigation	🔴	**MITIGATED** Signed tool definitions prevent tampering during cross-server calls `signTool(), tool_hash`	🟢
MCP-06	**Indirect Prompt Injection via MCP** MCPS mitigation detected	🟢	**MITIGATED** Signed message envelopes — all MCP messages carry cryptographic signatures `signMessage(), verifyMessage()`	🟢
MCP-07	**Resource Exhaustion & DoS** MCPS mitigation detected	🟢	**MITIGATED** Passport verification middleware — all requests require valid signed identity `secureMCP(), verifyPassport()`	🟢
MCP-08	**Insufficient Logging & Audit** Vulnerable pattern detected, no mitigation	🔴	**MITIGATED** Signed audit trail — every message exchange is logged with cryptographic proof `auditLog(), onAudit()`	🟢
MCP-09	**Insecure MCP-to-MCP Communication** MCPS mitigation detected	🟢	**MITIGATED** Origin binding — passports encode allowed origins, verified on each request `validateOrigin(), passport.origin`	🟢
MCP-10	**Context Window Pollution** MCPS mitigation detected	🟢	**MITIGATED** Envelope isolation — signed message boundaries prevent context pollution `signMessage(), envelope`	🟢

Risk Reduction

100 --> 100

OWASP MCP Top 10 Compliance

Coverage: 4/8 risks mitigated by MCPS

ID	Risk	Status	Current State	With MCPS
MCP-01	Rug Pulls	**FAIL**	Vulnerable pattern detected, no mitigation	Passport identity binding — tools are tied to verified agent identity
MCP-02	Tool Poisoning	**N/A**	Not applicable to code-level analysis	N/A — requires LLM-level defense
MCP-03	Privilege Escalation via Tool Composition	**WARN**	No evidence of vulnerability or mitigation	Tool integrity signing — each tool definition is cryptographically signed
MCP-04	Cross-Server Request Forgery	**FAIL**	Vulnerable pattern detected, no mitigation	Signed tool definitions prevent tampering during cross-server calls
MCP-05	Sampling Manipulation	**N/A**	Not applicable to code-level analysis	N/A — requires client-level defense
MCP-06	Indirect Prompt Injection via MCP	**PASS**	MCPS mitigation detected	Signed message envelopes — all MCP messages carry cryptographic signatures
MCP-07	Resource Exhaustion & DoS	**PASS**	MCPS mitigation detected	Passport verification middleware — all requests require valid signed identity
MCP-08	Insufficient Logging & Audit	**FAIL**	Vulnerable pattern detected, no mitigation	Signed audit trail — every message exchange is logged with cryptographic proof
MCP-09	Insecure MCP-to-MCP Communication	**PASS**	MCPS mitigation detected	Origin binding — passports encode allowed origins, verified on each request
MCP-10	Context Window Pollution	**PASS**	MCPS mitigation detected	Envelope isolation — signed message boundaries prevent context pollution

Quick Fix `npm install mcp-secure`

Add MCPS to your MCP server to automatically mitigate the risks marked FAIL above.

OWASP Agentic AI Top 10 Coverage

12 rules checked | 1018 findings

Rule	OWASP	MITRE	STRIDE	Severity	Findings	Status
AS-001	AA-03	T1059	Elevation of Privilege	CRITICAL	5	●
AS-002	AA-05	T1552	Information Disclosure	HIGH	13	●
AS-003	AA-04	T1078	Elevation of Privilege	MEDIUM	673	●
AS-004	AA-02	T1190	Tampering	HIGH	31	●
AS-005	AA-02	T1055	Tampering	CRITICAL	7	●
AS-006	AA-09	T1610	Elevation of Privilege	HIGH	0	●
AS-007	AA-06	T1195	Tampering	LOW	9	●
AS-008	AA-01	T1548	Elevation of Privilege	HIGH	0	●
AS-009	AA-07	T1059.007	Tampering	MEDIUM	0	●
AS-010	AA-08	T1562.002	Repudiation	MEDIUM	268	●
AS-011	AA-10	T1041	Information Disclosure	HIGH	12	●
AS-012	MCP-07	T1078.004	Spoofing	HIGH	0	●

Detailed Findings

#1 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

`docs/generate_redirects.py:29`

Known injection pattern detected

```
    27 |     <link rel="canonical" href="{url}">
    28 |     <meta name="robots" content="noindex">
>   29 |     <script>var anchor=window.location.hash.substr(1);location.href="{url}"+(anchor?"#"+anchor:"")</
script>
    30 |     <meta http-equiv="refresh" content="0; url={url}">…
    31 | </head>
```

Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#2 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

`docs/generate_redirects.py:45`

Known injection pattern detected

```
    43 |     <link rel="canonical" href="{url}">
    44 |     <meta name="robots" content="noindex">
>   45 |     <script>var anchor=window.location.hash.substr(1);location.href="{url}"+(anchor?"#"+anchor:"")</
script>
    46 |     <meta http-equiv="refresh" content="0; url={url}">
    47 | </head>
```

Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#3 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

`docs/generate_redirects.py:63`

Known injection pattern detected

```
    61 |     <link rel="canonical" href="{default_url}">
    62 |     <meta name="robots" content="noindex">
>   63 |     <script>
    64 |         // Catchall redirect for any unmapped paths
    65 |         window.location.replace("{default_url}");
```

Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#4 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`docs/generate_redirects.py:1`

No logging, auditing, or monitoring detected

```
>    1 | #!/usr/bin/env python3
     2 | """…
     3 | Generate HTML redirect files from redirects.json.
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#5 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`examples/chatbot-simulation-evaluation/simulation_utils.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import functools
     2 | from typing import Annotated, Any, Callable, Dict, List, Optional, Union
     3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#6 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/cache/base/__init__.py:42`

High-risk permission pattern: """Delete the cached values for the given namespaces.

```
    40 |     @abstractmethod
    41 |     def clear(self, namespaces: Sequence[Namespace] | None = None) -> None:
>   42 |         """Delete the cached values for the given namespaces.
    43 |         If no namespaces are provided, clear all cached values."""
    44 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#7 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/cache/base/__init__.py:47`

High-risk permission pattern: """Asynchronously delete the cached values for the given namespaces.

```
    45 |     @abstractmethod
    46 |     async def aclear(self, namespaces: Sequence[Namespace] | None = None) -> None:
>   47 |         """Asynchronously delete the cached values for the given namespaces.
    48 |         If no namespaces are provided, clear all cached values."""
    49 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#8 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint/langgraph/cache/base/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |…
     3 | from abc import ABC, abstractmethod
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#9 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/cache/memory/__init__.py:60`

High-risk permission pattern: """Delete the cached values for the given namespaces.

```
    58 |
    59 |     def clear(self, namespaces: Sequence[Namespace] | None = None) -> None:
>   60 |         """Delete the cached values for the given namespaces.
    61 |         If no namespaces are provided, clear all cached values."""
    62 |         with self._lock:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#10 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/cache/memory/__init__.py:71`

High-risk permission pattern: """Asynchronously delete the cached values for the given namespaces.

```
    69 |
    70 |     async def aclear(self, namespaces: Sequence[Namespace] | None = None) -> None:
>   71 |         """Asynchronously delete the cached values for the given namespaces.
    72 |         If no namespaces are provided, clear all cached values."""
    73 |         self.clear(namespaces)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#11 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint/langgraph/cache/memory/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import datetime
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#12 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/cache/redis/__init__.py:105`

High-risk permission pattern: pipe.execute()

```
  103 |
  104 |         try:
> 105 |             pipe.execute()
  106 |         except Exception:…
  107 |             # Silently fail if Redis is unavailable
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#13 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/cache/redis/__init__.py:115`

High-risk permission pattern: """Delete the cached values for the given namespaces.

```
  113 |
  114 |     def clear(self, namespaces: Sequence[Namespace] | None = None) -> None:
> 115 |         """Delete the cached values for the given namespaces.
  116 |         If no namespaces are provided, clear all cached values."""
  117 |         try:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#14 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/cache/redis/__init__.py:123`

High-risk permission pattern: self.redis.delete(*keys)

```
  121 |                 keys = self.redis.keys(pattern)
  122 |                 if keys:
> 123 |                     self.redis.delete(*keys)
  124 |             else:
  125 |                 # Clear specific namespaces
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#15 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/cache/redis/__init__.py:136`

High-risk permission pattern: self.redis.delete(*keys_to_delete)

```
  134 |
  135 |                 if keys_to_delete:
> 136 |                     self.redis.delete(*keys_to_delete)
  137 |         except Exception:
  138 |             # Silently fail if Redis is unavailable
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#16 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/cache/redis/__init__.py:142`

High-risk permission pattern: """Asynchronously delete the cached values for the given namespaces.

```
   140 |
   141 |     async def aclear(self, namespaces: Sequence[Namespace] | None = None) -> None:
>  142 |         """Asynchronously delete the cached values for the given namespaces.
   143 |         If no namespaces are provided, clear all cached values."""…
   144 |         self.clear(namespaces)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#17 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint/langgraph/cache/redis/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from collections.abc import Mapping, Sequence
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#18 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/checkpoint/base/__init__.py:92`

High-risk permission pattern: Used to determine which nodes to execute next.

```
    90 |
    91 |     This keeps track of the versions of the channels that each node has seen.
>   92 |     Used to determine which nodes to execute next.
    93 |     """
    94 |     updated_channels: list[str] | None
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#19 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/checkpoint/base/__init__.py:270`

High-risk permission pattern: """Delete all checkpoints and writes associated with a specific thread ID.

```
   268 |         thread_id: str,
   269 |     ) -> None:
>  270 |         """Delete all checkpoints and writes associated with a specific thread ID.
   271 |…
   272 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#20 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/checkpoint/base/__init__.py:281`

High-risk permission pattern: """Delete all checkpoints and writes associated with the given run IDs.

```
   279 |         run_ids: Sequence[str],
   280 |     ) -> None:
>  281 |         """Delete all checkpoints and writes associated with the given run IDs.
   282 |
   283 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#21 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/checkpoint/base/__init__.py:312`

High-risk permission pattern: recent checkpoint per namespace. `"delete"` removes all checkpoints.

```
   310 |             thread_ids: The thread IDs to prune.
   311 |             strategy: The pruning strategy. `"keep_latest"` retains only the most
>  312 |                 recent checkpoint per namespace. `"delete"` removes all checkpoints.
   313 |         """
   314 |         raise NotImplementedError
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#22 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/checkpoint/base/__init__.py:414`

High-risk permission pattern: """Delete all checkpoints and writes associated with a specific thread ID.

```
   412 |         thread_id: str,
   413 |     ) -> None:
>  414 |         """Delete all checkpoints and writes associated with a specific thread ID.
   415 |
   416 |         Args:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#23 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/checkpoint/base/__init__.py:425`

High-risk permission pattern: """Asynchronously delete all checkpoints and writes for the given run IDs.

```
  423 |         run_ids: Sequence[str],
  424 |     ) -> None:
> 425 |         """Asynchronously delete all checkpoints and writes for the given run IDs.
  426 |…
  427 |         Args:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#24 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/checkpoint/base/__init__.py:456`

High-risk permission pattern: recent checkpoint per namespace. `"delete"` removes all checkpoints.

```
  454 |             thread_ids: The thread IDs to prune.
  455 |             strategy: The pruning strategy. `"keep_latest"` retains only the most
> 456 |                 recent checkpoint per namespace. `"delete"` removes all checkpoints.
  457 |         """
  458 |         raise NotImplementedError
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#25 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint/langgraph/checkpoint/base/id.py:1`

No logging, auditing, or monitoring detected

```
>   1 | """Adapted from
    2 | https://github.com/oittaa/uuid6-python/blob/main/src/uuid6/__init__.py#L95
    3 | Bundled in to avoid install issues with uuid6 package
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#26 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/checkpoint/memory/__init__.py:411`

High-risk permission pattern: """Delete all checkpoints and writes associated with a thread ID.

```
  409 |
  410 |     def delete_thread(self, thread_id: str) -> None:
> 411 |         """Delete all checkpoints and writes associated with a thread ID.
  412 |…
  413 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#27 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/checkpoint/memory/__init__.py:414`

High-risk permission pattern: thread_id: The thread ID to delete.

```
  412 |
  413 |         Args:
> 414 |             thread_id: The thread ID to delete.
  415 |
  416 |         Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#28 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/checkpoint/memory/__init__.py:508`

High-risk permission pattern: """Delete all checkpoints and writes associated with a thread ID.

```
  506 |
  507 |     async def adelete_thread(self, thread_id: str) -> None:
> 508 |         """Delete all checkpoints and writes associated with a thread ID.
  509 |
  510 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#29 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/checkpoint/memory/__init__.py:511`

High-risk permission pattern: thread_id: The thread ID to delete.

```
  509 |
  510 |         Args:
> 511 |             thread_id: The thread ID to delete.
  512 |
  513 |         Returns:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#30 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint/langgraph/checkpoint/serde/_msgpack.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import os
     2 | from collections.abc import Iterable…
     3 | from typing import cast
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#31 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint/langgraph/checkpoint/serde/base.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from typing import Any, Protocol, runtime_checkable
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#32 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

`libs/checkpoint/langgraph/checkpoint/serde/encrypted.py:47`

Dependency without integrity verification

```
    45 |         except ImportError:
    46 |             raise ImportError(
>   47 |                 "Pycryptodome is not installed. Please install it with `pip install pycryptodome`."
    48 |             ) from None
    49 |
```

Remediation:
1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#33 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint/langgraph/checkpoint/serde/encrypted.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import os
     2 | from typing import Any…
     3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#34 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`libs/checkpoint/langgraph/checkpoint/serde/jsonplus.py:258`

Dangerous execution: return pickle.loads(data_)

```
   256 |             )
   257 |         elif self.pickle_fallback and type_ == "pickle":
>  258 |             return pickle.loads(data_)
   259 |         else:
   260 |             raise NotImplementedError(f"Unknown serialization type: {type_}")
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#35 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint/langgraph/checkpoint/serde/types.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from collections.abc import Sequence
     2 | from typing import (
     3 |     Any,
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#36 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`libs/checkpoint/langgraph/store/base/__init__.py:595`

Dangerous execution: 2. A synchronous embedding function (`EmbeddingsFunc`)

```
   593 |     Can be specified in three ways:
   594 |         1. A LangChain `Embeddings` instance
>  595 |         2. A synchronous embedding function (`EmbeddingsFunc`)
   596 |         3. An asynchronous embedding function (`AEmbeddingsFunc`)
   597 |         4. A provider string (e.g., `"openai:text-embedding-3-small"`)
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#37 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`libs/checkpoint/langgraph/store/base/__init__.py:596`

Dangerous execution: 3. An asynchronous embedding function (`AEmbeddingsFunc`)

```
   594 |         1. A LangChain `Embeddings` instance
   595 |         2. A synchronous embedding function (`EmbeddingsFunc`)
>  596 |         3. An asynchronous embedding function (`AEmbeddingsFunc`)
   597 |         4. A provider string (e.g., `"openai:text-embedding-3-small"`)…
   598 |
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#38 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/store/base/__init__.py:432`

High-risk permission pattern: """Operation to store, update, or delete an item in the store.

```
   430 |
   431 | class PutOp(NamedTuple):
>  432 |     """Operation to store, update, or delete an item in the store.
   433 |
   434 |     This class represents a single operation to modify the store's contents,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#39 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/store/base/__init__.py:565`

High-risk permission pattern: If provided, the store will periodically delete expired items based on TTL.

```
   563 |     """Interval in minutes between TTL sweep operations.
   564 |
>  565 |     If provided, the store will periodically delete expired items based on TTL.
   566 |     Defaults to None (no sweeping).
   567 |     """
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#40 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/store/base/__init__.py:726`

High-risk permission pattern: """Execute multiple operations synchronously in a single batch.

```
   724 |     @abstractmethod
   725 |     def batch(self, ops: Iterable[Op]) -> list[Result]:
>  726 |         """Execute multiple operations synchronously in a single batch.
   727 |
   728 |         Args:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#41 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/store/base/__init__.py:729`

High-risk permission pattern: ops: An iterable of operations to execute.

```
   727 |
   728 |         Args:
>  729 |             ops: An iterable of operations to execute.
   730 |…
   731 |         Returns:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#42 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/store/base/__init__.py:738`

High-risk permission pattern: """Execute multiple operations asynchronously in a single batch.

```
   736 |     @abstractmethod
   737 |     async def abatch(self, ops: Iterable[Op]) -> list[Result]:
>  738 |         """Execute multiple operations asynchronously in a single batch.
   739 |
   740 |         Args:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#43 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/store/base/__init__.py:741`

High-risk permission pattern: ops: An iterable of operations to execute.

```
   739 |
   740 |         Args:
>  741 |             ops: An iterable of operations to execute.
   742 |
   743 |         Returns:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#44 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/store/base/__init__.py:929`

High-risk permission pattern: def delete(self, namespace: tuple[str, ...], key: str) -> None:

```
   927 |         )
   928 |
>  929 |     def delete(self, namespace: tuple[str, ...], key: str) -> None:
   930 |         """Delete an item.…
   931 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#45 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/store/base/__init__.py:930`

High-risk permission pattern: """Delete an item.

```
   928 |
   929 |     def delete(self, namespace: tuple[str, ...], key: str) -> None:
>  930 |         """Delete an item.
   931 |
   932 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#46 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/store/base/__init__.py:1191`

High-risk permission pattern: """Asynchronously delete an item.

```
  1189 |
  1190 |     async def adelete(self, namespace: tuple[str, ...], key: str) -> None:
> 1191 |         """Asynchronously delete an item.
  1192 |
  1193 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#47 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint/langgraph/store/base/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Base classes and types for persistent key-value stores.
     2 |
     3 | Stores provide long-term memory that persists across threads and conversations.
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#48 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/langgraph/store/base/batch.py:252`

High-risk permission pattern: def delete(

```
   250 |
   251 |     @_check_loop
>  252 |     def delete(
   253 |         self,…
   254 |         namespace: tuple[str, ...],
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#49 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint/langgraph/store/base/batch.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Utilities for batching operations in a background task."""
     2 |
     3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#50 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`libs/checkpoint/langgraph/store/base/embed.py:49`

Dangerous execution: An Embeddings instance that wraps the provided function(s).

```
    47 |
    48 |     Returns:
>   49 |         An Embeddings instance that wraps the provided function(s).
    50 |
    51 |     ??? example "Examples"
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#51 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

`libs/checkpoint/langgraph/store/base/embed.py:98`

Dependency without integrity verification

```
    96 |                 "loading embeddings by provider:identifier string requires langchain>=0.3.9 "
    97 |                 "as well as the provider-specific package. "
>   98 |                 "Install LangChain with: pip install 'langchain>=0.3.9' "
    99 |                 "and the provider-specific package (e.g., 'langchain-openai>=0.3.0'). "
   100 |                 "Alternatively, specify 'embed' as a compatible Embeddings object or python
function."
```

Remediation:
1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#52 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint/langgraph/store/base/embed.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Utilities for working with embedding functions and LangChain's Embeddings interface.
     2 |…
     3 | This module provides tools to wrap arbitrary embedding functions (both sync and async)
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#53 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

`libs/checkpoint/langgraph/store/memory/__init__.py:98`

Dependency without integrity verification

```
    96 |     For vector search, install numpy for better performance:
    97 |     ```bash
>   98 |     pip install numpy
    99 |     ```
   100 | """
```

Remediation:
1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#54 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

`libs/checkpoint/langgraph/store/memory/__init__.py:172`

Dependency without integrity verification

```
   170 |         For vector search, install numpy for better performance:
   171 |         ```bash
>  172 |         pip install numpy
   173 |         ```
   174 |     """
```

Remediation:
1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#55 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

`libs/checkpoint/langgraph/store/memory/__init__.py:488`

Dependency without integrity verification

```
   486 |         "which may significantly impact performance, especially for large datasets or frequent
searches. "
   487 |         "For optimal speed and efficiency, consider installing NumPy: "
>  488 |         "pip install numpy"
   489 |     )…
   490 |     return False
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#56 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint/tests/embed_test_utils.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Embedding utilities for testing."""
     2 |
     3 | import math
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#57 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint/tests/test_redis_cache.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Unit tests for Redis cache implementation."""
     2 |
     3 | import time
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#58 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/tests/test_store.py:243`

High-risk permission pattern: ("admin", "users", "789"),

```
   241 |         ("users", "123"),
   242 |         ("users", "456", "settings"),
>  243 |         ("admin", "users", "789"),
   244 |     ]
   245 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#59 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/tests/test_store.py:327`

High-risk permission pattern: ("admin", "users", "789"),

```
  325 |         ("users", "456"),
  326 |         ("users", "789", "settings"),
> 327 |         ("admin", "users", "789"),
  328 |         ("guests", "123"),…
  329 |         ("guests", "456", "preferences"),
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#60 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/tests/test_store.py:354`

High-risk permission pattern: namespace=("admin", "users", "settings", "789"),

```
  352 |
  353 |     store.put(
> 354 |         namespace=("admin", "users", "settings", "789"),
  355 |         key="foo",
  356 |         value={"data": "some_val"},
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#61 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/tests/test_store.py:359`

High-risk permission pattern: ("admin", "users", "settings", "789"),

```
  357 |     )
  358 |     expected = [
> 359 |         ("admin", "users", "settings", "789"),
  360 |     ]
  361 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#62 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/tests/test_store.py:468`

High-risk permission pattern: store.delete(("foo", "langgraph", "foo"), "bar")

```
  466 |     assert store.get(("foo", "langgraph", "foo"), "bar").value == doc  # type: ignore[union-attr]
  467 |     assert store.search(("foo", "langgraph", "foo"), query="bar")[0].value == doc
> 468 |     store.delete(("foo", "langgraph", "foo"), "bar")
  469 |     assert store.get(("foo", "langgraph", "foo"), "bar") is None…
  470 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#63 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint/tests/test_store.py:480`

High-risk permission pattern: store.delete(("langgraph", "foo"), "bar")

```
  478 |     assert store.get(("langgraph", "foo"), "bar").value == doc  # type: ignore[union-attr]
  479 |     assert store.search(("langgraph", "foo"))[0].value == doc
> 480 |     store.delete(("langgraph", "foo"), "bar")
  481 |     assert store.get(("langgraph", "foo"), "bar") is None
  482 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#64 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint/tests/test_store.py:1`

No logging, auditing, or monitoring detected

```
>   1 | # mypy: disable-error-code="operator"
    2 | import asyncio
    3 | import json
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#65 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/__init__.py:1`

No logging, auditing, or monitoring detected

```
>   1 | """langgraph-checkpoint-conformance: conformance test suite for checkpointer implementations."""
    2 |
    3 | from langgraph.checkpoint.conformance.initializer import checkpointer_test
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#66 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/checkpoint-conformance/langgraph/checkpoint/conformance/capabilities.py:1

No logging, auditing, or monitoring detected

```
>    1 | """Capability detection for checkpointer implementations."""
     2 |…
     3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#67 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/checkpoint-conformance/langgraph/checkpoint/conformance/initializer.py:1

No logging, auditing, or monitoring detected

```
>    1 | """Checkpointer test registration and factory management."""
     2 |
     3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#68 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/checkpoint-conformance/langgraph/checkpoint/conformance/report.py:1

No logging, auditing, or monitoring detected

```
>    1 | """Capability report: results, progress callbacks, and pretty-printing."""
     2 |
     3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#69 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/__init__.py:1

No logging, auditing, or monitoring detected

```
>    1 | """Test spec modules for each checkpointer capability."""
     2 |
     3 | from langgraph.checkpoint.conformance.spec.test_copy_thread import (
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#70 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_copy_thread.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """COPY_THREAD capability tests — acopy_thread."""
     2 |…
     3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#71 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_for_runs.py:45`

High-risk permission pattern: # Pre-delete: verify both runs exist

```
    43 |     await _put_with_run_id(saver, tid, run2, parent_config=stored1)
    44 |
>   45 |     # Pre-delete: verify both runs exist
    46 |     pre_results = []
    47 |     async for tup in saver.alist(generate_config(tid)):
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#72 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_for_runs.py:50`

High-risk permission pattern: assert run1 in pre_run_ids, "Pre-delete: run1 should exist"

```
    48 |         pre_results.append(tup)
    49 |     pre_run_ids = {t.metadata.get("run_id") for t in pre_results}
>   50 |     assert run1 in pre_run_ids, "Pre-delete: run1 should exist"
    51 |     assert run2 in pre_run_ids, "Pre-delete: run2 should exist"
    52 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#73 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_for_runs.py:51`

High-risk permission pattern: assert run2 in pre_run_ids, "Pre-delete: run2 should exist"

```
    49 |     pre_run_ids = {t.metadata.get("run_id") for t in pre_results}
    50 |     assert run1 in pre_run_ids, "Pre-delete: run1 should exist"
>   51 |     assert run2 in pre_run_ids, "Pre-delete: run2 should exist"
    52 |
    53 |     await saver.adelete_for_runs([run1])
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#74 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_for_runs.py:73`

High-risk permission pattern: # Pre-delete: verify all 3 runs exist

```
    71 |     await _put_with_run_id(saver, tid, run3, parent_config=s2)
    72 |
>   73 |     # Pre-delete: verify all 3 runs exist
    74 |     pre_results = []…
    75 |     async for tup in saver.alist(generate_config(tid)):
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#75 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_for_runs.py:78`

High-risk permission pattern: assert run1 in pre_run_ids, "Pre-delete: run1 should exist"

```
    76 |         pre_results.append(tup)
    77 |     pre_run_ids = {t.metadata.get("run_id") for t in pre_results}
>   78 |     assert run1 in pre_run_ids, "Pre-delete: run1 should exist"
    79 |     assert run2 in pre_run_ids, "Pre-delete: run2 should exist"
    80 |     assert run3 in pre_run_ids, "Pre-delete: run3 should exist"
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#76 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_for_runs.py:79`

High-risk permission pattern: assert run2 in pre_run_ids, "Pre-delete: run2 should exist"

```
    77 |     pre_run_ids = {t.metadata.get("run_id") for t in pre_results}
    78 |     assert run1 in pre_run_ids, "Pre-delete: run1 should exist"
>   79 |     assert run2 in pre_run_ids, "Pre-delete: run2 should exist"
    80 |     assert run3 in pre_run_ids, "Pre-delete: run3 should exist"
    81 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#77 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_for_runs.py:80`

High-risk permission pattern: assert run3 in pre_run_ids, "Pre-delete: run3 should exist"

```
    78 |     assert run1 in pre_run_ids, "Pre-delete: run1 should exist"
    79 |     assert run2 in pre_run_ids, "Pre-delete: run2 should exist"
>   80 |     assert run3 in pre_run_ids, "Pre-delete: run3 should exist"
    81 |…
    82 |     await saver.adelete_for_runs([run1, run2])
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#78 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_for_runs.py:104`

High-risk permission pattern: # Pre-delete: verify both runs exist

```
   102 |     await _put_with_run_id(saver, tid, run_delete)
   103 |
>  104 |     # Pre-delete: verify both runs exist
   105 |     pre_results = []
   106 |     async for tup in saver.alist(generate_config(tid)):
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#79 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_for_runs.py:109`

High-risk permission pattern: assert run_keep in pre_run_ids, "Pre-delete: run_keep should exist"

```
   107 |         pre_results.append(tup)
   108 |     pre_run_ids = {t.metadata.get("run_id") for t in pre_results}
>  109 |     assert run_keep in pre_run_ids, "Pre-delete: run_keep should exist"
   110 |     assert run_delete in pre_run_ids, "Pre-delete: run_delete should exist"
   111 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#80 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_for_runs.py:110`

High-risk permission pattern: assert run_delete in pre_run_ids, "Pre-delete: run_delete should exist"

```
   108 |     pre_run_ids = {t.metadata.get("run_id") for t in pre_results}
   109 |     assert run_keep in pre_run_ids, "Pre-delete: run_keep should exist"
>  110 |     assert run_delete in pre_run_ids, "Pre-delete: run_delete should exist"
   111 |
   112 |     await saver.adelete_for_runs([run_delete])
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#81 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_for_runs.py:131`

High-risk permission pattern: # Pre-delete: verify writes exist

```
   129 |     await saver.aput_writes(stored, [("ch", "val")], str(uuid4()))
   130 |
>  131 |     # Pre-delete: verify writes exist
   132 |     pre_tup = await saver.aget_tuple(stored)…
   133 |     assert pre_tup is not None, "Pre-delete: checkpoint should exist"
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#82 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_for_runs.py:133`

High-risk permission pattern: assert pre_tup is not None, "Pre-delete: checkpoint should exist"

```
   131 |     # Pre-delete: verify writes exist
   132 |     pre_tup = await saver.aget_tuple(stored)
>  133 |     assert pre_tup is not None, "Pre-delete: checkpoint should exist"
   134 |     assert pre_tup.pending_writes is not None and len(pre_tup.pending_writes) == 1, (
   135 |         f"Pre-delete: expected 1 write, got {len(pre_tup.pending_writes) if pre_tup.pending_writes
else 0}"
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#83 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_for_runs.py:135`

High-risk permission pattern: f"Pre-delete: expected 1 write, got {len(pre_tup.pending_writes) if pre_tup.pend

```
   133 |     assert pre_tup is not None, "Pre-delete: checkpoint should exist"
   134 |     assert pre_tup.pending_writes is not None and len(pre_tup.pending_writes) == 1, (
>  135 |         f"Pre-delete: expected 1 write, got {len(pre_tup.pending_writes) if pre_tup.pending_writes
else 0}"
   136 |     )
   137 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#84 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_for_runs.py:168`

High-risk permission pattern: # Pre-delete: verify run1 present in both namespaces

```
   166 |     await _put_with_run_id(saver, tid, run1, checkpoint_ns="child:1")
   167 |
>  168 |     # Pre-delete: verify run1 present in both namespaces
   169 |     for ns in ["", "child:1"]:…
   170 |         pre_results = []
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#85 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_for_runs.py:174`

High-risk permission pattern: assert run1 in pre_run_ids, f"Pre-delete: run1 should exist in ns='{ns}'"

```
   172 |             pre_results.append(tup)
   173 |         pre_run_ids = {t.metadata.get("run_id") for t in pre_results}
>  174 |         assert run1 in pre_run_ids, f"Pre-delete: run1 should exist in ns='{ns}'"
   175 |
   176 |     await saver.adelete_for_runs([run1])
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#86 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_for_runs.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """DELETE_FOR_RUNS capability tests — adelete_for_runs."""
     2 |
     3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#87 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_thread.py:21`

High-risk permission pattern: """All checkpoints gone after delete."""

```
    19 |     saver: BaseCheckpointSaver,
    20 | ) -> None:
>   21 |     """All checkpoints gone after delete."""
    22 |     tid = str(uuid4())
    23 |     parent_cfg = None
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#88 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_thread.py:33`

High-risk permission pattern: # Pre-delete: verify data exists

```
    31 |         parent_cfg = await saver.aput(config, cp, generate_metadata(step=i), {})
    32 |
>   33 |     # Pre-delete: verify data exists
    34 |     assert await saver.aget_tuple(generate_config(tid)) is not None, (…
    35 |         "Pre-delete: checkpoint should exist"
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#89 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_thread.py:35`

High-risk permission pattern: "Pre-delete: checkpoint should exist"

```
    33 |     # Pre-delete: verify data exists
    34 |     assert await saver.aget_tuple(generate_config(tid)) is not None, (
>   35 |         "Pre-delete: checkpoint should exist"
    36 |     )
    37 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#90 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_thread.py:50`

High-risk permission pattern: """Pending writes gone after delete."""

```
    48 |
    49 | async def test_delete_thread_removes_writes(saver: BaseCheckpointSaver) -> None:
>   50 |     """Pending writes gone after delete."""
    51 |     tid = str(uuid4())
    52 |     config = generate_config(tid)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#91 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_thread.py:57`

High-risk permission pattern: # Pre-delete: verify writes exist

```
    55 |     await saver.aput_writes(stored, [("ch", "val")], str(uuid4()))
    56 |
>   57 |     # Pre-delete: verify writes exist
    58 |     pre_tup = await saver.aget_tuple(generate_config(tid))…
    59 |     assert pre_tup is not None, "Pre-delete: checkpoint should exist"
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#92 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_thread.py:59`

High-risk permission pattern: assert pre_tup is not None, "Pre-delete: checkpoint should exist"

```
    57 |     # Pre-delete: verify writes exist
    58 |     pre_tup = await saver.aget_tuple(generate_config(tid))
>   59 |     assert pre_tup is not None, "Pre-delete: checkpoint should exist"
    60 |     assert pre_tup.pending_writes is not None and len(pre_tup.pending_writes) == 1, (
    61 |         f"Pre-delete: expected 1 write, got {len(pre_tup.pending_writes) if pre_tup.pending_writes
else 0}"
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#93 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_thread.py:61`

High-risk permission pattern: f"Pre-delete: expected 1 write, got {len(pre_tup.pending_writes) if pre_tup.pend

```
    59 |     assert pre_tup is not None, "Pre-delete: checkpoint should exist"
    60 |     assert pre_tup.pending_writes is not None and len(pre_tup.pending_writes) == 1, (
>   61 |         f"Pre-delete: expected 1 write, got {len(pre_tup.pending_writes) if pre_tup.pending_writes
else 0}"
    62 |     )
    63 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#94 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_thread.py:81`

High-risk permission pattern: # Pre-delete: verify each namespace has data

```
    79 |         await saver.aput(cfg, cp, generate_metadata(), {})
    80 |
>   81 |     # Pre-delete: verify each namespace has data
    82 |     for ns in ["", "child:1"]:
    83 |         pre = await saver.aget_tuple(generate_config(tid, checkpoint_ns=ns))
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#95 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_thread.py:84`

High-risk permission pattern: assert pre is not None, f"Pre-delete: namespace '{ns}' should have data"

```
    82 |     for ns in ["", "child:1"]:
    83 |         pre = await saver.aget_tuple(generate_config(tid, checkpoint_ns=ns))
>   84 |         assert pre is not None, f"Pre-delete: namespace '{ns}' should have data"
    85 |…
    86 |     await saver.adelete_thread(tid)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#96 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_delete_thread.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """DELETE_THREAD capability tests — adelete_thread."""
     2 |
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#97 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_get_tuple.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """GET_TUPLE capability tests — aget_tuple retrieval."""
     2 |
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#98 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_list.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """LIST capability tests — alist with various filters."""
     2 |…
     3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#99 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_prune.py:147`

High-risk permission pattern: await saver.aprune([tid], strategy="delete")

```
   145 |     await _setup_thread(saver, tid, n=3)
   146 |
>  147 |     await saver.aprune([tid], strategy="delete")
   148 |     results = []
   149 |     async for tup in saver.alist(generate_config(tid)):
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#100 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_prune.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """PRUNE capability tests — aprune(strategy)."""
     2 |
     3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#101 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_put.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """PUT capability tests — aput + aget_tuple round-trip."""
     2 |
     3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#102 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/spec/test_put_writes.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """PUT_WRITES capability tests — aput_writes + pending_writes retrieval."""
     2 |…
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#103 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/test_utils.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Test utilities: checkpoint generators, assertion helpers, bulk operations."""
     2 |
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#104 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-conformance/langgraph/checkpoint/conformance/validate.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Core conformance runner — detects capabilities, runs test suites, builds report."""
     2 |
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#105 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-conformance/tests/test_validate_memory.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Self-tests: run the conformance suite against InMemorySaver."""
     2 |
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#106 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/__init__.py:85`

High-risk permission pattern: cur.execute(self.MIGRATIONS[0])

```
    83 |         """
    84 |         with self._cursor() as cur:
>   85 |             cur.execute(self.MIGRATIONS[0])
    86 |             results = cur.execute(…
    87 |                 "SELECT v FROM checkpoint_migrations ORDER BY v DESC LIMIT 1"
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#107 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/__init__.py:86`

High-risk permission pattern: results = cur.execute(

```
    84 |         with self._cursor() as cur:
    85 |             cur.execute(self.MIGRATIONS[0])
>   86 |             results = cur.execute(
    87 |                 "SELECT v FROM checkpoint_migrations ORDER BY v DESC LIMIT 1"
    88 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#108 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/__init__.py:99`

High-risk permission pattern: cur.execute(migration)

```
    97 |                 strict=False,
    98 |             ):
>   99 |                 cur.execute(migration)
   100 |                 cur.execute("INSERT INTO checkpoint_migrations (v) VALUES (%s)", (v,))
   101 |         if self.pipe:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#109 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/__init__.py:100`

High-risk permission pattern: cur.execute("INSERT INTO checkpoint_migrations (v) VALUES (%s)", (v,))

```
    98 |             ):
    99 |                 cur.execute(migration)
>  100 |                 cur.execute("INSERT INTO checkpoint_migrations (v) VALUES (%s)", (v,))
   101 |         if self.pipe:
   102 |             self.pipe.sync()
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#110 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/__init__.py:152`

High-risk permission pattern: cur.execute(query, params)

```
   150 |         # if we change this to use .stream() we need to make sure to close the cursor
   151 |         with self._cursor() as cur:
>  152 |             cur.execute(query, params)
   153 |             values = cur.fetchall()…
   154 |             if not values:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#111 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/__init__.py:162`

High-risk permission pattern: cur.execute(

```
   160 |                 if v["checkpoint"]["v"] < 4 and v["parent_checkpoint_id"]
   161 |             ]:
>  162 |                 cur.execute(
   163 |                     self.SELECT_PENDING_SENDS_SQL,
   164 |                     (
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#112 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/__init__.py:230`

High-risk permission pattern: cur.execute(

```
   228 |
   229 |         with self._cursor() as cur:
>  230 |             cur.execute(
   231 |                 self.SELECT_SQL + where,
   232 |                 args,
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#113 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/__init__.py:240`

High-risk permission pattern: cur.execute(

```
  238 |             # migrate pending sends if necessary
  239 |             if value["checkpoint"]["v"] < 4 and value["parent_checkpoint_id"]:
> 240 |                 cur.execute(
  241 |                     self.SELECT_PENDING_SENDS_SQL,…
  242 |                     (thread_id, [value["parent_checkpoint_id"]]),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#114 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/__init__.py:323`

High-risk permission pattern: cur.execute(

```
  321 |                     ),
  322 |                 )
> 323 |             cur.execute(
  324 |                 self.UPSERT_CHECKPOINTS_SQL,
  325 |                 (
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#115 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/__init__.py:371`

High-risk permission pattern: """Delete all checkpoints and writes associated with a thread ID.

```
  369 |
  370 |     def delete_thread(self, thread_id: str) -> None:
> 371 |         """Delete all checkpoints and writes associated with a thread ID.
  372 |
  373 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#116 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/__init__.py:374`

High-risk permission pattern: thread_id: The thread ID to delete.

```
  372 |
  373 |         Args:
> 374 |             thread_id: The thread ID to delete.
  375 |
  376 |         Returns:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#117 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/__init__.py:380`

High-risk permission pattern: cur.execute(

```
   378 |         """
   379 |         with self._cursor(pipeline=True) as cur:
>  380 |             cur.execute(
   381 |                 "DELETE FROM checkpoints WHERE thread_id = %s",…
   382 |                 (str(thread_id),),
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#118 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/__init__.py:381`

High-risk permission pattern: "DELETE FROM checkpoints WHERE thread_id = %s",

```
   379 |         with self._cursor(pipeline=True) as cur:
   380 |             cur.execute(
>  381 |                 "DELETE FROM checkpoints WHERE thread_id = %s",
   382 |                 (str(thread_id),),
   383 |             )
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#119 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/__init__.py:384`

High-risk permission pattern: cur.execute(

```
   382 |                 (str(thread_id),),
   383 |             )
>  384 |             cur.execute(
   385 |                 "DELETE FROM checkpoint_blobs WHERE thread_id = %s",
   386 |                 (str(thread_id),),
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#120 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/__init__.py:385`

High-risk permission pattern: "DELETE FROM checkpoint_blobs WHERE thread_id = %s",

```
   383 |             )
   384 |             cur.execute(
>  385 |                 "DELETE FROM checkpoint_blobs WHERE thread_id = %s",
   386 |                 (str(thread_id),),…
   387 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#121 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/__init__.py:388`

High-risk permission pattern: cur.execute(

```
   386 |                 (str(thread_id),),
   387 |             )
>  388 |             cur.execute(
   389 |                 "DELETE FROM checkpoint_writes WHERE thread_id = %s",
   390 |                 (str(thread_id),),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#122 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/__init__.py:389`

High-risk permission pattern: "DELETE FROM checkpoint_writes WHERE thread_id = %s",

```
   387 |             )
   388 |             cur.execute(
>  389 |                 "DELETE FROM checkpoint_writes WHERE thread_id = %s",
   390 |                 (str(thread_id),),
   391 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#123 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import threading
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#124 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/_ainternal.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Shared async utility functions for the Postgres checkpoint & storage classes."""
     2 |…
     3 | from collections.abc import AsyncIterator
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#125 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/_internal.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Shared utility functions for the Postgres checkpoint & storage classes."""
     2 |
     3 | from collections.abc import Iterator
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#126 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:90`

High-risk permission pattern: await cur.execute(self.MIGRATIONS[0])

```
    88 |         """
    89 |         async with self._cursor() as cur:
>   90 |             await cur.execute(self.MIGRATIONS[0])
    91 |             results = await cur.execute(
    92 |                 "SELECT v FROM checkpoint_migrations ORDER BY v DESC LIMIT 1"
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#127 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:91`

High-risk permission pattern: results = await cur.execute(

```
    89 |         async with self._cursor() as cur:
    90 |             await cur.execute(self.MIGRATIONS[0])
>   91 |             results = await cur.execute(
    92 |                 "SELECT v FROM checkpoint_migrations ORDER BY v DESC LIMIT 1"
    93 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#128 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:104`

High-risk permission pattern: await cur.execute(migration)

```
   102 |                 strict=False,
   103 |             ):
>  104 |                 await cur.execute(migration)
   105 |                 await cur.execute(…
   106 |                     "INSERT INTO checkpoint_migrations (v) VALUES (%s)", (v,)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#129 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:105`

High-risk permission pattern: await cur.execute(

```
   103 |             ):
   104 |                 await cur.execute(migration)
>  105 |                 await cur.execute(
   106 |                     "INSERT INTO checkpoint_migrations (v) VALUES (%s)", (v,)
   107 |                 )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#130 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:141`

High-risk permission pattern: await cur.execute(query, params, binary=True)

```
   139 |         # if we change this to use .stream() we need to make sure to close the cursor
   140 |         async with self._cursor() as cur:
>  141 |             await cur.execute(query, params, binary=True)
   142 |             values = await cur.fetchall()
   143 |             if not values:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#131 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:151`

High-risk permission pattern: await cur.execute(

```
   149 |                 if v["checkpoint"]["v"] < 4 and v["parent_checkpoint_id"]
   150 |             ]:
>  151 |                 await cur.execute(
   152 |                     self.SELECT_PENDING_SENDS_SQL,
   153 |                     (
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#132 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:198`

High-risk permission pattern: await cur.execute(

```
  196 |
  197 |         async with self._cursor() as cur:
> 198 |             await cur.execute(
  199 |                 self.SELECT_SQL + where,…
  200 |                 args,
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#133 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:209`

High-risk permission pattern: await cur.execute(

```
  207 |             # migrate pending sends if necessary
  208 |             if value["checkpoint"]["v"] < 4 and value["parent_checkpoint_id"]:
> 209 |                 await cur.execute(
  210 |                     self.SELECT_PENDING_SENDS_SQL,
  211 |                     (thread_id, [value["parent_checkpoint_id"]]),
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#134 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:283`

High-risk permission pattern: await cur.execute(

```
  281 |                     ),
  282 |                 )
> 283 |             await cur.execute(
  284 |                 self.UPSERT_CHECKPOINTS_SQL,
  285 |                 (
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#135 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:330`

High-risk permission pattern: """Delete all checkpoints and writes associated with a thread ID.

```
   328 |
   329 |     async def adelete_thread(self, thread_id: str) -> None:
>  330 |         """Delete all checkpoints and writes associated with a thread ID.
   331 |…
   332 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#136 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:333`

High-risk permission pattern: thread_id: The thread ID to delete.

```
   331 |
   332 |         Args:
>  333 |             thread_id: The thread ID to delete.
   334 |
   335 |         Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#137 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:339`

High-risk permission pattern: await cur.execute(

```
   337 |         """
   338 |         async with self._cursor(pipeline=True) as cur:
>  339 |             await cur.execute(
   340 |                 "DELETE FROM checkpoints WHERE thread_id = %s",
   341 |                 (str(thread_id),),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#138 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:340`

High-risk permission pattern: "DELETE FROM checkpoints WHERE thread_id = %s",

```
   338 |         async with self._cursor(pipeline=True) as cur:
   339 |             await cur.execute(
>  340 |                 "DELETE FROM checkpoints WHERE thread_id = %s",
   341 |                 (str(thread_id),),
   342 |             )
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#139 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:343`

High-risk permission pattern: await cur.execute(

```
   341 |                 (str(thread_id),),
   342 |             )
>  343 |             await cur.execute(
   344 |                 "DELETE FROM checkpoint_blobs WHERE thread_id = %s",…
   345 |                 (str(thread_id),),
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#140 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:344`

High-risk permission pattern: "DELETE FROM checkpoint_blobs WHERE thread_id = %s",

```
   342 |             )
   343 |             await cur.execute(
>  344 |                 "DELETE FROM checkpoint_blobs WHERE thread_id = %s",
   345 |                 (str(thread_id),),
   346 |             )
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#141 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:347`

High-risk permission pattern: await cur.execute(

```
   345 |                 (str(thread_id),),
   346 |             )
>  347 |             await cur.execute(
   348 |                 "DELETE FROM checkpoint_writes WHERE thread_id = %s",
   349 |                 (str(thread_id),),
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#142 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:348`

High-risk permission pattern: "DELETE FROM checkpoint_writes WHERE thread_id = %s",

```
   346 |             )
   347 |             await cur.execute(
>  348 |                 "DELETE FROM checkpoint_writes WHERE thread_id = %s",
   349 |                 (str(thread_id),),…
   350 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#143 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:557`

High-risk permission pattern: """Delete all checkpoints and writes associated with a thread ID.

```
   555 |
   556 |     def delete_thread(self, thread_id: str) -> None:
>  557 |         """Delete all checkpoints and writes associated with a thread ID.
   558 |
   559 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#144 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:560`

High-risk permission pattern: thread_id: The thread ID to delete.

```
   558 |
   559 |         Args:
>  560 |             thread_id: The thread ID to delete.
   561 |
   562 |         Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#145 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/aio.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import asyncio
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#146 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/base.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |…
     3 | import random
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#147 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/shallow.py:240`

High-risk permission pattern: cur.execute(self.MIGRATIONS[0])

```
   238 |         """
   239 |         with self._cursor() as cur:
>  240 |             cur.execute(self.MIGRATIONS[0])
   241 |             results = cur.execute(
   242 |                 "SELECT v FROM checkpoint_migrations ORDER BY v DESC LIMIT 1"
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#148 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/shallow.py:241`

High-risk permission pattern: results = cur.execute(

```
   239 |         with self._cursor() as cur:
   240 |             cur.execute(self.MIGRATIONS[0])
>  241 |             results = cur.execute(
   242 |                 "SELECT v FROM checkpoint_migrations ORDER BY v DESC LIMIT 1"
   243 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#149 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/shallow.py:254`

High-risk permission pattern: cur.execute(migration)

```
   252 |                 strict=False,
   253 |             ):
>  254 |                 cur.execute(migration)
   255 |                 cur.execute("INSERT INTO checkpoint_migrations (v) VALUES (%s)", (v,))
   256 |         if self.pipe:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#150 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/shallow.py:255`

High-risk permission pattern: cur.execute("INSERT INTO checkpoint_migrations (v) VALUES (%s)", (v,))

```
  253 |             ):
  254 |                 cur.execute(migration)
> 255 |                 cur.execute("INSERT INTO checkpoint_migrations (v) VALUES (%s)", (v,))
  256 |         if self.pipe:…
  257 |             self.pipe.sync()
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#151 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/shallow.py:280`

High-risk permission pattern: cur.execute(query, params, binary=True)

```
  278 |             params.append(int(limit))
  279 |         with self._cursor() as cur:
> 280 |             cur.execute(query, params, binary=True)
  281 |             for value in cur:
  282 |                 checkpoint: Checkpoint = {
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#152 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/shallow.py:344`

High-risk permission pattern: cur.execute(

```
  342 |
  343 |         with self._cursor() as cur:
> 344 |             cur.execute(
  345 |                 self.SELECT_SQL + where,
  346 |                 args,
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#153 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/shallow.py:421`

High-risk permission pattern: cur.execute(

```
   419 |
   420 |         with self._cursor(pipeline=True) as cur:
>  421 |             cur.execute(
   422 |                 """DELETE FROM checkpoint_writes…
   423 |                 WHERE thread_id = %s AND checkpoint_ns = %s AND checkpoint_id NOT IN (%s, %s)""",
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#154 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/shallow.py:422`

High-risk permission pattern: """DELETE FROM checkpoint_writes

```
   420 |         with self._cursor(pipeline=True) as cur:
   421 |             cur.execute(
>  422 |                 """DELETE FROM checkpoint_writes
   423 |                 WHERE thread_id = %s AND checkpoint_ns = %s AND checkpoint_id NOT IN (%s, %s)""",
   424 |                 (
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#155 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/shallow.py:441`

High-risk permission pattern: cur.execute(

```
   439 |                 ),
   440 |             )
>  441 |             cur.execute(
   442 |                 self.UPSERT_CHECKPOINTS_SQL,
   443 |                 (
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#156 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/shallow.py:604`

High-risk permission pattern: await cur.execute(self.MIGRATIONS[0])

```
   602 |         """
   603 |         async with self._cursor() as cur:
>  604 |             await cur.execute(self.MIGRATIONS[0])
   605 |             results = await cur.execute(
   606 |                 "SELECT v FROM checkpoint_migrations ORDER BY v DESC LIMIT 1"
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#157 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/shallow.py:605`

High-risk permission pattern: results = await cur.execute(

```
  603 |         async with self._cursor() as cur:
  604 |             await cur.execute(self.MIGRATIONS[0])
> 605 |             results = await cur.execute(
  606 |                 "SELECT v FROM checkpoint_migrations ORDER BY v DESC LIMIT 1"…
  607 |             )
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#158 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/shallow.py:618`

High-risk permission pattern: await cur.execute(migration)

```
  616 |                 strict=False,
  617 |             ):
> 618 |                 await cur.execute(migration)
  619 |                 await cur.execute(
  620 |                     "INSERT INTO checkpoint_migrations (v) VALUES (%s)", (v,)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#159 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/shallow.py:619`

High-risk permission pattern: await cur.execute(

```
  617 |             ):
  618 |                 await cur.execute(migration)
> 619 |                 await cur.execute(
  620 |                     "INSERT INTO checkpoint_migrations (v) VALUES (%s)", (v,)
  621 |                 )
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#160 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/shallow.py:646`

High-risk permission pattern: await cur.execute(query, params, binary=True)

```
   644 |             params.append(int(limit))
   645 |         async with self._cursor() as cur:
>  646 |             await cur.execute(query, params, binary=True)
   647 |             async for value in cur:…
   648 |                 checkpoint: Checkpoint = {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#161 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/shallow.py:691`

High-risk permission pattern: await cur.execute(

```
   689 |
   690 |         async with self._cursor() as cur:
>  691 |             await cur.execute(
   692 |                 self.SELECT_SQL + where,
   693 |                 args,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#162 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/shallow.py:759`

High-risk permission pattern: await cur.execute(

```
   757 |
   758 |         async with self._cursor(pipeline=True) as cur:
>  759 |             await cur.execute(
   760 |                 """DELETE FROM checkpoint_writes
   761 |                 WHERE thread_id = %s AND checkpoint_ns = %s AND checkpoint_id NOT IN (%s, %s)""",
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#163 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/shallow.py:760`

High-risk permission pattern: """DELETE FROM checkpoint_writes

```
   758 |         async with self._cursor(pipeline=True) as cur:
   759 |             await cur.execute(
>  760 |                 """DELETE FROM checkpoint_writes
   761 |                 WHERE thread_id = %s AND checkpoint_ns = %s AND checkpoint_id NOT IN (%s, %s)""",
   762 |                 (
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#164 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/shallow.py:779`

High-risk permission pattern: await cur.execute(

```
   777 |                 ),
   778 |             )
>  779 |             await cur.execute(
   780 |                 self.UPSERT_CHECKPOINTS_SQL,…
   781 |                 (
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#165 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-postgres/langgraph/checkpoint/postgres/shallow.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import asyncio
     2 | import threading
     3 | import warnings
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#166 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-postgres/langgraph/store/postgres/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from langgraph.store.postgres.aio import AsyncPostgresStore
     2 | from langgraph.store.postgres.base import PoolConfig, PostgresStore
     3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#167 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/aio.py:237`

High-risk permission pattern: await cur.execute(

```
   235 |
   236 |         async def _get_version(cur: AsyncCursor[DictRow], table: str) -> int:
>  237 |             await cur.execute(
   238 |                 f"""…
   239 |                 CREATE TABLE IF NOT EXISTS {table} (
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#168 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/aio.py:244`

High-risk permission pattern: await cur.execute(f"SELECT v FROM {table} ORDER BY v DESC LIMIT 1")

```
   242 |             """
   243 |             )
>  244 |             await cur.execute(f"SELECT v FROM {table} ORDER BY v DESC LIMIT 1")
   245 |             row = cast(dict, await cur.fetchone())
   246 |             if row is None:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#169 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/aio.py:255`

High-risk permission pattern: await cur.execute(sql)

```
   253 |             version = await _get_version(cur, table="store_migrations")
   254 |             for v, sql in enumerate(self.MIGRATIONS[version + 1 :], start=version + 1):
>  255 |                 await cur.execute(sql)
   256 |                 await cur.execute("INSERT INTO store_migrations (v) VALUES (%s)", (v,))
   257 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#170 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/aio.py:256`

High-risk permission pattern: await cur.execute("INSERT INTO store_migrations (v) VALUES (%s)", (v,))

```
   254 |             for v, sql in enumerate(self.MIGRATIONS[version + 1 :], start=version + 1):
   255 |                 await cur.execute(sql)
>  256 |                 await cur.execute("INSERT INTO store_migrations (v) VALUES (%s)", (v,))
   257 |
   258 |             if self.index_config:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#171 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/aio.py:291`

High-risk permission pattern: await cur.execute(sql)

```
   289 |                             params["index_type"] = it
   290 |                         sql = sql % params
>  291 |                     await cur.execute(sql)
   292 |                     await cur.execute(…
   293 |                         "INSERT INTO vector_migrations (v) VALUES (%s)", (v,)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#172 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/aio.py:292`

High-risk permission pattern: await cur.execute(

```
   290 |                         sql = sql % params
   291 |                     await cur.execute(sql)
>  292 |                     await cur.execute(
   293 |                         "INSERT INTO vector_migrations (v) VALUES (%s)", (v,)
   294 |                     )
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#173 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/aio.py:297`

High-risk permission pattern: """Delete expired store items based on TTL.

```
   295 |
   296 |     async def sweep_ttl(self) -> int:
>  297 |         """Delete expired store items based on TTL.
   298 |
   299 |         Returns:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#174 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/aio.py:303`

High-risk permission pattern: await cur.execute(

```
   301 |         """
   302 |         async with self._cursor() as cur:
>  303 |             await cur.execute(
   304 |                 """…
   305 |                 DELETE FROM store
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#175 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/aio.py:305`

High-risk permission pattern: DELETE FROM store

```
   303 |             await cur.execute(
   304 |                 """
>  305 |                 DELETE FROM store
   306 |                 WHERE expires_at IS NOT NULL AND expires_at < NOW()
   307 |                 """
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#176 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/aio.py:315`

High-risk permission pattern: """Periodically delete expired store items based on TTL.

```
   313 |         self, sweep_interval_minutes: int | None = None
   314 |     ) -> asyncio.Task[None]:
>  315 |         """Periodically delete expired store items based on TTL.
   316 |
   317 |         Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#177 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/aio.py:453`

High-risk permission pattern: await cur.execute(query, params)

```
   451 |     ) -> None:
   452 |         for query, params, namespace, items in self._get_batch_GET_ops_queries(get_ops):
>  453 |             await cur.execute(query, params)
   454 |             rows = cast(list[Row], await cur.fetchall())
   455 |             key_to_row = {row["key"]: row for row in rows}
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#178 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/aio.py:498`

High-risk permission pattern: await cur.execute(query, params)

```
  496 |
  497 |         for query, params in queries:
> 498 |             await cur.execute(query, params)
  499 |…
  500 |     async def _batch_search_ops(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#179 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/aio.py:519`

High-risk permission pattern: await cur.execute(query, params)

```
  517 |
  518 |         for (idx, _), (query, params) in zip(search_ops, queries, strict=False):
> 519 |             await cur.execute(query, params)
  520 |             rows = cast(list[Row], await cur.fetchall())
  521 |             items = [
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#180 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/aio.py:537`

High-risk permission pattern: await cur.execute(query, params)

```
  535 |         queries = self._get_batch_list_namespaces_queries(list_ops)
  536 |         for (query, params), (idx, _) in zip(queries, list_ops, strict=False):
> 537 |             await cur.execute(query, params)
  538 |             rows = cast(list[dict], await cur.fetchall())
  539 |             namespaces = [_decode_ns_bytes(row["truncated_prefix"]) for row in rows]
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#181 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/base.py:112`

High-risk permission pattern: FOREIGN KEY (prefix, key) REFERENCES store(prefix, key) ON DELETE CASCADE

```
  110 |     updated_at TIMESTAMP WITH TIME ZONE DEFAULT CURRENT_TIMESTAMP,
  111 |     PRIMARY KEY (prefix, key, field_name),
> 112 |     FOREIGN KEY (prefix, key) REFERENCES store(prefix, key) ON DELETE CASCADE
  113 | );…
  114 | """,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#182 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/base.py:325`

High-risk permission pattern: f"DELETE FROM store WHERE prefix = %s AND key IN ({placeholders})"

```
  323 |                 placeholders = ",".join(["%s"] * len(keys))
  324 |                 query = (
> 325 |                     f"DELETE FROM store WHERE prefix = %s AND key IN ({placeholders})"
  326 |                 )
  327 |                 params = (_namespace_to_text(namespace), *keys)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#183 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/base.py:808`

High-risk permission pattern: """Delete expired store items based on TTL.

```
  806 |
  807 |     def sweep_ttl(self) -> int:
> 808 |         """Delete expired store items based on TTL.
  809 |
  810 |         Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#184 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/base.py:814`

High-risk permission pattern: cur.execute(

```
  812 |         """
  813 |         with self._cursor() as cur:
> 814 |             cur.execute(
  815 |                 """
  816 |                 DELETE FROM store
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#185 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/base.py:816`

High-risk permission pattern: DELETE FROM store

```
   814 |             cur.execute(
   815 |                 """
>  816 |                 DELETE FROM store
   817 |                 WHERE expires_at IS NOT NULL AND expires_at < NOW()…
   818 |                 """
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#186 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/base.py:826`

High-risk permission pattern: """Periodically delete expired store items based on TTL.

```
   824 |         self, sweep_interval_minutes: int | None = None
   825 |     ) -> concurrent.futures.Future[None]:
>  826 |         """Periodically delete expired store items based on TTL.
   827 |
   828 |         Returns:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#187 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/base.py:995`

High-risk permission pattern: cur.execute(query, params)

```
   993 |     ) -> None:
   994 |         for query, params, namespace, items in self._get_batch_GET_ops_queries(get_ops):
>  995 |             cur.execute(query, params)
   996 |             rows = cast(list[Row], cur.fetchall())
   997 |             key_to_row = {row["key"]: row for row in rows}
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#188 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/base.py:1041`

High-risk permission pattern: cur.execute(query, params)

```
  1039 |
  1040 |         for query, params in queries:
> 1041 |             cur.execute(query, params)
  1042 |…
  1043 |     def _batch_search_ops(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#189 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/base.py:1064`

High-risk permission pattern: cur.execute(query, params)

```
  1062 |
  1063 |         for (idx, _), (query, params) in zip(search_ops, queries, strict=False):
> 1064 |             cur.execute(query, params)
  1065 |             rows = cast(list[Row], cur.fetchall())
  1066 |             results[idx] = [
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#190 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/base.py:1082`

High-risk permission pattern: cur.execute(query, params)

```
  1080 |             self._get_batch_list_namespaces_queries(list_ops), list_ops, strict=False
  1081 |         ):
> 1082 |             cur.execute(query, params)
  1083 |             results[idx] = [_decode_ns_bytes(row["truncated_prefix"]) for row in cur]
  1084 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#191 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/base.py:1097`

High-risk permission pattern: cur.execute(

```
  1095 |
  1096 |         def _get_version(cur: Cursor[dict[str, Any]], table: str) -> int:
> 1097 |             cur.execute(
  1098 |                 f"""
  1099 |                 CREATE TABLE IF NOT EXISTS {table} (
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#192 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/base.py:1104`

High-risk permission pattern: cur.execute(f"SELECT v FROM {table} ORDER BY v DESC LIMIT 1")

```
  1102 |             """
  1103 |             )
> 1104 |             cur.execute(f"SELECT v FROM {table} ORDER BY v DESC LIMIT 1")
  1105 |             row = cast(dict, cur.fetchone())…
  1106 |             if row is None:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#193 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/base.py:1116`

High-risk permission pattern: cur.execute(sql)

```
  1114 |             for v, sql in enumerate(self.MIGRATIONS[version + 1 :], start=version + 1):
  1115 |                 try:
> 1116 |                     cur.execute(sql)
  1117 |                     cur.execute("INSERT INTO store_migrations (v) VALUES (%s)", (v,))
  1118 |                 except Exception as e:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#194 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/base.py:1117`

High-risk permission pattern: cur.execute("INSERT INTO store_migrations (v) VALUES (%s)", (v,))

```
  1115 |                 try:
  1116 |                     cur.execute(sql)
> 1117 |                     cur.execute("INSERT INTO store_migrations (v) VALUES (%s)", (v,))
  1118 |                 except Exception as e:
  1119 |                     logger.error(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#195 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/base.py:1159`

High-risk permission pattern: cur.execute(sql)

```
  1157 |                            params["index_type"] = it
  1158 |                        sql = sql % params
> 1159 |                    cur.execute(sql)
  1160 |                    cur.execute("INSERT INTO vector_migrations (v) VALUES (%s)", (v,))…
  1161 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#196 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/langgraph/store/postgres/base.py:1160`

High-risk permission pattern: cur.execute("INSERT INTO vector_migrations (v) VALUES (%s)", (v,))

```
  1158 |                        sql = sql % params
  1159 |                    cur.execute(sql)
> 1160 |                    cur.execute("INSERT INTO vector_migrations (v) VALUES (%s)", (v,))
  1161 |
  1162 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#197 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/conftest.py:24`

High-risk permission pattern: """Delete all tables before each test."""

```
    22 | @pytest.fixture(scope="function", autouse=True)
    23 | async def clear_test_db(conn: AsyncConnection[DictRow]) -> None:
>   24 |     """Delete all tables before each test."""
    25 |     try:
    26 |         await conn.execute("DELETE FROM checkpoints")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#198 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/conftest.py:26`

High-risk permission pattern: await conn.execute("DELETE FROM checkpoints")

```
    24 |     """Delete all tables before each test."""
    25 |     try:
>   26 |         await conn.execute("DELETE FROM checkpoints")
    27 |         await conn.execute("DELETE FROM checkpoint_blobs")
    28 |         await conn.execute("DELETE FROM checkpoint_writes")
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#199 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/conftest.py:27`

High-risk permission pattern: await conn.execute("DELETE FROM checkpoint_blobs")

```
    25 |     try:
    26 |         await conn.execute("DELETE FROM checkpoints")
>   27 |         await conn.execute("DELETE FROM checkpoint_blobs")
    28 |         await conn.execute("DELETE FROM checkpoint_writes")…
    29 |         await conn.execute("DELETE FROM checkpoint_migrations")
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#200 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/conftest.py:28`

High-risk permission pattern: await conn.execute("DELETE FROM checkpoint_writes")

```
    26 |         await conn.execute("DELETE FROM checkpoints")
    27 |         await conn.execute("DELETE FROM checkpoint_blobs")
>   28 |         await conn.execute("DELETE FROM checkpoint_writes")
    29 |         await conn.execute("DELETE FROM checkpoint_migrations")
    30 |     except UndefinedTable:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#201 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/conftest.py:29`

High-risk permission pattern: await conn.execute("DELETE FROM checkpoint_migrations")

```
    27 |         await conn.execute("DELETE FROM checkpoint_blobs")
    28 |         await conn.execute("DELETE FROM checkpoint_writes")
>   29 |         await conn.execute("DELETE FROM checkpoint_migrations")
    30 |     except UndefinedTable:
    31 |         pass
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#202 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/conftest.py:33`

High-risk permission pattern: await conn.execute("DELETE FROM store_migrations")

```
    31 |         pass
    32 |     try:
>   33 |         await conn.execute("DELETE FROM store_migrations")
    34 |         await conn.execute("DELETE FROM store")…
    35 |     except UndefinedTable:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#203 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/conftest.py:34`

High-risk permission pattern: await conn.execute("DELETE FROM store")

```
    32 |     try:
    33 |         await conn.execute("DELETE FROM store_migrations")
>   34 |         await conn.execute("DELETE FROM store")
    35 |     except UndefinedTable:
    36 |         pass
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#204 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-postgres/tests/conftest.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from collections.abc import AsyncIterator
     2 |
     3 | import pytest
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#205 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-postgres/tests/embed_test_utils.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Embedding utilities for testing."""
     2 |
     3 | import math
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#206 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_async.py:40`

High-risk permission pattern: await conn.execute(f"CREATE DATABASE {database}")

```
    38 |         DEFAULT_POSTGRES_URI, autocommit=True
    39 |     ) as conn:
>   40 |         await conn.execute(f"CREATE DATABASE {database}")
    41 |     try:…
    42 |         # yield checkpointer
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#207 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_async.py:56`

High-risk permission pattern: await conn.execute(f"DROP DATABASE {database}")

```
    54 |             DEFAULT_POSTGRES_URI, autocommit=True
    55 |         ) as conn:
>   56 |             await conn.execute(f"DROP DATABASE {database}")
    57 |
    58 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#208 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_async.py:67`

High-risk permission pattern: await conn.execute(f"CREATE DATABASE {database}")

```
    65 |         DEFAULT_POSTGRES_URI, autocommit=True
    66 |     ) as conn:
>   67 |         await conn.execute(f"CREATE DATABASE {database}")
    68 |     try:
    69 |         async with await AsyncConnection.connect(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#209 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_async.py:85`

High-risk permission pattern: await conn.execute(f"DROP DATABASE {database}")

```
    83 |             DEFAULT_POSTGRES_URI, autocommit=True
    84 |         ) as conn:
>   85 |             await conn.execute(f"DROP DATABASE {database}")
    86 |
    87 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#210 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_async.py:96`

High-risk permission pattern: await conn.execute(f"CREATE DATABASE {database}")

```
    94 |         DEFAULT_POSTGRES_URI, autocommit=True
    95 |     ) as conn:
>   96 |         await conn.execute(f"CREATE DATABASE {database}")
    97 |     try:…
    98 |         async with await AsyncConnection.connect(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#211 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_async.py:112`

High-risk permission pattern: await conn.execute(f"DROP DATABASE {database}")

```
   110 |             DEFAULT_POSTGRES_URI, autocommit=True
   111 |         ) as conn:
>  112 |             await conn.execute(f"DROP DATABASE {database}")
   113 |
   114 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#212 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_async.py:123`

High-risk permission pattern: await conn.execute(f"CREATE DATABASE {database}")

```
   121 |         DEFAULT_POSTGRES_URI, autocommit=True
   122 |     ) as conn:
>  123 |         await conn.execute(f"CREATE DATABASE {database}")
   124 |     try:
   125 |         async with await AsyncConnection.connect(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#213 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_async.py:139`

High-risk permission pattern: await conn.execute(f"DROP DATABASE {database}")

```
   137 |             DEFAULT_POSTGRES_URI, autocommit=True
   138 |         ) as conn:
>  139 |             await conn.execute(f"DROP DATABASE {database}")
   140 |…
   141 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#214 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-postgres/tests/test_async.py:1`

No logging, auditing, or monitoring detected

```
>    1 | # type: ignore
     2 |
     3 | from contextlib import asynccontextmanager
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#215 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_async_store.py:54`

High-risk permission pattern: await conn.execute(f"CREATE DATABASE {database}")

```
    52 |         admin_conn_string, autocommit=True
    53 |     ) as conn:
>   54 |         await conn.execute(f"CREATE DATABASE {database}")
    55 |     try:
    56 |         async with AsyncPostgresStore.from_conn_string(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#216 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_async_store.py:70`

High-risk permission pattern: await cur.execute("DROP TABLE IF EXISTS store_migrations")

```
    68 |             async with store._cursor() as cur:
    69 |                 # drop the migration index
>   70 |                 await cur.execute("DROP TABLE IF EXISTS store_migrations")
    71 |             await store.setup()  # Will fail if migrations aren't idempotent
    72 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#217 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_async_store.py:98`

High-risk permission pattern: await conn.execute(f"DROP DATABASE {database}")

```
    96 |             admin_conn_string, autocommit=True
    97 |         ) as conn:
>   98 |             await conn.execute(f"DROP DATABASE {database}")
    99 |…
   100 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#218 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_async_store.py:107`

High-risk permission pattern: store.delete(("foo", "bar"), "baz")

```
   105 |         store.get(("foo", "bar"), "baz")
   106 |     with pytest.raises(asyncio.InvalidStateError):
>  107 |         store.delete(("foo", "bar"), "baz")
   108 |     with pytest.raises(asyncio.InvalidStateError):
   109 |         store.search(("foo", "bar"))
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#219 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_async_store.py:382`

High-risk permission pattern: await conn.execute(f"CREATE DATABASE {database}")

```
   380 |         admin_conn_string, autocommit=True
   381 |     ) as conn:
>  382 |         await conn.execute(f"CREATE DATABASE {database}")
   383 |     try:
   384 |         async with AsyncPostgresStore.from_conn_string(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#220 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_async_store.py:394`

High-risk permission pattern: await conn.execute(f"DROP DATABASE {database}")

```
   392 |             admin_conn_string, autocommit=True
   393 |         ) as conn:
>  394 |             await conn.execute(f"DROP DATABASE {database}")
   395 |…
   396 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#221 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-postgres/tests/test_async_store.py:1`

No logging, auditing, or monitoring detected

```
>    1 | # type: ignore
     2 | from __future__ import annotations
     3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#222 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_store.py:51`

High-risk permission pattern: conn.execute(f"CREATE DATABASE {database}")

```
    49 |     }
    50 |     with Connection.connect(admin_conn_string, autocommit=True) as conn:
>   51 |         conn.execute(f"CREATE DATABASE {database}")
    52 |     try:
    53 |         with PostgresStore.from_conn_string(conn_string, ttl=ttl_config) as store:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#223 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_store.py:92`

High-risk permission pattern: conn.execute(f"DROP DATABASE {database}")

```
    90 |     finally:
    91 |         with Connection.connect(admin_conn_string, autocommit=True) as conn:
>   92 |             conn.execute(f"DROP DATABASE {database}")
    93 |
    94 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#224 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_store.py:172`

High-risk permission pattern: PutOp(namespace=("test",), key="key3", value=None), # Delete operation

```
   170 |         PutOp(namespace=("test",), key="key1", value={"data": "value1"}),
   171 |         PutOp(namespace=("test",), key="key2", value={"data": "value2"}),
>  172 |         PutOp(namespace=("test",), key="key3", value=None),  # Delete operation
   173 |     ]…
   174 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#225 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_store.py:281`

High-risk permission pattern: # Test delete

```
   279 |     assert item_in_different_namespace is None
   280 |
>  281 |     # Test delete
   282 |     store.delete(namespace, item_id)
   283 |     deleted_item = store.get(namespace, item_id)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#226 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_store.py:282`

High-risk permission pattern: store.delete(namespace, item_id)

```
   280 |
   281 |     # Test delete
>  282 |     store.delete(namespace, item_id)
   283 |     deleted_item = store.get(namespace, item_id)
   284 |     assert deleted_item is None
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#227 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_store.py:326`

High-risk permission pattern: store.delete(namespace, "dummy")

```
  324 |     # Cleanup
  325 |     for namespace in test_namespaces:
> 326 |         store.delete(namespace, "dummy")
  327 |…
  328 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#228 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_store.py:375`

High-risk permission pattern: store.delete(namespace, key)

```
  373 |     # Cleanup
  374 |     for namespace, key, _ in test_data:
> 375 |         store.delete(namespace, key)
  376 |
  377 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#229 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_store.py:409`

High-risk permission pattern: conn.execute(f"CREATE DATABASE {database}")

```
  407 |
  408 |     with Connection.connect(admin_conn_string, autocommit=True) as conn:
> 409 |         conn.execute(f"CREATE DATABASE {database}")
  410 |     try:
  411 |         with PostgresStore.from_conn_string(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#230 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_store.py:419`

High-risk permission pattern: cur.execute("DROP TABLE IF EXISTS store_migrations")

```
  417 |             with store._cursor() as cur:
  418 |                 # drop the migration index
> 419 |                 cur.execute("DROP TABLE IF EXISTS store_migrations")
  420 |             store.setup()  # Will fail if migrations aren't idempotent
  421 |             yield store
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#231 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_store.py:424`

High-risk permission pattern: conn.execute(f"DROP DATABASE {database}")

```
  422 |     finally:
  423 |         with Connection.connect(admin_conn_string, autocommit=True) as conn:
> 424 |             conn.execute(f"DROP DATABASE {database}")
  425 |…
  426 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#232 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-postgres/tests/test_store.py:1`

No logging, auditing, or monitoring detected

```
>   1 | # type: ignore
    2 | from __future__ import annotations
    3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#233 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_sync.py:36`

High-risk permission pattern: conn.execute(f"CREATE DATABASE {database}")

```
   34 |     # create unique db
   35 |     with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>  36 |         conn.execute(f"CREATE DATABASE {database}")
   37 |     try:
   38 |         # yield checkpointer
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#234 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_sync.py:50`

High-risk permission pattern: conn.execute(f"DROP DATABASE {database}")

```
    48 |         # drop unique db
    49 |         with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   50 |             conn.execute(f"DROP DATABASE {database}")
    51 |…
    52 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#235 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_sync.py:59`

High-risk permission pattern: conn.execute(f"CREATE DATABASE {database}")

```
    57 |     # create unique db
    58 |     with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   59 |         conn.execute(f"CREATE DATABASE {database}")
    60 |     try:
    61 |         with Connection.connect(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#236 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_sync.py:75`

High-risk permission pattern: conn.execute(f"DROP DATABASE {database}")

```
    73 |         # drop unique db
    74 |         with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   75 |             conn.execute(f"DROP DATABASE {database}")
    76 |
    77 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#237 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_sync.py:84`

High-risk permission pattern: conn.execute(f"CREATE DATABASE {database}")

```
    82 |     # create unique db
    83 |     with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   84 |         conn.execute(f"CREATE DATABASE {database}")
    85 |     try:
    86 |         with Connection.connect(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#238 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_sync.py:98`

High-risk permission pattern: conn.execute(f"DROP DATABASE {database}")

```
     96 |         # drop unique db
     97 |         with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>    98 |             conn.execute(f"DROP DATABASE {database}")
     99 |…
    100 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#239 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_sync.py:107`

High-risk permission pattern: conn.execute(f"CREATE DATABASE {database}")

```
    105 |     # create unique db
    106 |     with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   107 |         conn.execute(f"CREATE DATABASE {database}")
    108 |     try:
    109 |         with Connection.connect(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#240 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-postgres/tests/test_sync.py:121`

High-risk permission pattern: conn.execute(f"DROP DATABASE {database}")

```
    119 |         # drop unique db
    120 |         with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   121 |             conn.execute(f"DROP DATABASE {database}")
    122 |
    123 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#241 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-postgres/tests/test_sync.py:1`

No logging, auditing, or monitoring detected

```
>    1 | # type: ignore
     2 |…
     3 | import re
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#242 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/cache/sqlite/__init__.py:32`

High-risk permission pattern: self._conn.execute("PRAGMA journal_mode=WAL;")

```
    30 |         self._lock = threading.RLock()
    31 |         # Better concurrency & atomicity
>   32 |         self._conn.execute("PRAGMA journal_mode=WAL;")
    33 |         # Schema: key -> (expiry, encoding, value)
    34 |         self._conn.execute(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#243 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/cache/sqlite/__init__.py:34`

High-risk permission pattern: self._conn.execute(

```
    32 |         self._conn.execute("PRAGMA journal_mode=WAL;")
    33 |         # Schema: key -> (expiry, encoding, value)
>   34 |         self._conn.execute(
    35 |             """CREATE TABLE IF NOT EXISTS cache (
    36 |                 ns TEXT,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#244 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/cache/sqlite/__init__.py:56`

High-risk permission pattern: cursor = self._conn.execute(

```
    54 |             for ns_tuple, key in keys:
    55 |                 params.extend((",".join(ns_tuple), key))
>   56 |             cursor = self._conn.execute(
    57 |                 f"SELECT ns, key, expiry, encoding, val FROM cache WHERE (ns, key) IN
({placeholders})",
    58 |                 tuple(params),
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#245 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/cache/sqlite/__init__.py:65`

High-risk permission pattern: self._conn.execute(

```
    63 |                 if expiry is not None and now > expiry:
    64 |                     # purge expired entry
>   65 |                     self._conn.execute(
    66 |                         "DELETE FROM cache WHERE (ns, key) = (?, ?)", (ns, key)…
    67 |                     )
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#246 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/cache/sqlite/__init__.py:66`

High-risk permission pattern: "DELETE FROM cache WHERE (ns, key) = (?, ?)", (ns, key)

```
    64 |                     # purge expired entry
    65 |                     self._conn.execute(
>   66 |                         "DELETE FROM cache WHERE (ns, key) = (?, ?)", (ns, key)
    67 |                     )
    68 |                     continue
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#247 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/cache/sqlite/__init__.py:89`

High-risk permission pattern: self._conn.execute(

```
    87 |                     expiry = None
    88 |                 encoding, raw = self.serde.dumps_typed(value)
>   89 |                 self._conn.execute(
    90 |                     "INSERT OR REPLACE INTO cache (ns, key, expiry, encoding, val) VALUES
(?, ?, ?, ?, ?)",
    91 |                     (",".join(key[0]), key[1], expiry, encoding, raw),
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#248 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/cache/sqlite/__init__.py:99`

High-risk permission pattern: """Delete the cached values for the given namespaces.

```
    97 |
    98 |     def clear(self, namespaces: Sequence[Namespace] | None = None) -> None:
>   99 |         """Delete the cached values for the given namespaces.
   100 |         If no namespaces are provided, clear all cached values."""…
   101 |         with self._lock, self._conn:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#249 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/cache/sqlite/__init__.py:103`

High-risk permission pattern: self._conn.execute("DELETE FROM cache")

```
   101 |         with self._lock, self._conn:
   102 |             if namespaces is None:
>  103 |                 self._conn.execute("DELETE FROM cache")
   104 |             else:
   105 |                 placeholders = ",".join("?" for _ in namespaces)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#250 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/cache/sqlite/__init__.py:106`

High-risk permission pattern: self._conn.execute(

```
   104 |             else:
   105 |                 placeholders = ",".join("?" for _ in namespaces)
>  106 |                 self._conn.execute(
   107 |                     f"DELETE FROM cache WHERE (ns) IN ({placeholders})",
   108 |                     tuple(",".join(key) for key in namespaces),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#251 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/cache/sqlite/__init__.py:107`

High-risk permission pattern: f"DELETE FROM cache WHERE (ns) IN ({placeholders})",

```
   105 |                 placeholders = ",".join("?" for _ in namespaces)
   106 |                 self._conn.execute(
>  107 |                     f"DELETE FROM cache WHERE (ns) IN ({placeholders})",
   108 |                     tuple(",".join(key) for key in namespaces),
   109 |                 )
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#252 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/cache/sqlite/__init__.py:112`

High-risk permission pattern: """Asynchronously delete the cached values for the given namespaces.

```
   110 |
   111 |     async def aclear(self, namespaces: Sequence[Namespace] | None = None) -> None:
>  112 |         """Asynchronously delete the cached values for the given namespaces.
   113 |         If no namespaces are provided, clear all cached values."""…
   114 |         await asyncio.to_thread(self.clear, namespaces)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#253 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-sqlite/langgraph/cache/sqlite/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import asyncio
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#254 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/__init__.py:223`

High-risk permission pattern: cur.execute(

```
   221 |             # find the latest checkpoint for the thread_id
   222 |             if checkpoint_id := get_checkpoint_id(config):
>  223 |                 cur.execute(
   224 |                     "SELECT thread_id, checkpoint_id, parent_checkpoint_id, type, checkpoint,
metadata FROM checkpoints WHERE thread_id = ? AND checkpoint_ns = ? AND checkpoint_id = ?",
   225 |                     (
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#255 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/__init__.py:232

High-risk permission pattern: cur.execute(

```
   230 |                 )
   231 |             else:
>  232 |                 cur.execute(
   233 |                     "SELECT thread_id, checkpoint_id, parent_checkpoint_id, type, checkpoint,
metadata FROM checkpoints WHERE thread_id = ? AND checkpoint_ns = ? ORDER BY checkpoint_id DESC LIMIT 1",…
   234 |                     (str(config["configurable"]["thread_id"]), checkpoint_ns),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#256 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/__init__.py:255

High-risk permission pattern: cur.execute(

```
   253 |                     }
   254 |                 # find any pending writes
>  255 |                 cur.execute(
   256 |                     "SELECT task_id, channel, type, value FROM writes WHERE thread_id = ? AND
checkpoint_ns = ? AND checkpoint_id = ? ORDER BY task_id, idx",
   257 |                     (
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#257 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/__init__.py:336

High-risk permission pattern: cur.execute(query, param_values)

```
   334 |             param_values = (*param_values, limit)
   335 |         with self.cursor(transaction=False) as cur, closing(self.conn.cursor()) as wcur:
>  336 |             cur.execute(query, param_values)
   337 |             for (
   338 |                 thread_id,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#258 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/__init__.py:346

High-risk permission pattern: wcur.execute(

```
   344 |                 metadata,
   345 |             ) in cur:
>  346 |                 wcur.execute(
   347 |                     "SELECT task_id, channel, type, value FROM writes WHERE thread_id = ? AND
checkpoint_ns = ? AND checkpoint_id = ? ORDER BY task_id, idx",
   348 |                     (thread_id, checkpoint_ns, checkpoint_id),
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#259 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/__init__.py:418`

High-risk permission pattern: cur.execute(

```
   416 |         ).encode("utf-8", "ignore")
   417 |         with self.cursor() as cur:
>  418 |             cur.execute(
   419 |                 "INSERT OR REPLACE INTO checkpoints (thread_id, checkpoint_ns, checkpoint_id,
parent_checkpoint_id, type, checkpoint, metadata) VALUES (?, ?, ?, ?, ?, ?, ?)",…
   420 |                 (
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#260 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/__init__.py:478`

High-risk permission pattern: """Delete all checkpoints and writes associated with a thread ID.

```
   476 |
   477 |     def delete_thread(self, thread_id: str) -> None:
>  478 |         """Delete all checkpoints and writes associated with a thread ID.
   479 |
   480 |         Args:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#261 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/__init__.py:481`

High-risk permission pattern: thread_id: The thread ID to delete.

```
   479 |
   480 |         Args:
>  481 |             thread_id: The thread ID to delete.
   482 |
   483 |         Returns:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#262 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/__init__.py:487`

High-risk permission pattern: cur.execute(

```
   485 |         """
   486 |         with self.cursor() as cur:
>  487 |             cur.execute(
   488 |                 "DELETE FROM checkpoints WHERE thread_id = ?",…
   489 |                 (str(thread_id),),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#263 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/__init__.py:488`

High-risk permission pattern: "DELETE FROM checkpoints WHERE thread_id = ?",

```
   486 |         with self.cursor() as cur:
   487 |             cur.execute(
>  488 |                 "DELETE FROM checkpoints WHERE thread_id = ?",
   489 |                 (str(thread_id),),
   490 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#264 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/__init__.py:491`

High-risk permission pattern: cur.execute(

```
   489 |                 (str(thread_id),),
   490 |             )
>  491 |             cur.execute(
   492 |                 "DELETE FROM writes WHERE thread_id = ?",
   493 |                 (str(thread_id),),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#265 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/__init__.py:492`

High-risk permission pattern: "DELETE FROM writes WHERE thread_id = ?",

```
   490 |             )
   491 |             cur.execute(
>  492 |                 "DELETE FROM writes WHERE thread_id = ?",
   493 |                 (str(thread_id),),
   494 |             )
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#266 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |…
     3 | import json
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#267 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/aio.py:251`

High-risk permission pattern: """Delete all checkpoints and writes associated with a thread ID.

```
   249 |
   250 |     def delete_thread(self, thread_id: str) -> None:
>  251 |         """Delete all checkpoints and writes associated with a thread ID.
   252 |
   253 |         Args:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#268 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/aio.py:254`

High-risk permission pattern: thread_id: The thread ID to delete.

```
   252 |
   253 |         Args:
>  254 |             thread_id: The thread ID to delete.
   255 |
   256 |         Returns:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#269 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/aio.py:335

High-risk permission pattern: await cur.execute(

```
   333 |             # find the latest checkpoint for the thread_id
   334 |             if checkpoint_id := get_checkpoint_id(config):
>  335 |                 await cur.execute(
   336 |                     "SELECT thread_id, checkpoint_id, parent_checkpoint_id, type, checkpoint,
metadata FROM checkpoints WHERE thread_id = ? AND checkpoint_ns = ? AND checkpoint_id = ?",…
   337 |                     (
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#270 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/aio.py:344

High-risk permission pattern: await cur.execute(

```
   342 |                 )
   343 |             else:
>  344 |                 await cur.execute(
   345 |                     "SELECT thread_id, checkpoint_id, parent_checkpoint_id, type, checkpoint,
metadata FROM checkpoints WHERE thread_id = ? AND checkpoint_ns = ? ORDER BY checkpoint_id DESC LIMIT 1",
   346 |                     (str(config["configurable"]["thread_id"]), checkpoint_ns),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#271 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/aio.py:367

High-risk permission pattern: await cur.execute(

```
   365 |                     }
   366 |                 # find any pending writes
>  367 |                 await cur.execute(
   368 |                     "SELECT task_id, channel, type, value FROM writes WHERE thread_id = ? AND
checkpoint_ns = ? AND checkpoint_id = ? ORDER BY task_id, idx",
   369 |                     (
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#272 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/aio.py:433

High-risk permission pattern: self.conn.execute(query, params) as cur,

```
   431 |         async with (
   432 |             self.lock,
>  433 |             self.conn.execute(query, params) as cur,
   434 |             self.conn.cursor() as wcur,
   435 |         ):
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#273 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/aio.py:445`

High-risk permission pattern: await wcur.execute(

```
   443 |                 metadata,
   444 |             ) in cur:
>  445 |                 await wcur.execute(
   446 |                     "SELECT task_id, channel, type, value FROM writes WHERE thread_id = ? AND
checkpoint_ns = ? AND checkpoint_id = ? ORDER BY task_id, idx",…
   447 |                     (thread_id, checkpoint_ns, checkpoint_id),
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#274 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/aio.py:509`

High-risk permission pattern: self.conn.execute(

```
   507 |         async with (
   508 |             self.lock,
>  509 |             self.conn.execute(
   510 |                 "INSERT OR REPLACE INTO checkpoints (thread_id, checkpoint_ns, checkpoint_id,
parent_checkpoint_id, type, checkpoint, metadata) VALUES (?, ?, ?, ?, ?, ?, ?)",
   511 |                 (
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#275 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/aio.py:573`

High-risk permission pattern: """Delete all checkpoints and writes associated with a thread ID.

```
   571 |
   572 |     async def adelete_thread(self, thread_id: str) -> None:
>  573 |         """Delete all checkpoints and writes associated with a thread ID.
   574 |
   575 |         Args:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#276 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/aio.py:576`

High-risk permission pattern: thread_id: The thread ID to delete.

```
   574 |
   575 |         Args:
>  576 |             thread_id: The thread ID to delete.
   577 |…
   578 |         Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#277 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/aio.py:582`

High-risk permission pattern: await cur.execute(

```
   580 |         """
   581 |         async with self.lock, self.conn.cursor() as cur:
>  582 |             await cur.execute(
   583 |                 "DELETE FROM checkpoints WHERE thread_id = ?",
   584 |                 (str(thread_id),),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#278 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/aio.py:583`

High-risk permission pattern: "DELETE FROM checkpoints WHERE thread_id = ?",

```
   581 |         async with self.lock, self.conn.cursor() as cur:
   582 |             await cur.execute(
>  583 |                 "DELETE FROM checkpoints WHERE thread_id = ?",
   584 |                 (str(thread_id),),
   585 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#279 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/aio.py:586`

High-risk permission pattern: await cur.execute(

```
   584 |                 (str(thread_id),),
   585 |             )
>  586 |             await cur.execute(
   587 |                 "DELETE FROM writes WHERE thread_id = ?",
   588 |                 (str(thread_id),),
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#280 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/aio.py:587`

High-risk permission pattern: "DELETE FROM writes WHERE thread_id = ?",

```
   585 |             )
   586 |             await cur.execute(
>  587 |                 "DELETE FROM writes WHERE thread_id = ?",
   588 |                 (str(thread_id),),…
   589 |             )
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#281 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/aio.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import asyncio
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#282 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-sqlite/langgraph/checkpoint/sqlite/utils.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import json
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#283 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-sqlite/langgraph/store/sqlite/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from langgraph.store.sqlite.aio import AsyncSqliteStore
     2 | from langgraph.store.sqlite.base import SqliteStore…
     3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#284 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:154`

High-risk permission pattern: await self.conn.execute(

```
    152 |
    153 |             # Create migrations table if it doesn't exist
>   154 |             await self.conn.execute(
    155 |                 """
    156 |                 CREATE TABLE IF NOT EXISTS store_migrations (
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#285 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:163`

High-risk permission pattern: async with self.conn.execute(

```
    161 |
    162 |             # Check current migration version
>   163 |             async with self.conn.execute(
    164 |                 "SELECT v FROM store_migrations ORDER BY v DESC LIMIT 1"
    165 |             ) as cur:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#286 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:175`

High-risk permission pattern: await self.conn.execute(

```
    173 |             for v, sql in enumerate(self.MIGRATIONS[version + 1 :], start=version + 1):
    174 |                 await self.conn.executescript(sql)
>   175 |                 await self.conn.execute(
    176 |                     "INSERT INTO store_migrations (v) VALUES (?)", (v,)
    177 |                 )
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#287 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:185`

High-risk permission pattern: await self.conn.execute(

```
  183 |                 await self.conn.load_extension(sqlite_vec.loadable_path())
  184 |                 await self.conn.enable_load_extension(False)
> 185 |                 await self.conn.execute(
  186 |                     """…
  187 |                     CREATE TABLE IF NOT EXISTS vector_migrations (
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#288 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:194`

High-risk permission pattern: async with self.conn.execute(

```
  192 |
  193 |                 # Check current vector migration version
> 194 |                 async with self.conn.execute(
  195 |                     "SELECT v FROM vector_migrations ORDER BY v DESC LIMIT 1"
  196 |                 ) as cur:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#289 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:208`

High-risk permission pattern: await self.conn.execute(

```
  206 |                 ):
  207 |                     await self.conn.executescript(sql)
> 208 |                     await self.conn.execute(
  209 |                         "INSERT INTO vector_migrations (v) VALUES (?)", (v,)
  210 |                     )
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#290 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:230`

High-risk permission pattern: await self.conn.execute("BEGIN")

```
   228 |         async with self.lock:
   229 |             if transaction:
>  230 |                 await self.conn.execute("BEGIN")
   231 |…
   232 |             async with self.conn.cursor() as cur:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#291 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:237`

High-risk permission pattern: await self.conn.execute("COMMIT")

```
   235 |                 finally:
   236 |                     if transaction:
>  237 |                         await self.conn.execute("COMMIT")
   238 |
   239 |     async def sweep_ttl(self) -> int:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#292 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:240`

High-risk permission pattern: """Delete expired store items based on TTL.

```
   238 |
   239 |     async def sweep_ttl(self) -> int:
>  240 |         """Delete expired store items based on TTL.
   241 |
   242 |         Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#293 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:246`

High-risk permission pattern: await cur.execute(

```
   244 |         """
   245 |         async with self._cursor() as cur:
>  246 |             await cur.execute(
   247 |                 """
   248 |                 DELETE FROM store
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#294 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:248`

High-risk permission pattern: DELETE FROM store

```
   246 |             await cur.execute(
   247 |                 """
>  248 |                 DELETE FROM store
   249 |                 WHERE expires_at IS NOT NULL AND expires_at < CURRENT_TIMESTAMP…
   250 |                 """
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#295 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:258`

High-risk permission pattern: """Periodically delete expired store items based on TTL.

```
   256 |         self, sweep_interval_minutes: int | None = None
   257 |     ) -> asyncio.Task[None]:
>  258 |         """Periodically delete expired store items based on TTL.
   259 |
   260 |         Returns:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#296 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:353`

High-risk permission pattern: """Execute a batch of operations asynchronously.

```
   351 |
   352 |     async def abatch(self, ops: Iterable[Op]) -> list[Result]:
>  353 |         """Execute a batch of operations asynchronously.
   354 |
   355 |         Args:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#297 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:356`

High-risk permission pattern: ops: Iterable of operations to execute.

```
   354 |
   355 |         Args:
>  356 |             ops: Iterable of operations to execute.
   357 |…
   358 |         Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#298 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:407`

High-risk permission pattern: # Group all queries by namespace to execute all operations for each namespace to

```
   405 |             cur: Database cursor.
   406 |         """
>  407 |         # Group all queries by namespace to execute all operations for each namespace together
   408 |         namespace_queries = defaultdict(list)
   409 |         for prepared_query in self._get_batch_GET_ops_queries(get_ops):
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#299 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:414`

High-risk permission pattern: # Execute TTL refresh queries first

```
   412 |         # Process each namespace's operations
   413 |         for namespace, queries in namespace_queries.items():
>  414 |             # Execute TTL refresh queries first
   415 |             for query in queries:
   416 |                 if query.kind == "refresh":
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#300 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:418`

High-risk permission pattern: await cur.execute(query.query, query.params)

```
   416 |                 if query.kind == "refresh":
   417 |                     try:
>  418 |                         await cur.execute(query.query, query.params)
   419 |                     except Exception as e:
   420 |                         raise ValueError(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#301 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:424`

High-risk permission pattern: # Then execute GET queries and process results

```
   422 |                         ) from e
   423 |
>  424 |             # Then execute GET queries and process results
   425 |             for query in queries:…
   426 |                 if query.kind == "get":
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#302 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:428`

High-risk permission pattern: await cur.execute(query.query, query.params)

```
   426 |                 if query.kind == "get":
   427 |                     try:
>  428 |                         await cur.execute(query.query, query.params)
   429 |                     except Exception as e:
   430 |                         raise ValueError(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#303 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:495`

High-risk permission pattern: await cur.execute(query, params)

```
   493 |
   494 |         for query, params in queries:
>  495 |             await cur.execute(query, params)
   496 |
   497 |     async def _batch_search_ops(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#304 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:538`

High-risk permission pattern: await cur.execute(query, params)

```
   536 |             search_ops, prepared_queries, strict=False
   537 |         ):
>  538 |             await cur.execute(query, params)
   539 |             rows = await cur.fetchall()…
   540 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#305 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:562`

High-risk permission pattern: await cur.execute(update_query, update_params)

```
   560 |                         update_params = (prefix_text, *key_list)
   561 |                         try:
>  562 |                             await cur.execute(update_query, update_params)
   563 |                         except Exception as e:
   564 |                             logger.error(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#306 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/aio.py:620`

High-risk permission pattern: await cur.execute(query, params)

```
   618 |         queries = self._get_batch_list_namespaces_queries(list_ops)
   619 |         for (query, params), (idx, _) in zip(queries, list_ops, strict=False):
>  620 |             await cur.execute(query, params)
   621 |
   622 |             rows = await cur.fetchall()
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#307 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:84`

High-risk permission pattern: FOREIGN KEY (prefix, key) REFERENCES store(prefix, key) ON DELETE CASCADE

```
    82 |     updated_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP,
    83 |     PRIMARY KEY (prefix, key, field_name),
>   84 |     FOREIGN KEY (prefix, key) REFERENCES store(prefix, key) ON DELETE CASCADE
    85 | );
    86 | """,
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#308 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:204`

High-risk permission pattern: query: str # Main query to execute

```
   202 |
   203 | class PreparedGetQuery(NamedTuple):
>  204 |     query: str  # Main query to execute
   205 |     params: tuple  # Parameters for the main query…
   206 |     namespace: tuple[str, ...]  # Namespace info
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#309 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:304`

High-risk permission pattern: f"DELETE FROM store WHERE prefix = ? AND key IN ({placeholders})"

```
   302 |                 placeholders = ",".join(["?" for _ in keys])
   303 |                 query = (
>  304 |                     f"DELETE FROM store WHERE prefix = ? AND key IN ({placeholders})"
   305 |                 )
   306 |                 params = (_namespace_to_text(namespace), *keys)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#310 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:967`

High-risk permission pattern: self.conn.execute("BEGIN")

```
   965 |         with self.lock:
   966 |             if transaction:
>  967 |                 self.conn.execute("BEGIN")
   968 |
   969 |             cur = self.conn.cursor()
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#311 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:974`

High-risk permission pattern: self.conn.execute("COMMIT")

```
   972 |             finally:
   973 |                 if transaction:
>  974 |                     self.conn.execute("COMMIT")
   975 |                 cur.close()…
   976 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#312 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:997`

High-risk permission pattern: cur = self.conn.execute(

```
   995 |
   996 |             # Check current migration version
>  997 |             cur = self.conn.execute(
   998 |                 "SELECT v FROM store_migrations ORDER BY v DESC LIMIT 1"
   999 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#313 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:1009`

High-risk permission pattern: self.conn.execute("INSERT INTO store_migrations (v) VALUES (?)", (v,))

```
  1007 |             for v, sql in enumerate(self.MIGRATIONS[version + 1 :], start=version + 1):
  1008 |                 self.conn.executescript(sql)
> 1009 |                 self.conn.execute("INSERT INTO store_migrations (v) VALUES (?)", (v,))
  1010 |
  1011 |             # Apply vector migrations if index config is provided
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#314 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:1026`

High-risk permission pattern: cur = self.conn.execute(

```
  1024 |
  1025 |                 # Check current vector migration version
> 1026 |                 cur = self.conn.execute(
  1027 |                     "SELECT v FROM vector_migrations ORDER BY v DESC LIMIT 1"
  1028 |                 )
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#315 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:1040`

High-risk permission pattern: self.conn.execute(

```
  1038 |                 ):
  1039 |                     self.conn.executescript(sql)
> 1040 |                     self.conn.execute(
  1041 |                         "INSERT INTO vector_migrations (v) VALUES (?)", (v,)…
  1042 |                     )
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#316 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:1047`

High-risk permission pattern: """Delete expired store items based on TTL.

```
  1045 |
  1046 |     def sweep_ttl(self) -> int:
> 1047 |         """Delete expired store items based on TTL.
  1048 |
  1049 |         Returns:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#317 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:1053`

High-risk permission pattern: cur.execute(

```
  1051 |         """
  1052 |         with self._cursor() as cur:
> 1053 |             cur.execute(
  1054 |                 """
  1055 |                 DELETE FROM store
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#318 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:1055`

High-risk permission pattern: DELETE FROM store

```
  1053 |             cur.execute(
  1054 |                 """
> 1055 |                 DELETE FROM store
  1056 |                 WHERE expires_at IS NOT NULL AND expires_at < CURRENT_TIMESTAMP…
  1057 |                 """
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#319 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:1065`

High-risk permission pattern: """Periodically delete expired store items based on TTL.

```
  1063 |         self, sweep_interval_minutes: int | None = None
  1064 |     ) -> concurrent.futures.Future[None]:
> 1065 |         """Periodically delete expired store items based on TTL.
  1066 |
  1067 |         Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#320 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:1154`

High-risk permission pattern: """Execute a batch of operations.

```
  1152 |
  1153 |     def batch(self, ops: Iterable[Op]) -> list[Result]:
> 1154 |         """Execute a batch of operations.
  1155 |
  1156 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#321 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:1157`

High-risk permission pattern: ops (Iterable[Op]): List of operations to execute

```
  1155 |
  1156 |         Args:
> 1157 |             ops (Iterable[Op]): List of operations to execute
  1158 |
  1159 |         Returns:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#322 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:1200`

High-risk permission pattern: # Group all queries by namespace to execute all operations for each namespace to

```
  1198 |         cur: sqlite3.Cursor,
  1199 |     ) -> None:
> 1200 |         # Group all queries by namespace to execute all operations for each namespace together
  1201 |         namespace_queries = defaultdict(list)…
  1202 |         for prepared_query in self._get_batch_GET_ops_queries(get_ops):
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#323 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:1207`

High-risk permission pattern: # Execute TTL refresh queries first

```
  1205 |         # Process each namespace's operations
  1206 |         for namespace, queries in namespace_queries.items():
> 1207 |             # Execute TTL refresh queries first
  1208 |             for query in queries:
  1209 |                 if query.kind == "refresh":
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#324 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:1211`

High-risk permission pattern: cur.execute(query.query, query.params)

```
  1209 |                 if query.kind == "refresh":
  1210 |                     try:
> 1211 |                         cur.execute(query.query, query.params)
  1212 |                     except Exception as e:
  1213 |                         raise ValueError(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#325 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:1217`

High-risk permission pattern: # Then execute GET queries and process results

```
  1215 |                         ) from e
  1216 |
> 1217 |             # Then execute GET queries and process results
  1218 |             for query in queries:…
  1219 |                 if query.kind == "get":
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#326 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:1221`

High-risk permission pattern: cur.execute(query.query, query.params)

```
  1219 |                 if query.kind == "get":
  1220 |                     try:
> 1221 |                         cur.execute(query.query, query.params)
  1222 |                     except Exception as e:
  1223 |                         raise ValueError(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#327 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:1281`

High-risk permission pattern: cur.execute(query, params)

```
  1279 |
  1280 |         for query, params in queries:
> 1281 |             cur.execute(query, params)
  1282 |
  1283 |     def _batch_search_ops(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#328 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:1317`

High-risk permission pattern: cur.execute(query, params)

```
  1315 |             search_ops, prepared_queries, strict=False
  1316 |         ):
> 1317 |             cur.execute(query, params)
  1318 |             rows = cur.fetchall()
  1319 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#329 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:1339`

High-risk permission pattern: cur.execute(update_query, update_params)

```
  1337 |                         update_params = (prefix_text, *key_list)
  1338 |                         try:
> 1339 |                             cur.execute(update_query, update_params)
  1340 |                         except Exception as e:…
  1341 |                             logger.error(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#330 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/langgraph/store/sqlite/base.py:1389`

High-risk permission pattern: cur.execute(query, params)

```
  1387 |         queries = self._get_batch_list_namespaces_queries(list_ops)
  1388 |         for (query, params), (idx, _) in zip(queries, list_ops, strict=False):
> 1389 |             cur.execute(query, params)
  1390 |             results[idx] = [_decode_ns_text(row[0]) for row in cur.fetchall()]
  1391 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#331 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/tests/test_aiosqlite.py:180`

High-risk permission pattern: # If it doesn't raise an error, it should at least not execute the injection

```
    178 |                         async for c in saver.alist(None, limit=malicious_limit)  # type: ignore
    179 |                     ]
>   180 |                     # If it doesn't raise an error, it should at least not execute the injection
    181 |                     # SQLite's parameter binding will try to convert the string to an integer
    182 |                     # which will either fail or treat it as 0
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#332 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

`libs/checkpoint-sqlite/tests/test_aiosqlite.py:166`

Known injection pattern detected

```
  164 |             # which is the correct secure behavior
  165 |             malicious_limits = [
> 166 |                 "1; DROP TABLE checkpoints; --",
  167 |                 "1 OR 1=1",…
  168 |                 "999999 UNION SELECT * FROM checkpoints",
```

Remediation:
1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#333 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-sqlite/tests/test_aiosqlite.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from typing import Any
     2 |
     3 | import pytest
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#334 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/tests/test_async_store.py:34`

High-risk permission pattern: temp_file = tempfile.NamedTemporaryFile(delete=False)

```
   32 |     else:
   33 |         # Temporary file store
>  34 |         temp_file = tempfile.NamedTemporaryFile(delete=False)
   35 |         temp_file.close()
   36 |         try:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#335 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/tests/test_async_store.py:75`

High-risk permission pattern: temp_file = tempfile.NamedTemporaryFile(delete=False)

```
   73 |         yield ":memory:"
   74 |     else:
>  75 |         temp_file = tempfile.NamedTemporaryFile(delete=False)
   76 |         temp_file.close()
   77 |         try:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#336 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/tests/test_async_store.py:90`

High-risk permission pattern: store.delete(("foo", "bar"), "baz")

```
    88 |         store.get(("foo", "bar"), "baz")
    89 |     with pytest.raises(asyncio.InvalidStateError):
>   90 |         store.delete(("foo", "bar"), "baz")
    91 |     with pytest.raises(asyncio.InvalidStateError):…
    92 |         store.search(("foo", "bar"))
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#337 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/tests/test_async_store.py:241`

High-risk permission pattern: PutOp(namespace=("test",), key="key3", value=None), # Delete operation

```
   239 |         PutOp(namespace=("test",), key="key1", value={"data": "value1"}),
   240 |         PutOp(namespace=("test",), key="key2", value={"data": "value2"}),
>  241 |         PutOp(namespace=("test",), key="key3", value=None),  # Delete operation
   242 |     ]
   243 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#338 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-sqlite/tests/test_async_store.py:1`

No logging, auditing, or monitoring detected

```
>    1 | # mypy: disable-error-code="union-attr,arg-type,index,operator"
     2 | import asyncio
     3 | import os
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#339 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

`libs/checkpoint-sqlite/tests/test_sqlite.py:194`

Known injection pattern detected

```
  192 |             "x') UNION SELECT 1,2,3,4,5,6,7 --",  # UNION-based injection
  193 |             "access') = 'public' OR '1'='1' OR json_extract(value, '$.",  # Complex injection
> 194 |             "'; DROP TABLE checkpoints; --",  # Destructive injection
  195 |         ]…
  196 |
```

Remediation:
1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#340 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-sqlite/tests/test_sqlite.py:1`

No logging, auditing, or monitoring detected

```
>   1 | from typing import Any, cast
    2 |
    3 | import pytest
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#341 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/tests/test_store.py:90`

High-risk permission pattern: temp_file = tempfile.NamedTemporaryFile(delete=False)

```
   88 |     else:
   89 |         # Temporary file store
>  90 |         temp_file = tempfile.NamedTemporaryFile(delete=False)
   91 |         temp_file.close()
   92 |         try:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#342 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/tests/test_store.py:127`

High-risk permission pattern: temp_file = tempfile.NamedTemporaryFile(delete=False)

```
  125 |         conn_str = ":memory:"
  126 |     else:
> 127 |         temp_file = tempfile.NamedTemporaryFile(delete=False)
  128 |         temp_file.close()
  129 |         conn_str = temp_file.name
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#343 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/tests/test_store.py:233`

High-risk permission pattern: PutOp(namespace=("test",), key="key3", value=None), # Delete operation

```
    231 |         PutOp(namespace=("test",), key="key1", value={"data": "value1"}),
    232 |         PutOp(namespace=("test",), key="key2", value={"data": "value2"}),
>   233 |         PutOp(namespace=("test",), key="key3", value=None),  # Delete operation
    234 |     ]…
    235 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#344 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/tests/test_store.py:353`

High-risk permission pattern: # Test delete

```
    351 |             assert item_in_different_namespace is None
    352 |
>   353 |             # Test delete
    354 |             store.delete(namespace, item_id)
    355 |             deleted_item = store.get(namespace, item_id)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#345 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/tests/test_store.py:354`

High-risk permission pattern: store.delete(namespace, item_id)

```
    352 |
    353 |             # Test delete
>   354 |             store.delete(namespace, item_id)
    355 |             deleted_item = store.get(namespace, item_id)
    356 |             assert deleted_item is None
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#346 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/tests/test_store.py:399`

High-risk permission pattern: store.delete(namespace, "dummy")

```
  397 |             # Cleanup
  398 |             for namespace in test_namespaces:
> 399 |                 store.delete(namespace, "dummy")
  400 |…
  401 |     def test_search(self) -> None:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#347 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/tests/test_store.py:449`

High-risk permission pattern: store.delete(namespace, key)

```
  447 |             # Cleanup
  448 |             for namespace, key, _ in test_data:
> 449 |                 store.delete(namespace, key)
  450 |
  451 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#348 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/tests/test_store.py:473`

High-risk permission pattern: cursor.execute(

```
  471 |         # Check if vector tables exist
  472 |         cursor = store.conn.cursor()
> 473 |         cursor.execute(
  474 |             "SELECT name FROM sqlite_master WHERE type='table' AND name LIKE '%vector%'"
  475 |         )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#349 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/tests/test_store.py:879`

High-risk permission pattern: store.delete(namespace, item_id)

```
  877 |         assert (uid, "test", "documents") in namespaces
  878 |
> 879 |         store.delete(namespace, item_id)
  880 |         store.delete(namespace, new_item_id)
  881 |         deleted_item = store.get(namespace, item_id)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#350 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/tests/test_store.py:880`

High-risk permission pattern: store.delete(namespace, new_item_id)

```
   878 |
   879 |         store.delete(namespace, item_id)
>  880 |         store.delete(namespace, new_item_id)
   881 |         deleted_item = store.get(namespace, item_id)…
   882 |         assert deleted_item is None
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#351 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/tests/test_store.py:989`

High-risk permission pattern: store.delete(namespace, "dummy")

```
   987 |         # Clean up
   988 |         for namespace in test_namespaces:
>  989 |             store.delete(namespace, "dummy")
   990 |
   991 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#352 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/checkpoint-sqlite/tests/test_store.py:1049`

High-risk permission pattern: store.delete(ns, key)

```
  1047 |         for ns in test_namespaces:
  1048 |             key = f"item_{ns[-1]}"
> 1049 |             store.delete(ns, key)
  1050 |
  1051 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#353 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-sqlite/tests/test_store.py:1`

No logging, auditing, or monitoring detected

```
>    1 | # mypy: disable-error-code="union-attr,arg-type,index,operator"
     2 | import os…
     3 | import re
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#354 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/checkpoint-sqlite/tests/test_ttl.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Test SQLite store Time-To-Live (TTL) functionality."""
     2 |
     3 | import asyncio
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#355 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/examples/graph_prerelease_reqs/agent.py:41`

High-risk permission pattern: # Define the function to execute tools

```
    39 |
    40 |
>   41 | # Define the function to execute tools
    42 | tool_node = ToolNode(tools)
    43 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#356 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/examples/graph_prerelease_reqs/agent.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from collections.abc import Sequence
     2 | from typing import Annotated, Literal, TypedDict
     3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#357 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/examples/graph_prerelease_reqs_fail/agent.py:42`

High-risk permission pattern: # Define the function to execute tools

```
    40 |
    41 |
>   42 | # Define the function to execute tools
    43 | tool_node = ToolNode(tools)…
    44 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#358 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/examples/graph_prerelease_reqs_fail/agent.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from collections.abc import Sequence
     2 | from typing import Annotated, Literal, TypedDict
     3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#359 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/examples/graphs/agent.py:53`

High-risk permission pattern: # Define the function to execute tools

```
    51 |
    52 |
>   53 | # Define the function to execute tools
    54 | tool_node = ToolNode(tools)
    55 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#360 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/examples/graphs/agent.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from collections.abc import Sequence
     2 | from typing import Annotated, Literal, TypedDict
     3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#361 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/examples/graphs/storm.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import asyncio
     2 | import json…
     3 | from typing import Annotated
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#362 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/examples/graphs_reqs_a/graphs_submod/agent.py:57`

High-risk permission pattern: # Define the function to execute tools

```
     55 |
     56 |
>    57 | # Define the function to execute tools
     58 | tool_node = ToolNode(tools)
     59 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#363 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/examples/graphs_reqs_a/graphs_submod/agent.py:21`

File input near prompt/instruction handling — injection vector

```
     19 | model_oai = model_oai.bind_tools(tools)
     20 |
>    21 | prompt = open(Path(__file__).parent.parent / "prompt.txt").read()
     22 | subprompt = open(Path(__file__).parent / "subprompt.txt").read()
     23 |
```

Remediation:
1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#364 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/examples/graphs_reqs_a/graphs_submod/agent.py:22`

File input near prompt/instruction handling — injection vector

```
     20 |
     21 | prompt = open(Path(__file__).parent.parent / "prompt.txt").read()
>    22 | subprompt = open(Path(__file__).parent / "subprompt.txt").read()
     23 |
     24 |
```

Remediation:
1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#365 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/examples/graphs_reqs_a/graphs_submod/agent.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from collections.abc import Sequence
     2 | from pathlib import Path…
     3 | from typing import Annotated, Literal, TypedDict
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#366 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/examples/graphs_reqs_a/hello.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from graphs_reqs_a.graphs_submod.agent import graph  # noqa
     2 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#367 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/examples/graphs_reqs_b/graphs_submod/agent.py:57`

High-risk permission pattern: # Define the function to execute tools

```
    55 |
    56 |
>   57 | # Define the function to execute tools
    58 | tool_node = ToolNode(tools)
    59 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#368 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/examples/graphs_reqs_b/graphs_submod/agent.py:21`

File input near prompt/instruction handling — injection vector

```
    19 | model_oai = model_oai.bind_tools(tools)
    20 |
>   21 | prompt = open(Path(__file__).parent.parent / "prompt.txt").read()
    22 | subprompt = open(Path(__file__).parent / "subprompt.txt").read()
    23 |
```

Remediation:
1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#369 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/examples/graphs_reqs_b/graphs_submod/agent.py:22`

File input near prompt/instruction handling — injection vector

```
    20 |
    21 | prompt = open(Path(__file__).parent.parent / "prompt.txt").read()
>   22 | subprompt = open(Path(__file__).parent / "subprompt.txt").read()
    23 |…
    24 |
```

Remediation:
1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#370 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/examples/graphs_reqs_b/graphs_submod/agent.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from collections.abc import Sequence
     2 | from pathlib import Path
     3 | from typing import Annotated, Literal, TypedDict
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#371 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/examples/graphs_reqs_b/hello.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from graphs_submod.agent import graph  # noqa
     2 | from utils.greeter import greet
     3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#372 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/cli/examples/graphs_reqs_b/utils/greeter.py:1

No logging, auditing, or monitoring detected

```
>    1 | def greet():
     2 |     print("Hello, world!")…
     3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#373 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/cli/examples/my_app.py:1

No logging, auditing, or monitoring detected

```
>    1 | from contextlib import asynccontextmanager
     2 | from contextvars import ContextVar
     3 | from typing import Any
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#374 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/cli/generate_schema.py:1

No logging, auditing, or monitoring detected

```
>    1 | #!/usr/bin/env python3
     2 | """
     3 | Script to generate a JSON schema for the langgraph-cli Config class.
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#375 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/cli/js-examples/.eslintrc.cjs:1

No logging, auditing, or monitoring detected

```
>    1 | module.exports = {
     2 |   extends: [
     3 |     "eslint:recommended",
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#376 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/cli/js-examples/jest.config.js:1

No logging, auditing, or monitoring detected

```
>    1 | export default {
     2 |   preset: "ts-jest/presets/default-esm",…
     3 |   moduleNameMapper: {
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#377 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

libs/cli/js-examples/src/agent/graph.ts:45

Dependency without integrity verification

```
    43 |    *
    44 |    * ```ts
>   45 |    * import OpenAI from "openai";
    46 |    * const openai = new OpenAI({
    47 |    *   apiKey: process.env.OPENAI_API_KEY,
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#378 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/cli/js-examples/src/agent/state.ts:1

No logging, auditing, or monitoring detected

```
>    1 | import { BaseMessage, BaseMessageLike } from "@langchain/core/messages";
     2 | import { Annotation, messagesStateReducer } from "@langchain/langgraph";
     3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#379 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/cli/js-examples/tests/agent.test.ts:1

No logging, auditing, or monitoring detected

```
>    1 | import { describe, it, expect } from "@jest/globals";
     2 | import { route } from "../src/agent/graph.js";
     3 | describe("Routers", () => {
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#380 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/js-examples/tests/graph.int.test.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | import { describe, it, expect } from "@jest/globals";
     2 | import { graph } from "../src/agent/graph.js";…
     3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#381 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/js-monorepo-example/.eslintrc.cjs:1`

No logging, auditing, or monitoring detected

```
>    1 | module.exports = {
     2 |   extends: [
     3 |     "eslint:recommended",
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#382 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/js-monorepo-example/apps/agent/src/graph.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Simple LangGraph.js example for monorepo testing
     3 |  */
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#383 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/js-monorepo-example/apps/agent/src/state.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | import { BaseMessage, BaseMessageLike } from "@langchain/core/messages";
     2 | import { Annotation, messagesStateReducer } from "@langchain/langgraph";
     3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#384 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/js-monorepo-example/libs/shared/src/index.ts:1`

No logging, auditing, or monitoring detected

```
>    1 | /**
     2 |  * Simple utility functions for monorepo testing…
     3 |  */
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#385 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/langgraph_cli/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | __version__ = "0.4.17"
     2 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#386 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/langgraph_cli/__main__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from .cli import cli
     2 |
     3 | if __name__ == "__main__":
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#387 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/langgraph_cli/analytics.py:74`

File input near prompt/instruction handling — injection vector

```
    72 |
    73 |     try:
>   74 |         urllib.request.urlopen(req)
    75 |     except urllib.error.URLError:
    76 |         pass
```

Remediation:
1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#388 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/langgraph_cli/analytics.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import functools
     2 | import json…
     3 | import os
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#389 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

`libs/cli/langgraph_cli/analytics.py:7`

Dynamic HTTP with sensitive data context

```
     5 | import platform
     6 | import threading
>    7 | import urllib.error
     8 | import urllib.request
     9 | from typing import Any, TypedDict
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#390 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

`libs/cli/langgraph_cli/analytics.py:8`

Dynamic HTTP with sensitive data context

```
     6 | import threading
     7 | import urllib.error
>    8 | import urllib.request
     9 | from typing import Any, TypedDict
    10 |
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#391 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

`libs/cli/langgraph_cli/analytics.py:66`

Dynamic HTTP with sensitive data context

```
    64 |     supabase_url = SUPABASE_URL
    65 |
>   66 |     req = urllib.request.Request(
    67 |         f"{supabase_url}/rest/v1/logs",
    68 |         data=json.dumps(data).encode("utf-8"),
```

Remediation:
1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#392 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

`libs/cli/langgraph_cli/analytics.py:74`

Dynamic HTTP with sensitive data context

```
    72 |
    73 |     try:
>   74 |         urllib.request.urlopen(req)
    75 |     except urllib.error.URLError:…
    76 |         pass
```

Remediation:
1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#393 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

`libs/cli/langgraph_cli/analytics.py:75`

Dynamic HTTP with sensitive data context

```
    73 |     try:
    74 |         urllib.request.urlopen(req)
>   75 |     except urllib.error.URLError:
    76 |         pass
    77 |
```

Remediation:
1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#394 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/langgraph_cli/cli.py:775`

High-risk permission pattern: invoke_without_command=True, # allow `deploy` click group to execute without co

```
   773 |     ),
   774 |     context_settings=dict(ignore_unknown_options=True, allow_extra_args=True),
>  775 |     invoke_without_command=True,  # allow `deploy` click group to execute without command
   776 | )
   777 | @_deploy_base_options(include_docker_args=False, validate_config_path=False)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#395 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/langgraph_cli/cli.py:783`

High-risk permission pattern: # otherwise, we return None here and click will proceed to actually run the subc

```
   781 |     # We register deploy as both a group and a command here.
   782 |     # if we detect no subcommand, we run _deploy (basically run langgraph deploy as a top level
command)
>  783 |     # otherwise, we return None here and click will proceed to actually run the subcommand (list or
delete)
   784 |     if ctx.invoked_subcommand is not None:…
   785 |         return
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#396 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/langgraph_cli/cli.py:1214`

High-risk permission pattern: help="Delete without prompting for confirmation.",

```
  1212 |     is_flag=True,
  1213 |     default=False,
> 1214 |     help="Delete without prompting for confirmation.",
  1215 | )
  1216 | @click.argument("deployment_id")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#397 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/langgraph_cli/cli.py:1218`

High-risk permission pattern: "delete",

```
  1216 | @click.argument("deployment_id")
  1217 | @deploy.command(
> 1218 |     "delete",
  1219 |     help=(
  1220 |         "[Beta] Delete a LangSmith Deployment.\n\n"
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#398 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/langgraph_cli/cli.py:1220`

High-risk permission pattern: "[Beta] Delete a LangSmith Deployment.\n\n"

```
  1218 |     "delete",
  1219 |     help=(
> 1220 |         "[Beta] Delete a LangSmith Deployment.\n\n"
  1221 |         "Use the `deploy list` command to list deployment IDs."
  1222 |     ),
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#399 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/langgraph_cli/cli.py:1230`

High-risk permission pattern: f"Are you sure you want to delete deployment ID {deployment_id}? (Y/n)",

```
  1228 |         response = click.prompt(
  1229 |             click.style(
> 1230 |                 f"Are you sure you want to delete deployment ID {deployment_id}? (Y/n)",
  1231 |                 fg="yellow",…
  1232 |             ),
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#400 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/langgraph_cli/cli.py:151`

File input near prompt/instruction handling — injection vector

```
   149 |     config_data = {"auths": {registry_host: {"auth": auth_b64}}}
   150 |     with tempfile.TemporaryDirectory() as tmpdir:
>  151 |         with open(os.path.join(tmpdir, "config.json"), "w") as f:
   152 |             json_mod.dump(config_data, f)
   153 |         yield tmpdir
```

Remediation:
1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#401 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/langgraph_cli/cli.py:1552`

File input near prompt/instruction handling — injection vector

```
  1550 |         api_version=api_version,
  1551 |     )
> 1552 |     with open(str(save_path), "w", encoding="utf-8") as f:
  1553 |         f.write(dockerfile)
  1554 |     secho("'  Created: Dockerfile", fg="green")
```

Remediation:
1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#402 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/langgraph_cli/cli.py:1568`

File input near prompt/instruction handling — injection vector

```
  1566 |         # Add docker compose and related files
  1567 |         # Add .dockerignore file in the same directory as the Dockerfile
> 1568 |         with open(str(save_path.parent / ".dockerignore"), "w", encoding="utf-8") as f:
  1569 |             f.write(_get_docker_ignore_content())…
  1570 |         secho("'  Created: .dockerignore", fg="green")
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#403 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/langgraph_cli/cli.py:1574`

File input near prompt/instruction handling — injection vector

```
  1572 |         # Generate a docker-compose.yml file
  1573 |         path = str(save_path.parent / "docker-compose.yml")
> 1574 |         with open(path, "w", encoding="utf-8") as f:
  1575 |             with Runner() as runner:
  1576 |                 capabilities = langgraph_cli.docker.check_capabilities(runner)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#404 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/langgraph_cli/cli.py:1601`

File input near prompt/instruction handling — injection vector

```
  1599 |         if not (save_path.parent / ".env").exists():
  1600 |             # Also add an empty .env file
> 1601 |             with open(str(save_path.parent / ".env"), "w", encoding="utf-8") as f:
  1602 |                 f.writelines(
  1603 |                     [
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#405 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/langgraph_cli/config.py:82`

High-risk permission pattern: packages_rm += ' && find /usr/local/bin -name "pip*" -delete || true'

```
    80 |         )
    81 |         if "pip" in to_uninstall:
>   82 |             packages_rm += ' && find /usr/local/bin -name "pip*" -delete || true'
    83 |         commands.append(f"RUN rm -rf {packages_rm}")
    84 |         wolfi_packages_rm = " ".join(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#406 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/langgraph_cli/config.py:88`

High-risk permission pattern: wolfi_packages_rm += ' && find /usr/bin -name "pip*" -delete || true'

```
    86 |         )
    87 |         if "pip" in to_uninstall:
>   88 |             wolfi_packages_rm += ' && find /usr/bin -name "pip*" -delete || true'
    89 |         commands.append(f"RUN rm -rf {wolfi_packages_rm}")…
    90 |         if pip_installer == "uv":
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#407 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/langgraph_cli/config.py:311`

File input near prompt/instruction handling — injection vector

```
   309 | def validate_config_file(config_path: pathlib.Path) -> Config:
   310 |     """Load and validate a configuration file."""
>  311 |     with open(config_path) as f:
   312 |         config = json.load(f)
   313 |     validated = validate_config(config)
```

Remediation:
1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#408 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/langgraph_cli/config.py:320`

File input near prompt/instruction handling — injection vector

```
   318 |         if package_json_path.is_file():
   319 |             try:
>  320 |                 with open(package_json_path) as f:
   321 |                     package_json = json.load(f)
   322 |                     if "engines" in package_json:
```

Remediation:
1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#409 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/langgraph_cli/config.py:821`

File input near prompt/instruction handling — injection vector

```
  819 |     def get_pkg_manager_name():
  820 |         try:
> 821 |             with open(config_path.parent / "package.json") as f:
  822 |                 pkg = json.load(f)…
  823 |
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#410 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

`libs/cli/langgraph_cli/config.py:83`

Known injection pattern detected

```
   81 |         if "pip" in to_uninstall:
   82 |             packages_rm += ' && find /usr/local/bin -name "pip*" -delete || true'
>  83 |         commands.append(f"RUN rm -rf {packages_rm}")
   84 |         wolfi_packages_rm = " ".join(
   85 |             f"/usr/lib/python*/site-packages/{pack}*" for pack in to_uninstall
```

Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#411 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

`libs/cli/langgraph_cli/config.py:89`

Known injection pattern detected

```
   87 |         if "pip" in to_uninstall:
   88 |             wolfi_packages_rm += ' && find /usr/bin -name "pip*" -delete || true'
>  89 |         commands.append(f"RUN rm -rf {wolfi_packages_rm}")
   90 |         if pip_installer == "uv":
   91 |             commands.append(
```

Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#412 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/langgraph_cli/config.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import copy
     2 | import json
     3 | import os
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#413 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`libs/cli/langgraph_cli/constants.py:5`

Potential secret: possible hardcoded secret

```
     3 |
     4 | # analytics
>    5 | SUPABASE_PUBLIC_API_KEY = "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJzdXBhYmFzZSIsInJlZiI6Imt6c
mxwcG9qaW5wY3l5YWlweG5iIiwicm9sZSI6ImFub24iLCJpYXQiOjE3MTkyNTc1NzksImV4cCI6MjAzNDgzMzU3OX0.kkVOlLz3BxemA5nP-
vat3K4qRtrDuO4SwZSR_htcX9c"
     6 | SUPABASE_URL = "https://kzrlppojinpcyyaipxnb.supabase.co"…
     7 |
```

Remediation:
1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#414 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/langgraph_cli/constants.py:1`

No logging, auditing, or monitoring detected

```
>    1 | DEFAULT_CONFIG = "langgraph.json"
     2 | DEFAULT_PORT = 8123
     3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#415 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/langgraph_cli/docker.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import json
     2 | import pathlib
     3 | import shutil
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#416 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/langgraph_cli/helpers.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Helpers for the ``langgraph logs`` CLI command."""
     2 |
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#417 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/langgraph_cli/host_backend.py:87`

High-risk permission pattern: return self._request("DELETE", f"/v2/deployments/{deployment_id}")

```
    85 |
    86 |     def delete_deployment(self, deployment_id: str) -> None:
>   87 |         return self._request("DELETE", f"/v2/deployments/{deployment_id}")
    88 |…
    89 |     def request_push_token(self, deployment_id: str) -> dict[str, Any]:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#418 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/langgraph_cli/host_backend.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """HTTP client for LangGraph host backend deployments."""
     2 |
     3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#419 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/langgraph_cli/progress.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import sys
     2 | import threading
     3 | import time
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#420 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/langgraph_cli/schemas.py:26`

High-risk permission pattern: If provided, the store will periodically delete expired items based on the TTL.

```
    24 |     """Optional. Interval in minutes between TTL sweep iterations.
    25 |
>   26 |     If provided, the store will periodically delete expired items based on the TTL.
    27 |     If omitted, no automatic sweeping will occur.
    28 |     """
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#421 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/langgraph_cli/schemas.py:110`

High-risk permission pattern: strategy: Literal["delete", "keep_latest"]

```
  108 |     """Configure a default TTL for checkpointed data within threads."""
  109 |
> 110 |     strategy: Literal["delete", "keep_latest"]
  111 |     """Action taken when a thread exceeds its TTL.…
  112 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#422 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/langgraph_cli/schemas.py:113`

High-risk permission pattern: - "delete": Remove the thread and all its data entirely.

```
  111 |     """Action taken when a thread exceeds its TTL.
  112 |
> 113 |     - "delete": Remove the thread and all its data entirely.
  114 |     - "keep_latest": Prune old checkpoints but keep the thread and its latest state.
  115 |     """
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#423 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/langgraph_cli/templates.py:104`

File input near prompt/instruction handling — injection vector

```
  102 |     click.secho(f"URL: {repo_url}", fg="yellow")
  103 |     try:
> 104 |         with request.urlopen(repo_url) as response:
  105 |             if response.status == 200:
  106 |                 with ZipFile(BytesIO(response.read())) as zip_file:
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#424 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/langgraph_cli/templates.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import os
     2 | import shutil
     3 | import sys
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#425 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

`libs/cli/langgraph_cli/templates.py:5`

Dynamic HTTP with sensitive data context

```
     3 | import sys
     4 | from io import BytesIO
>    5 | from urllib import error, request
     6 | from zipfile import ZipFile…
     7 |
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#426 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/langgraph_cli/util.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from collections.abc import Sequence
     2 |
     3 | import click
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#427 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/langgraph_cli/version.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Main entrypoint into package."""
     2 |
     3 | from importlib import metadata
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#428 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/python-monorepo-example/apps/agent/src/agent/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Agent package."""
     2 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#429 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/python-monorepo-example/apps/agent/src/agent/graph.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Simple LangGraph agent for monorepo testing."""
     2 |…
     3 | from common import get_common_prefix
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#430 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/python-monorepo-example/apps/agent/src/agent/state.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """State definition for the agent."""
     2 |
     3 | from collections.abc import Sequence
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#431 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/python-monorepo-example/libs/common/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Common helper functions package."""
     2 |
     3 | from .helpers import get_common_prefix
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#432 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/python-monorepo-example/libs/common/helpers.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Common helper functions."""
     2 |
     3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#433 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/python-monorepo-example/libs/shared/src/shared/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Shared utilities package."""
     2 |…
     3 | from .utils import get_dummy_message
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#434 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/python-monorepo-example/libs/shared/src/shared/utils.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Shared utility functions."""
     2 |
     3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#435 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/tests/integration_tests/test_cli.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import pytest
     2 | import requests
     3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#436 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/tests/unit_tests/agent.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import asyncio
     2 | import os
     3 | from collections.abc import Sequence
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#437 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/tests/unit_tests/cli/test_cli.py:299`

High-risk permission pattern: assert "deploy delete" in result.output

```
   297 |     assert "deploy" in result.output
   298 |     assert "deploy list" in result.output
>  299 |     assert "deploy delete" in result.output
   300 |     assert "[Beta] List LangSmith Deployments." in result.output…
   301 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#438 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/tests/unit_tests/cli/test_cli.py:425`

High-risk permission pattern: "delete",

```
   423 |         [
   424 |             "deploy",
>  425 |             "delete",
   426 |             "--api-key",
   427 |             "test-key",
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#439 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/tests/unit_tests/cli/test_cli.py:443`

High-risk permission pattern: "Are you sure you want to delete deployment ID dep-123? (Y/n):" in result.output

```
   441 |     }
   442 |     assert (
>  443 |         "Are you sure you want to delete deployment ID dep-123? (Y/n):" in result.output
   444 |     )
   445 |     assert result.output.strip().endswith("Deleted deployment dep-123.")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#440 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/tests/unit_tests/cli/test_cli.py:467`

High-risk permission pattern: "delete",

```
   465 |         [
   466 |             "deploy",
>  467 |             "delete",
   468 |             "--api-key",
   469 |             "test-key",
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#441 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/tests/unit_tests/cli/test_cli.py:502`

High-risk permission pattern: "delete",

```
   500 |         [
   501 |             "deploy",
>  502 |             "delete",
   503 |             "--force",…
   504 |             "--api-key",
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#442 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/tests/unit_tests/cli/test_cli.py:513`

High-risk permission pattern: assert "Are you sure you want to delete deployment ID dep-123?" not in result.ou

```
   511 |
   512 |     assert result.exit_code == 0, result.output
>  513 |     assert "Are you sure you want to delete deployment ID dep-123?" not in result.output
   514 |     assert captured == {
   515 |         "host_url": "https://api.example.com",
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#443 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/tests/unit_tests/cli/test_cli.py:41`

File input near prompt/instruction handling — injection vector

```
    39 |
    40 |         # Write the provided dictionary content to config.json
>   41 |         with open(config_path, "w", encoding="utf-8") as config_file:
    42 |             json.dump(config_content, config_file)
    43 |
```

Remediation:
1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#444 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/tests/unit_tests/cli/test_cli.py:616`

File input near prompt/instruction handling — injection vector

```
  614 |
  615 |         assert save_path.exists()
> 616 |         with open(save_path) as f:
  617 |             dockerfile = f.read()…
  618 |             assert re.match("FROM langchain/langgraph-server:0.2-py3.*", dockerfile), (
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#445 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/tests/unit_tests/cli/test_cli.py:847`

File input near prompt/instruction handling — injection vector

```
  845 |         # Check if Dockerfile was created and contains correct FROM line
  846 |         assert save_path.exists()
> 847 |         with open(save_path) as f:
  848 |             dockerfile = f.read()
  849 |             assert "FROM langchain/langgraph-api:0.2.74-py3.11" in dockerfile
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#446 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/tests/unit_tests/cli/test_cli.py:887`

File input near prompt/instruction handling — injection vector

```
  885 |         # Check if Dockerfile was created and contains correct FROM line
  886 |         assert save_path.exists()
> 887 |         with open(save_path) as f:
  888 |             dockerfile = f.read()
  889 |             assert "FROM my-registry/custom-api:1.0.0-py3.12-wolfi" in dockerfile
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#447 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/tests/unit_tests/cli/test_cli.py:923`

File input near prompt/instruction handling — injection vector

```
  921 |         # Check if Dockerfile was created and contains correct FROM line
  922 |         assert save_path.exists()
> 923 |         with open(save_path) as f:
  924 |             dockerfile = f.read()
  925 |             assert "FROM langchain/langgraphjs-api:0.2.74-node20" in dockerfile
```

Remediation:
1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#448 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/tests/unit_tests/cli/test_cli.py:1090`

File input near prompt/instruction handling — injection vector

```
  1088 |
  1089 |         assert save_path.exists()
> 1090 |         with open(save_path) as f:
  1091 |             dockerfile = f.read()…
  1092 |             assert "FROM langchain/langgraph-executor:3.11" in dockerfile
```

Remediation:
1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#449 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/tests/unit_tests/cli/test_cli.py:1123`

File input near prompt/instruction handling — injection vector

```
  1121 |         assert result.exit_code == 0, result.output
  1122 |         assert save_path.exists()
> 1123 |         with open(save_path) as f:
  1124 |             dockerfile = f.read()
  1125 |             assert "FROM langchain/langgraph-api:3.11" in dockerfile
```

Remediation:
1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#450 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/tests/unit_tests/cli/test_cli.py:1158`

File input near prompt/instruction handling — injection vector

```
  1156 |         assert result.exit_code == 0, result.output
  1157 |         assert save_path.exists()
> 1158 |         with open(save_path) as f:
  1159 |             dockerfile = f.read()
  1160 |             assert "FROM my-custom-executor:latest" in dockerfile
```

Remediation:
1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#451 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

`libs/cli/tests/unit_tests/cli/test_cli.py:19`

Dependency without integrity verification

```
    17 |
    18 | FORMATTED_CLEANUP_LINES = _get_pip_cleanup_lines(
>   19 |     install_cmd="uv pip install --system",
    20 |     to_uninstall=("pip", "setuptools", "wheel"),…
    21 |     pip_installer="uv",
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#452 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

`libs/cli/tests/unit_tests/cli/test_cli.py:154`

Dependency without integrity verification

```
   152 |                 # -- End of local package ../../.. --
   153 |                 # -- Installing all local dependencies --
>  154 |                 RUN for dep in /deps/*; do             echo "Installing $$dep";             if [ -d
"$$dep" ]; then                 echo "Installing $$dep";                 (cd "$$dep" &&
PYTHONDONTWRITEBYTECODE=1 uv pip install --system --no-cache-dir -c /api/constraints.txt -e .);
fi;         done
   155 |                 # -- End of local dependencies install --
   156 |                 ENV LANGSERVE_GRAPHS='{{"agent": "agent.py:graph"}}'
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#453 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/tests/unit_tests/cli/test_cli.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import json
     2 | import pathlib
     3 | import re
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#454 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/tests/unit_tests/cli/test_templates.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Unit tests for the 'new' CLI command.
     2 |
     3 | This command creates a new LangGraph project using a specified template.
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#455 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/tests/unit_tests/conftest.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import os
     2 | from unittest.mock import patch…
     3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#456 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/tests/unit_tests/graphs/agent.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from langgraph.func import entrypoint
     2 |
     3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#457 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/tests/unit_tests/helpers.py:1`

No logging, auditing, or monitoring detected

```
>    1 | def clean_empty_lines(input_str: str):
     2 |     return "\n".join(filter(None, input_str.splitlines()))
     3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#458 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/tests/unit_tests/test_config.py:315`

File input near prompt/instruction handling — injection vector

```
   313 |
   314 |         node_config = {"node_version": "20", "graphs": {"agent": "./agent.js:graph"}}
>  315 |         with open(config_path, "w") as f:
   316 |             json.dump(node_config, f)…
   317 |
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#459 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/tests/unit_tests/test_config.py:321`

File input near prompt/instruction handling — injection vector

```
   319 |
   320 |         package_json = {"name": "test", "engines": {"node": "20"}}
>  321 |         with open(tmpdir_path / "package.json", "w") as f:
   322 |             json.dump(package_json, f)
   323 |         validate_config_file(config_path)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#460 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/tests/unit_tests/test_config.py:326`

File input near prompt/instruction handling — injection vector

```
   324 |
   325 |         package_json["engines"]["node"] = "20.18"
>  326 |         with open(tmpdir_path / "package.json", "w") as f:
   327 |             json.dump(package_json, f)
   328 |         with pytest.raises(click.UsageError, match="Use major version only"):
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#461 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/tests/unit_tests/test_config.py:332`

File input near prompt/instruction handling — injection vector

```
   330 |
   331 |         package_json["engines"] = {"node": "18"}
>  332 |         with open(tmpdir_path / "package.json", "w") as f:
   333 |             json.dump(package_json, f)
   334 |         with pytest.raises(click.UsageError, match="must be >= 20"):
```

Remediation:
1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#462 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/tests/unit_tests/test_config.py:338`

File input near prompt/instruction handling — injection vector

```
  336 |
  337 |         package_json["engines"] = {"node": "20", "deno": "1.0"}
> 338 |         with open(tmpdir_path / "package.json", "w") as f:
  339 |             json.dump(package_json, f)…
  340 |         with pytest.raises(click.UsageError, match="Only 'node' engine is supported"):
```

Remediation:
1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#463 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/tests/unit_tests/test_config.py:343`

File input near prompt/instruction handling — injection vector

```
  341 |             validate_config_file(config_path)
  342 |
> 343 |         with open(tmpdir_path / "package.json", "w") as f:
  344 |             f.write("{invalid json")
  345 |         with pytest.raises(click.UsageError, match="Invalid package.json"):
```

Remediation:
1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#464 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/tests/unit_tests/test_config.py:353`

File input near prompt/instruction handling — injection vector

```
  351 |             "graphs": {"agent": "./agent.py:graph"},
  352 |         }
> 353 |         with open(config_path, "w") as f:
  354 |             json.dump(python_config, f)
  355 |
```

Remediation:
1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#465 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/tests/unit_tests/test_config.py:364`

File input near prompt/instruction handling — injection vector

```
  362 |             "{invalid json",
  363 |         ]:
> 364 |             with open(tmpdir_path / "package.json", "w") as f:
  365 |                 if isinstance(package_content, dict):…
  366 |                     json.dump(package_content, f)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#466 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

`libs/cli/tests/unit_tests/test_config.py:658`

File input near prompt/instruction handling — injection vector

```
  656 | dependencies = ["langchain"]"""
  657 |     pyproject_path = "tests/unit_tests/pyproject.toml"
> 658 |     with open(pyproject_path, "w") as f:
  659 |         f.write(pyproject_str)
  660 |
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#467 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/tests/unit_tests/test_config.py:1`

No logging, auditing, or monitoring detected

```
>   1 | import copy
    2 | import json
    3 | import os
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#468 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/tests/unit_tests/test_deploy_helpers.py:1`

No logging, auditing, or monitoring detected

```
>   1 | import base64
    2 | import json
    3 | import os
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#469 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/tests/unit_tests/test_docker.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import pytest
     2 |…
     3 | from langgraph_cli.docker import (
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#470 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/cli/tests/unit_tests/test_host_backend.py:77`

High-risk permission pattern: assert c._request("DELETE", "/test") is None

```
    75 |         timeout=30,
    76 |     )
>   77 |     assert c._request("DELETE", "/test") is None
    78 |
    79 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#471 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/tests/unit_tests/test_host_backend.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import httpx
     2 | import pytest
     3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#472 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/tests/unit_tests/test_logs_helpers.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from langgraph_cli.helpers import format_log_entry, format_timestamp, level_fg
     2 |
     3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#473 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/cli/tests/unit_tests/test_util.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from unittest.mock import patch
     2 |…
     3 | from langgraph_cli.util import (
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#474 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/bench/__main__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import random
     2 | from uuid import uuid4
     3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#475 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/bench/fanout_to_subgraph.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import operator
     2 | from typing import Annotated
     3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#476 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/bench/pydantic_state.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import operator
     2 | from collections.abc import Sequence
     3 | from functools import partial
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#477 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/bench/react_agent.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from typing import Any
     2 | from uuid import uuid4…
     3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#478 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/bench/sequential.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Create a sequential no-op graph consisting of a few hundred nodes."""
     2 |
     3 | from langgraph._internal._runnable import RunnableCallable
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#479 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/bench/serde_allowlist.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from collections import deque
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#480 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/bench/wide_dict.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import operator
     2 | from collections.abc import Sequence
     3 | from functools import partial
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#481 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/bench/wide_state.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import operator
     2 | from collections.abc import Sequence…
     3 | from dataclasses import dataclass, field
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#482 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/_internal/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Internal modules for LangGraph.
     2 |
     3 | This module is not part of the public API, and thus stability is not guaranteed.
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#483 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/_internal/_cache.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from collections.abc import Hashable, Mapping, Sequence
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#484 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/_internal/_config.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from collections import ChainMap
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#485 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/_internal/_constants.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Constants used for Pregel operations."""
     2 |…
     3 | import sys
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#486 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/_internal/_fields.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import dataclasses
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#487 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/_internal/_future.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import asyncio
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#488 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/_internal/_pydantic.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import sys
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#489 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/_internal/_queue.py:1`

No logging, auditing, or monitoring detected

```
>    1 | # type: ignore
     2 | from __future__ import annotations…
     3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#490 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/_internal/_replay.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Replay state for subgraph checkpoint loading during time-travel."""
     2 |
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#491 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/_internal/_retry.py:1`

No logging, auditing, or monitoring detected

```
>    1 | def default_retry_on(exc: Exception) -> bool:
     2 |     import httpx
     3 |     import requests
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#492 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/_internal/_runnable.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import asyncio
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#493 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/_internal/_scratchpad.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import dataclasses
     2 | from collections.abc import Callable…
     3 | from typing import Any
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#494 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/_internal/_typing.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Private typing utilities for LangGraph."""
     2 |
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#495 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/channels/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from langgraph.channels.any_value import AnyValue
     2 | from langgraph.channels.base import BaseChannel
     3 | from langgraph.channels.binop import BinaryOperatorAggregate
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#496 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/channels/any_value.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from collections.abc import Sequence
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#497 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/channels/base.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |…
     3 | from abc import ABC, abstractmethod
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#498 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/channels/binop.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import collections.abc
     2 | from collections.abc import Callable, Sequence
     3 | from typing import Any, Generic
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#499 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/channels/ephemeral_value.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from collections.abc import Sequence
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#500 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/channels/last_value.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from collections.abc import Sequence
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#501 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/channels/named_barrier_value.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from collections.abc import Sequence
     2 | from typing import Generic…
     3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#502 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/channels/topic.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from collections.abc import Iterator, Sequence
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#503 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/channels/untracked_value.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from collections.abc import Sequence
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#504 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/config.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import asyncio
     2 | import sys
     3 | from typing import Any
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#505 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/constants.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import sys
     2 | from typing import Any…
     3 | from warnings import warn
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#506 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/errors.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from collections.abc import Sequence
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#507 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/func/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import functools
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#508 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/graph/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from langgraph.constants import END, START
     2 | from langgraph.graph.message import MessageGraph, MessagesState, add_messages
     3 | from langgraph.graph.state import StateGraph
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#509 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/graph/_branch.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |…
     3 | from collections.abc import Awaitable, Callable, Hashable, Sequence
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#510 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/graph/_node.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from collections.abc import Sequence
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#511 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/langgraph/graph/message.py:229`

High-risk permission pattern: f"Attempting to delete a message with an ID that doesn't exist ('{m.id}')"

```
   227 |             if isinstance(m, RemoveMessage):
   228 |                 raise ValueError(
>  229 |                     f"Attempting to delete a message with an ID that doesn't exist ('{m.id}')"
   230 |                 )
   231 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#512 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/graph/message.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import uuid
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#513 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/langgraph/graph/ui.py:134`

High-risk permission pattern: """Delete a UI message by ID from the UI state.

```
   132 |
   133 | def delete_ui_message(id: str, *, state_key: str = "ui") -> RemoveUIMessage:
>  134 |     """Delete a UI message by ID from the UI state.
   135 |…
   136 |     This function creates and sends a message to remove a UI component from the current state.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#514 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/langgraph/graph/ui.py:220`

High-risk permission pattern: f"Attempting to delete an UI message with an ID that doesn't exist ('{msg_id}')"

```
   218 |             if msg.get("type") == "remove-ui":
   219 |                 raise ValueError(
>  220 |                     f"Attempting to delete an UI message with an ID that doesn't exist ('{msg_id}')"
   221 |                 )
   222 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#515 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/graph/ui.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from typing import Any, Literal, cast
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#516 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/managed/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from langgraph.managed.is_last_step import IsLastStep, RemainingSteps
     2 |
     3 | __all__ = ("IsLastStep", "RemainingSteps")
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#517 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/managed/base.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from abc import ABC, abstractmethod
     2 | from inspect import isclass…
     3 | from typing import (
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#518 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/managed/is_last_step.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from typing import Annotated
     2 |
     3 | from langgraph._internal._scratchpad import PregelScratchpad
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#519 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/pregel/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from langgraph.pregel.main import NodeBuilder, Pregel
     2 |
     3 | __all__ = ("Pregel", "NodeBuilder")
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#520 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/pregel/_call.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Utility to convert a user provided function into a Runnable with a ChannelWrite."""
     2 |
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#521 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/pregel/_checkpoint.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |…
     3 | from collections.abc import Mapping
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#522 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/pregel/_draw.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from collections import defaultdict
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#523 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/pregel/_executor.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import asyncio
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#524 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/langgraph/pregel/_loop.py:462`

High-risk permission pattern: """Execute a single iteration of the Pregel loop.

```
   460 |
   461 |     def tick(self) -> bool:
>  462 |         """Execute a single iteration of the Pregel loop.
   463 |
   464 |         Returns:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#525 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/langgraph/pregel/_loop.py:562`

High-risk permission pattern: # only replay (re-execute) done tasks on the first tick

```
  560 |         # clear pending writes
  561 |         self.checkpoint_pending_writes.clear()
> 562 |         # only replay (re-execute) done tasks on the first tick
  563 |         self.is_replaying = False…
  564 |         # save checkpoint
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#526 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/pregel/_loop.py:1`

No logging, auditing, or monitoring detected

```
>   1 | from __future__ import annotations
    2 |
    3 | import asyncio
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#527 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/pregel/_messages.py:1`

No logging, auditing, or monitoring detected

```
>   1 | from __future__ import annotations
    2 |
    3 | from collections.abc import AsyncIterator, Callable, Iterator, Sequence
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#528 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/pregel/_read.py:1`

No logging, auditing, or monitoring detected

```
>   1 | from __future__ import annotations
    2 |
    3 | from collections.abc import AsyncIterator, Callable, Iterator, Mapping, Sequence
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#529 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/langgraph/pregel/_runner.py:224`

High-risk permission pattern: # execute tasks, and wait for one to fail or all to finish.

```
   222 |             )
   223 |             futures[fut] = t
>  224 |         # execute tasks, and wait for one to fail or all to finish.
   225 |         # each task is independent from all other concurrent tasks…
   226 |         # yield updates/debug output as each task finishes
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#530 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/langgraph/pregel/_runner.py:372`

High-risk permission pattern: # execute tasks, and wait for one to fail or all to finish.

```
   370 |             )
   371 |             futures[fut] = t
>  372 |         # execute tasks, and wait for one to fail or all to finish.
   373 |         # each task is independent from all other concurrent tasks
   374 |         # yield updates/debug output as each task finishes
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#531 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/pregel/_runner.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import asyncio
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#532 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/pregel/_utils.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import ast
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#533 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/pregel/_validate.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |…
     3 | from collections.abc import Mapping, Sequence
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#534 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/pregel/_write.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from collections.abc import Callable, Sequence
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#535 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/pregel/debug.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from collections.abc import Iterable, Iterator, Mapping, Sequence
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#536 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/langgraph/pregel/main.py:348`

High-risk permission pattern: - **Plan: Determine which **actors** to execute in this step. For example,**

```
   346 |     Each step consists of three phases:
   347 |
>  348 |     - **Plan**: Determine which **actors** to execute in this step. For example,
   349 |         in the first step, select the **actors** that subscribe to the special
   350 |         **input** channels; in subsequent steps,
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#537 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/langgraph/pregel/main.py:352`

High-risk permission pattern: - **Execution: Execute all selected **actors** in parallel,**

```
   350 |         **input** channels; in subsequent steps,
   351 |         select the **actors** that subscribe to channels updated in the previous step.
>  352 |     - **Execution**: Execute all selected **actors** in parallel,
   353 |         until all complete, or one fails, or a timeout is reached. During this…
   354 |         phase, channel updates are invisible to actors until the next step.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#538 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/langgraph/pregel/main.py:1831`

High-risk permission pattern: # execute task

```
  1829 |                 run_task_ids.append(task_id)
  1830 |                 run = RunnableSequence(*writers) if len(writers) > 1 else writers[0]
> 1831 |                 # execute task
  1832 |                 run.invoke(
  1833 |                     values,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#539 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/langgraph/pregel/main.py:2271`

High-risk permission pattern: # execute task

```
  2269 |                 run_task_ids.append(task_id)
  2270 |                 run = RunnableSequence(*writers) if len(writers) > 1 else writers[0]
> 2271 |                 # execute task
  2272 |                 await run.ainvoke(
  2273 |                     values,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#540 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/pregel/main.py:1`

No logging, auditing, or monitoring detected

```
>     1 | from __future__ import annotations
      2 |
      3 | import asyncio
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#541 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/pregel/protocol.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |…
     3 | from abc import abstractmethod
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#542 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/pregel/types.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Re-export types moved to langgraph.types"""
     2 |
     3 | from langgraph.types import (
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#543 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/runtime.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from dataclasses import dataclass, field, replace
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#544 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`libs/langgraph/langgraph/types.py:775`

Potential secret: possible hardcoded secret

```
   773 |             print(chunk)
   774 |
>  775 |         # > {'__interrupt__': (Interrupt(value='what is your age?',
id='45fda8478b2ef754419799e10992af06'),)}
   776 |
   777 |         command = Command(resume=\"some input from a human!!!\")
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#545 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/langgraph/types.py:202`

High-risk permission pattern: """Names of the nodes scheduled to execute next."""

```
   200 |     """Current state values at the time of this checkpoint."""
   201 |     next: list[str]
>  202 |     """Names of the nodes scheduled to execute next."""
   203 |     parent_config: RunnableConfig | None…
   204 |     """Configuration of the parent checkpoint, or `None` if this is the first checkpoint."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#546 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/langgraph/types.py:559`

High-risk permission pattern: """The name of the node to execute in each task for this step."""

```
   557 |     """Current values of channels."""
   558 |     next: tuple[str, ...]
>  559 |     """The name of the node to execute in each task for this step."""
   560 |     config: RunnableConfig
   561 |     """Config used to fetch this snapshot."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#547 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/langgraph/types.py:569`

High-risk permission pattern: """Tasks to execute in this step. If already attempted, may contain an error."""

```
   567 |     """Config used to fetch the parent snapshot, if any."""
   568 |     tasks: tuple[PregelTask, ...]
>  569 |     """Tasks to execute in this step. If already attempted, may contain an error."""
   570 |     interrupts: tuple[Interrupt, ...]
   571 |     """Interrupts that occurred in this step that are pending resolution."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#548 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/langgraph/types.py:671`

High-risk permission pattern: - `Send` object (to execute a node with the input provided)

```
   669 |             - Name of the node to navigate to next (any node that belongs to the specified `graph`)
   670 |             - Sequence of node names to navigate to next
>  671 |             - `Send` object (to execute a node with the input provided)
   672 |             - Sequence of `Send` objects
   673 |     """
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#549 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/types.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |…
     3 | import sys
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#550 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/typing.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from typing_extensions import TypeVar
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#551 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/utils/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Legacy utilities module, to be removed in v1."""
     2 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#552 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/utils/config.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Backwards compat imports for config utilities, to be removed in v1."""
     2 |
     3 | from langgraph._internal._config import ensure_config, patch_configurable  # noqa: F401
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#553 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/utils/runnable.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Backwards compat imports for runnable utilities, to be removed in v1."""
     2 |…
     3 | from langgraph._internal._runnable import RunnableCallable, RunnableLike  # noqa: F401
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#554 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/version.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Exports package version."""
     2 |
     3 | from importlib import metadata
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#555 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/langgraph/warnings.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """LangGraph specific warnings."""
     2 |
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#556 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/agents.py:10`

High-risk permission pattern: Represents a request to execute an action by an agent.

```
     8 | class AgentAction(BaseModel):
     9 |     """
>   10 |     Represents a request to execute an action by an agent.
    11 |…
    12 |     The action consists of the name of the tool to execute and the input to pass
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#557 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/agents.py:12`

High-risk permission pattern: The action consists of the name of the tool to execute and the input to pass

```
    10 |     Represents a request to execute an action by an agent.
    11 |
>   12 |     The action consists of the name of the tool to execute and the input to pass
    13 |     to the tool. The log is used to pass along extra information about the action.
    14 |     """
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#558 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/agents.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from typing import Literal
     2 |
     3 | from pydantic import BaseModel
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#559 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/any_int.py:1`

No logging, auditing, or monitoring detected

```
>    1 | class AnyInt(int):
     2 |     def __init__(self) -> None:
     3 |         super().__init__()
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#560 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/any_str.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import re
     2 | from collections.abc import Sequence…
     3 | from typing import Any
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#561 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest.py:85`

High-risk permission pattern: redis_client.delete(*keys)

```
    83 |             keys = redis_client.keys(pattern)
    84 |             if keys:
>   85 |                 redis_client.delete(*keys)
    86 |         except Exception:
    87 |             pass
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#562 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/conftest.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import os
     2 | from collections.abc import AsyncIterator, Iterator
     3 | from uuid import UUID
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#563 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_checkpointer.py:85`

High-risk permission pattern: conn.execute(f"CREATE DATABASE {database}")

```
    83 |     # create unique db
    84 |     with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   85 |         conn.execute(f"CREATE DATABASE {database}")
    86 |     try:
    87 |         # yield checkpointer
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#564 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_checkpointer.py:97`

High-risk permission pattern: conn.execute(f"DROP DATABASE {database}")

```
    95 |         # drop unique db
    96 |         with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   97 |             conn.execute(f"DROP DATABASE {database}")
    98 |…
    99 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#565 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_checkpointer.py:105`

High-risk permission pattern: conn.execute(f"CREATE DATABASE {database}")

```
   103 |     # create unique db
   104 |     with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>  105 |         conn.execute(f"CREATE DATABASE {database}")
   106 |     try:
   107 |         # yield checkpointer
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#566 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_checkpointer.py:120`

High-risk permission pattern: conn.execute(f"DROP DATABASE {database}")

```
   118 |         # drop unique db
   119 |         with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>  120 |             conn.execute(f"DROP DATABASE {database}")
   121 |
   122 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#567 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_checkpointer.py:128`

High-risk permission pattern: conn.execute(f"CREATE DATABASE {database}")

```
   126 |     # create unique db
   127 |     with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>  128 |         conn.execute(f"CREATE DATABASE {database}")
   129 |     try:
   130 |         # yield checkpointer
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#568 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_checkpointer.py:141`

High-risk permission pattern: conn.execute(f"DROP DATABASE {database}")

```
   139 |         # drop unique db
   140 |         with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>  141 |             conn.execute(f"DROP DATABASE {database}")
   142 |…
   143 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#569 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_checkpointer.py:158`

High-risk permission pattern: await conn.execute(f"CREATE DATABASE {database}")

```
   156 |         DEFAULT_POSTGRES_URI, autocommit=True
   157 |     ) as conn:
>  158 |         await conn.execute(f"CREATE DATABASE {database}")
   159 |     try:
   160 |         # yield checkpointer
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#570 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_checkpointer.py:172`

High-risk permission pattern: await conn.execute(f"DROP DATABASE {database}")

```
   170 |             DEFAULT_POSTGRES_URI, autocommit=True
   171 |         ) as conn:
>  172 |             await conn.execute(f"DROP DATABASE {database}")
   173 |
   174 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#571 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_checkpointer.py:182`

High-risk permission pattern: await conn.execute(f"CREATE DATABASE {database}")

```
   180 |         DEFAULT_POSTGRES_URI, autocommit=True
   181 |     ) as conn:
>  182 |         await conn.execute(f"CREATE DATABASE {database}")
   183 |     try:…
   184 |         # yield checkpointer
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#572 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_checkpointer.py:199`

High-risk permission pattern: await conn.execute(f"DROP DATABASE {database}")

```
   197 |             DEFAULT_POSTGRES_URI, autocommit=True
   198 |         ) as conn:
>  199 |             await conn.execute(f"DROP DATABASE {database}")
   200 |
   201 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#573 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_checkpointer.py:209`

High-risk permission pattern: await conn.execute(f"CREATE DATABASE {database}")

```
   207 |         DEFAULT_POSTGRES_URI, autocommit=True
   208 |     ) as conn:
>  209 |         await conn.execute(f"CREATE DATABASE {database}")
   210 |     try:
   211 |         # yield checkpointer
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#574 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_checkpointer.py:224`

High-risk permission pattern: await conn.execute(f"DROP DATABASE {database}")

```
   222 |             DEFAULT_POSTGRES_URI, autocommit=True
   223 |         ) as conn:
>  224 |             await conn.execute(f"DROP DATABASE {database}")
   225 |
   226 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#575 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/conftest_checkpointer.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import os
     2 | from contextlib import asynccontextmanager, contextmanager…
     3 | from uuid import uuid4
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#576 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_store.py:22`

High-risk permission pattern: conn.execute(f"CREATE DATABASE {database}")

```
    20 |     # create unique db
    21 |     with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   22 |         conn.execute(f"CREATE DATABASE {database}")
    23 |     try:
    24 |         # yield store
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#577 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_store.py:31`

High-risk permission pattern: conn.execute(f"DROP DATABASE {database}")

```
    29 |         # drop unique db
    30 |         with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   31 |             conn.execute(f"DROP DATABASE {database}")
    32 |
    33 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#578 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_store.py:39`

High-risk permission pattern: conn.execute(f"CREATE DATABASE {database}")

```
    37 |     # create unique db
    38 |     with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   39 |         conn.execute(f"CREATE DATABASE {database}")
    40 |     try:…
    41 |         # yield store
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#579 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_store.py:51`

High-risk permission pattern: conn.execute(f"DROP DATABASE {database}")

```
    49 |         # drop unique db
    50 |         with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   51 |             conn.execute(f"DROP DATABASE {database}")
    52 |
    53 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#580 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_store.py:59`

High-risk permission pattern: conn.execute(f"CREATE DATABASE {database}")

```
    57 |     # create unique db
    58 |     with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   59 |         conn.execute(f"CREATE DATABASE {database}")
    60 |     try:
    61 |         # yield store
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#581 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_store.py:70`

High-risk permission pattern: conn.execute(f"DROP DATABASE {database}")

```
    68 |         # drop unique db
    69 |         with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   70 |             conn.execute(f"DROP DATABASE {database}")
    71 |
    72 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#582 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_store.py:79`

High-risk permission pattern: await conn.execute(f"CREATE DATABASE {database}")

```
    77 |         DEFAULT_POSTGRES_URI, autocommit=True
    78 |     ) as conn:
>   79 |         await conn.execute(f"CREATE DATABASE {database}")
    80 |     try:…
    81 |         async with AsyncPostgresStore.from_conn_string(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#583 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_store.py:90`

High-risk permission pattern: await conn.execute(f"DROP DATABASE {database}")

```
    88 |             DEFAULT_POSTGRES_URI, autocommit=True
    89 |         ) as conn:
>   90 |             await conn.execute(f"DROP DATABASE {database}")
    91 |
    92 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#584 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_store.py:99`

High-risk permission pattern: await conn.execute(f"CREATE DATABASE {database}")

```
    97 |         DEFAULT_POSTGRES_URI, autocommit=True
    98 |     ) as conn:
>   99 |         await conn.execute(f"CREATE DATABASE {database}")
   100 |     try:
   101 |         async with AsyncPostgresStore.from_conn_string(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#585 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_store.py:113`

High-risk permission pattern: await conn.execute(f"DROP DATABASE {database}")

```
   111 |             DEFAULT_POSTGRES_URI, autocommit=True
   112 |         ) as conn:
>  113 |             await conn.execute(f"DROP DATABASE {database}")
   114 |…
   115 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#586 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_store.py:122`

High-risk permission pattern: await conn.execute(f"CREATE DATABASE {database}")

```
   120 |         DEFAULT_POSTGRES_URI, autocommit=True
   121 |     ) as conn:
>  122 |         await conn.execute(f"CREATE DATABASE {database}")
   123 |     try:
   124 |         async with AsyncPostgresStore.from_conn_string(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#587 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/conftest_store.py:134`

High-risk permission pattern: await conn.execute(f"DROP DATABASE {database}")

```
   132 |             DEFAULT_POSTGRES_URI, autocommit=True
   133 |         ) as conn:
>  134 |             await conn.execute(f"DROP DATABASE {database}")
   135 |
   136 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#588 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/conftest_store.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from contextlib import asynccontextmanager, contextmanager
     2 | from uuid import uuid4
     3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#589 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/langgraph/tests/example_app/example_graph.py:1

No logging, auditing, or monitoring detected

```
>    1 | from typing import Annotated
     2 |…
     3 | from langchain_core.messages import AIMessage, BaseMessage, ToolMessage
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#590 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/langgraph/tests/fake_chat.py:1

No logging, auditing, or monitoring detected

```
>    1 | import re
     2 | from collections.abc import AsyncIterator, Iterator
     3 | from typing import Any, cast
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#591 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/langgraph/tests/fake_tracer.py:1

No logging, auditing, or monitoring detected

```
>    1 | from typing import Any
     2 | from uuid import UUID
     3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#592 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/langgraph/tests/memory_assert.py:1

No logging, auditing, or monitoring detected

```
>    1 | import os
     2 | import tempfile
     3 | from collections import defaultdict
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#593 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/langgraph/tests/messages.py:1

No logging, auditing, or monitoring detected

```
>    1 | """Redefined messages as a work-around for pydantic issue with AnyStr.
     2 |…
     3 | The code below creates version of pydantic models
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#594 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/langgraph/tests/test_algo.py:1

No logging, auditing, or monitoring detected

```
>    1 | from langgraph._internal._constants import PULL, PUSH
     2 | from langgraph.pregel._algo import prepare_next_tasks, task_path_str
     3 | from langgraph.pregel._checkpoint import channels_from_checkpoint, empty_checkpoint
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#595 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/langgraph/tests/test_channels.py:1

No logging, auditing, or monitoring detected

```
>    1 | import operator
     2 | from collections.abc import Sequence
     3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#596 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/langgraph/tests/test_checkpoint_migration.py:1

No logging, auditing, or monitoring detected

```
>    1 | import operator
     2 | import sys
     3 | import time
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#597 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/langgraph/tests/test_config_async.py:1

No logging, auditing, or monitoring detected

```
>    1 | import pytest
     2 | from langchain_core.callbacks import AsyncCallbackManager…
     3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#598 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/langgraph/tests/test_deprecation.py:1

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import warnings
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#599 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

libs/langgraph/tests/test_interrupt_migration.py:33

Potential secret: possible hardcoded secret

```
    31 |     # JsonPlusSerializer().dumps_typed(Interrupt(value="legacy_test", ns=["legacy_test"],
resumable=True, when="during"))
    32 |     legacy_interrupt_bytes = b'{"lc": 2, "type": "constructor", "id": ["langgraph", "types",
"Interrupt"], "kwargs": {"value": "legacy_test", "resumable": true, "ns": ["legacy_test"], "when": "during"}}'
>   33 |     legacy_interrupt_id = "f1fa625689ec006a5b32b76863e22a6c"
    34 |
    35 |     interrupt = serializer.loads_typed(("json", legacy_interrupt_bytes))
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#600 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

libs/langgraph/tests/test_interrupt_migration.py:46

Potential secret: possible hardcoded secret

```
    44 |     # JsonPlusSerializer().dumps_typed(Interrupt(value="legacy_test", ns=["legacy:test",
"with:complex", "name:space"], resumable=True, when="during"))
    45 |     legacy_interrupt_bytes = b'{"lc": 2, "type": "constructor", "id": ["langgraph", "types",
"Interrupt"], "kwargs": {"value": "legacy_test", "resumable": true, "ns": ["legacy:test", "with:complex",
"name:space"], "when": "during"}}'
>   46 |     legacy_interrupt_id = "e69356a9ee3630ee7f4f597f2693000c"
    47 |
    48 |     interrupt = serializer.loads_typed(("json", legacy_interrupt_bytes))
```

Remediation:
1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#601 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/test_interrupt_migration.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import warnings
     2 |…
     3 | import pytest
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#602 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/test_interruption.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import pytest
     2 | from langgraph.checkpoint.base import BaseCheckpointSaver
     3 | from typing_extensions import TypedDict
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#603 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/test_large_cases.py:540`

High-risk permission pattern: # execute the tool

```
   538 |         assert "input" not in data
   539 |         assert "intermediate_steps" not in data
>  540 |         # execute the tool
   541 |         agent_action: AgentAction = data.pop("agent_outcome")
   542 |         observation = {t.name: t for t in tools}[agent_action.tool].invoke(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#604 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/test_large_cases.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import json
     2 | import operator…
     3 | import re
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#605 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/test_large_cases_async.py:530`

High-risk permission pattern: # execute the tool

```
   528 |     # Define tool execution logic
   529 |     def execute_tools(data: AgentState) -> dict:
>  530 |         # execute the tool
   531 |         agent_action: AgentAction = data.pop("agent_outcome")
   532 |         observation = {t.name: t for t in tools}[agent_action.tool].invoke(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#606 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/test_large_cases_async.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import asyncio
     2 | import operator
     3 | import re
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#607 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/test_managed_values.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from typing_extensions import NotRequired, Required, TypedDict
     2 |
     3 | from langgraph.graph import StateGraph
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#608 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/test_messages_state.py:122`

High-risk permission pattern: ValueError, match="Attempting to delete a message with an ID that doesn't exist"

```
   120 |     right = RemoveMessage(id="2")
   121 |     with pytest.raises(
>  122 |         ValueError, match="Attempting to delete a message with an ID that doesn't exist"
   123 |     ):…
   124 |         add_messages(left, right)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#609 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/test_messages_state.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from typing import Annotated
     2 | from uuid import UUID
     3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#610 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/test_parent_command.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from typing_extensions import TypedDict
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#611 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/test_parent_command_async.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import pytest
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#612 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/test_pregel.py:5160`

High-risk permission pattern: # pick the first step to execute next

```
  5158 |             # create plan somehow
  5159 |             plan = ["step1", ["step2", "step3"], "step4"]
> 5160 |             # pick the first step to execute next
  5161 |             first_step, *plan = plan…
  5162 |             # put the rest of plan in state
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#613 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/test_pregel.py:5244`

High-risk permission pattern: """Test that parallel nodes execute concurrently."""

```
  5242 |
  5243 | def test_parallel_node_execution():
> 5244 |     """Test that parallel nodes execute concurrently."""
  5245 |
  5246 |     class State(TypedDict):
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#614 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/test_pregel.py:5414`

High-risk permission pattern: # Verify delete leaves it empty

```
  5412 |     assert "RuntimeError('Simulated failure')" in failed_checkpoint.tasks[0].error
  5413 |
> 5414 |     # Verify delete leaves it empty
  5415 |     graph.checkpointer.delete_thread(config["configurable"]["thread_id"])
  5416 |     assert graph.checkpointer.get_tuple(config) is None
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#615 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/test_pregel_async.py:6372`

High-risk permission pattern: # pick the first step to execute next

```
  6370 |             # create plan somehow
  6371 |             plan = ["step1", ["step2", "step3"], "step4"]
> 6372 |             # pick the first step to execute next
  6373 |             first_step, *plan = plan
  6374 |             # put the rest of plan in state
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#616 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/test_pregel_async.py:6457`

High-risk permission pattern: """Test that parallel nodes execute concurrently."""

```
  6455 |
  6456 | async def test_parallel_node_execution():
> 6457 |     """Test that parallel nodes execute concurrently."""
  6458 |…
  6459 |     class State(TypedDict):
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#617 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/test_pydantic.py:77`

High-risk permission pattern: ADMIN = "admin"

```
    75 |     # Enum type
    76 |     class UserRole(Enum):
>   77 |         ADMIN = "admin"
    78 |         USER = "user"
    79 |         GUEST = "guest"
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#618 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/test_pydantic.py:220`

High-risk permission pattern: "role": "admin",

```
   218 |         "required_list": [10, 20, 30],
   219 |         # Enum & Literal
>  220 |         "role": "admin",
   221 |         "status": "active",
   222 |         # Annotated & NewType
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#619 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/test_pydantic.py:260`

High-risk permission pattern: assert state.role == UserRole.ADMIN

```
   258 |
   259 |         # Enum & Literal
>  260 |         assert state.role == UserRole.ADMIN
   261 |         assert state.status == "active"…
   262 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#620 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/test_pydantic.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import datetime
     2 | import decimal
     3 | import ipaddress
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#621 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/test_remote_graph.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import re
     2 | import sys
     3 | from dataclasses import dataclass
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#622 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/test_retry.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from unittest.mock import Mock, patch
     2 |
     3 | import pytest
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#623 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/test_runnable.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |…
     3 | from typing import Any, Optional
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#624 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`libs/langgraph/tests/test_runtime.py:29`

Potential secret: possible hardcoded secret

```
    27 |     compiled = graph.compile()
    28 |     result = compiled.invoke(
>   29 |         {"message": "hello world"}, context=Context(api_key="sk_123456")
    30 |     )
    31 |     assert result == {"message": "api key: sk_123456"}
```

Remediation:
1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#625 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`libs/langgraph/tests/test_runtime.py:52`

Potential secret: possible hardcoded secret

```
    50 |     compiled = graph.compile()
    51 |     result = compiled.invoke(
>   52 |         {"message": "hello world"}, context=Context(api_key="sk_123456")
    53 |     )
    54 |     assert result == {"message": "api key: sk_123456"}
```

Remediation:
1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#626 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`libs/langgraph/tests/test_runtime.py:147`

Potential secret: possible hardcoded secret

```
   145 |     # Test with actual dataclass instance (should still work)
   146 |     result = compiled.invoke(
>  147 |         {"message": "test"}, context=Context(api_key="sk_test3", timeout=90)
   148 |     )
   149 |     assert result == {"message": "api_key: sk_test3, timeout: 90"}
```

Remediation:
1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#627 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`libs/langgraph/tests/test_runtime.py:188`

Potential secret: possible hardcoded secret

```
   186 |     result = compiled.invoke(
   187 |         {"message": "test"},
>  188 |         context=Context(api_key="sk_test3", timeout=90, tags=["test"]),
   189 |     )…
   190 |     assert result == {"message": "api_key: sk_test3, timeout: 90, tags: ['test']"}
```

Remediation:
1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#628 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/test_runtime.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from dataclasses import dataclass
     2 | from typing import Any
     3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#629 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/test_serde_allowlist.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from collections import deque
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#630 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/langgraph/tests/test_state.py:1

No logging, auditing, or monitoring detected

```
>    1 | import inspect
     2 | import operator…
     3 | import warnings
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#631 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/langgraph/tests/test_stream_v2.py:1

No logging, auditing, or monitoring detected

```
>    1 | """Tests for v2 streaming format (StreamPart TypedDicts).
     2 |
     3 | This file is checked by mypy directly — no subprocess workarounds.
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#632 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/langgraph/tests/test_subgraph_persistence.py:1

No logging, auditing, or monitoring detected

```
>    1 | """Tests for subgraph persistence behavior (sync).
     2 |
     3 | Covers three checkpointer settings for subgraph state:
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#633 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/langgraph/tests/test_subgraph_persistence_async.py:1

No logging, auditing, or monitoring detected

```
>    1 | """Tests for subgraph persistence behavior (async).
     2 |
     3 | Covers three checkpointer settings for subgraph state:
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#634 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/test_time_travel.py:16`

High-risk permission pattern: pending writes. Nodes re-execute and interrupts DO re-fire.

```
    14 |   Interrupts re-fire on replay.
    15 | - Fork (update_state then invoke): Creates a new checkpoint without cached
>   16 |   pending writes. Nodes re-execute and interrupts DO re-fire.
    17 | """…
    18 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#635 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/test_time_travel.py:571`

High-risk permission pattern: post_process re-execute, parent_node does not."""

```
   569 | ) -> None:
   570 |     """Replay from parent checkpoint before subgraph node. Subgraph and
>  571 |     post_process re-execute, parent_node does not."""
   572 |
   573 |     called: list[str] = []
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#636 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/test_time_travel.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Tests for time travel (replay and fork) behavior.
     2 |
     3 | Covers the intersection of replay vs fork across graph structures:
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#637 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/test_time_travel_async.py:16`

High-risk permission pattern: pending writes. Nodes re-execute and interrupts DO re-fire.

```
    14 |   Interrupts re-fire on replay.
    15 | - Fork (update_state then invoke): Creates a new checkpoint without cached
>   16 |   pending writes. Nodes re-execute and interrupts DO re-fire.
    17 | """
    18 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#638 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/langgraph/tests/test_time_travel_async.py:593`

High-risk permission pattern: post_process re-execute, parent_node does not."""

```
   591 | ) -> None:
   592 |     """Replay from parent checkpoint before subgraph node. Subgraph and
>  593 |     post_process re-execute, parent_node does not."""
   594 |…
   595 |     called: list[str] = []
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#639 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/test_time_travel_async.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Async tests for time travel (replay and fork) behavior.
     2 |
     3 | Covers the intersection of replay vs fork across graph structures:
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#640 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/test_tracing_interops.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import json
     2 | import sys
     3 | import time
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#641 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/test_type_checking.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from dataclasses import dataclass
     2 | from operator import add…
     3 | from typing import Annotated, Any
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#642 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/langgraph/tests/test_utils.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import functools
     2 | import sys
     3 | import uuid
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#643 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/prebuilt/langgraph/prebuilt/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """langgraph.prebuilt exposes a higher-level API for creating and executing agents and tools."""
     2 |
     3 | from langgraph.prebuilt.chat_agent_executor import create_react_agent
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#644 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`libs/prebuilt/langgraph/prebuilt/chat_agent_executor.py:1013`

Potential secret: possible hardcoded secret

```
  1011 |     "AgentState",
  1012 |     "AgentStatePydantic",
> 1013 |     "AgentStateWithStructuredResponse",
  1014 |     "AgentStateWithStructuredResponsePydantic",
  1015 | ]
```

Remediation:
1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#645 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`libs/prebuilt/langgraph/prebuilt/chat_agent_executor.py:1014`

Potential secret: possible hardcoded secret

```
  1012 |     "AgentStatePydantic",
  1013 |     "AgentStateWithStructuredResponse",
> 1014 |     "AgentStateWithStructuredResponsePydantic",
  1015 | ]…
  1016 |
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#646 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/chat_agent_executor.py:493`

High-risk permission pattern: A->>T: Execute tools

```
   491 |             Note over A: Prompt + LLM
   492 |             loop while tool_calls present
>  493 |                 A->>T: Execute tools
   494 |                 T-->>A: ToolMessage for each tool_calls
   495 |             end
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#647 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

`libs/prebuilt/langgraph/prebuilt/chat_agent_executor.py:576`

Dependency without integrity verification

```
   574 |             except ImportError:
   575 |                 raise ImportError(
>  576 |                     "Please install langchain (`pip install langchain`) to "
   577 |                     "use '<provider>:<model>' string syntax for `model` parameter."
   578 |                 )
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#648 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/prebuilt/langgraph/prebuilt/chat_agent_executor.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import inspect
     2 | import warnings
     3 | from collections.abc import Awaitable, Callable, Sequence
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#649 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/prebuilt/langgraph/prebuilt/interrupt.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from typing import Literal
     2 |…
     3 | from langgraph.warnings import LangGraphDeprecatedSinceV10
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#650 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:136`

High-risk permission pattern: handle the request without validation. If the interceptor calls `execute()`,

```
   134 |         tool: BaseTool instance to be invoked, or None if tool is not
   135 |             registered with the `ToolNode`. When tool is `None`, interceptors can
>  136 |             handle the request without validation. If the interceptor calls `execute()`,
   137 |             validation will occur and raise an error for unregistered tools.
   138 |         state: Agent state (`dict`, `list`, or `BaseModel`).
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#651 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:206`

High-risk permission pattern: execute: Callable to execute the tool (CAN BE CALLED MULTIPLE TIMES).

```
   204 | Wrapper receives:
   205 |     request: ToolCallRequest with tool_call, tool, state, and runtime.
>  206 |     execute: Callable to execute the tool (CAN BE CALLED MULTIPLE TIMES).
   207 |
   208 | Returns:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#652 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:211`

High-risk permission pattern: The execute callable can be invoked multiple times for retry logic,

```
   209 |     ToolMessage or Command (the final result).
   210 |
>  211 | The execute callable can be invoked multiple times for retry logic,
   212 | with potentially modified requests each time. Each call to execute
   213 | is independent and stateless.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#653 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:212`

High-risk permission pattern: with potentially modified requests each time. Each call to execute

```
  210 |
  211 | The execute callable can be invoked multiple times for retry logic,
> 212 | with potentially modified requests each time. Each call to execute
  213 | is independent and stateless.…
  214 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#654 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:221`

High-risk permission pattern: Passthrough (execute once):

```
  219 |
  220 | Examples:
> 221 |     Passthrough (execute once):
  222 |
  223 |     def handler(request, execute):
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#655 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:223`

High-risk permission pattern: def handler(request, execute):

```
  221 |     Passthrough (execute once):
  222 |
> 223 |     def handler(request, execute):
  224 |         return execute(request)
  225 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#656 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:224`

High-risk permission pattern: return execute(request)

```
   222 |
   223 |     def handler(request, execute):
>  224 |         return execute(request)
   225 |…
   226 |     Modify request before execution:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#657 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:229`

High-risk permission pattern: def handler(request, execute):

```
   227 |
   228 |     ```python
>  229 |     def handler(request, execute):
   230 |         modified_call = {**request.tool_call, "args": {**request.tool_call["args"], "value":
request.tool_call["args"]["value"] * 2}}
   231 |         modified_request = request.override(tool_call=modified_call)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#658 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:232`

High-risk permission pattern: return execute(modified_request)

```
   230 |         modified_call = {**request.tool_call, "args": {**request.tool_call["args"], "value":
request.tool_call["args"]["value"] * 2}}
   231 |         modified_request = request.override(tool_call=modified_call)
>  232 |         return execute(modified_request)
   233 |     ```
   234 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#659 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:235`

High-risk permission pattern: Retry on error (execute multiple times):

```
   233 |     ```
   234 |
>  235 |     Retry on error (execute multiple times):
   236 |
   237 |     ```python
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#660 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:238`

High-risk permission pattern: def handler(request, execute):

```
  236 |
  237 |     ```python
> 238 |     def handler(request, execute):
  239 |         for attempt in range(3):…
  240 |             try:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#661 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:241`

High-risk permission pattern: result = execute(request)

```
  239 |         for attempt in range(3):
  240 |             try:
> 241 |                 result = execute(request)
  242 |                 if is_valid(result):
  243 |                     return result
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#662 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:253`

High-risk permission pattern: def handler(request, execute):

```
  251 |
  252 |     ```python
> 253 |     def handler(request, execute):
  254 |         for attempt in range(3):
  255 |             result = execute(request)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#663 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:255`

High-risk permission pattern: result = execute(request)

```
    253 |     def handler(request, execute):
    254 |         for attempt in range(3):
>   255 |             result = execute(request)
    256 |             if isinstance(result, ToolMessage) and result.status != "error":…
    257 |                 return result
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#664 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:263`

High-risk permission pattern: Cache/short-circuit without calling execute:

```
    261 |     ```
    262 |
>   263 |     Cache/short-circuit without calling execute:
    264 |
    265 |     ```python
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#665 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:266`

High-risk permission pattern: def handler(request, execute):

```
    264 |
    265 |     ```python
>   266 |     def handler(request, execute):
    267 |         if cached := get_cache(request):
    268 |             return ToolMessage(content=cached, tool_call_id=request.tool_call["id"])
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#666 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:269`

High-risk permission pattern: result = execute(request)

```
    267 |         if cached := get_cache(request):
    268 |             return ToolMessage(content=cached, tool_call_id=request.tool_call["id"])
>   269 |         result = execute(request)
    270 |         save_cache(request, result)
    271 |         return result
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#667 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:761`

High-risk permission pattern: ToolCallRequest and execute callable, returns ToolMessage or Command.

```
   759 |             messages_key: State key containing messages.
   760 |             wrap_tool_call: Sync wrapper function to intercept tool execution. Receives
>  761 |                 ToolCallRequest and execute callable, returns ToolMessage or Command.
   762 |                 Enables retries, caching, request modification, and control flow.…
   763 |             awrap_tool_call: Async wrapper function to intercept tool execution.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#668 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:900`

High-risk permission pattern: """Execute tool call with configured error handling.

```
   898 |         config: RunnableConfig,
   899 |     ) -> ToolMessage | Command:
>  900 |         """Execute tool call with configured error handling.
   901 |
   902 |         Args:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#669 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:916`

High-risk permission pattern: # Validate tool exists when we actually need to execute it

```
   914 |         tool = request.tool
   915 |
>  916 |         # Validate tool exists when we actually need to execute it
   917 |         if tool is None:
   918 |             if invalid_tool_message := self._validate_tool_call(call):
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#670 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:998`

High-risk permission pattern: """Execute single tool call with wrap_tool_call wrapper if configured.

```
   996 |         tool_runtime: ToolRuntime,
   997 |     ) -> ToolMessage | Command:
>  998 |         """Execute single tool call with wrap_tool_call wrapper if configured.
   999 |…
  1000 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#671 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:1023`

High-risk permission pattern: # No wrapper - execute directly

```
  1021 |
  1022 |         if self._wrap_tool_call is None:
> 1023 |             # No wrapper - execute directly
  1024 |             return self._execute_tool_sync(tool_request, input_type, config)
  1025 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#672 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:1026`

High-risk permission pattern: # Define execute callable that can be called multiple times

```
  1024 |             return self._execute_tool_sync(tool_request, input_type, config)
  1025 |
> 1026 |         # Define execute callable that can be called multiple times
  1027 |         def execute(req: ToolCallRequest) -> ToolMessage | Command:
  1028 |             """Execute tool with given request. Can be called multiple times."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#673 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:1027`

High-risk permission pattern: def execute(req: ToolCallRequest) -> ToolMessage | Command:

```
  1025 |
  1026 |         # Define execute callable that can be called multiple times
> 1027 |         def execute(req: ToolCallRequest) -> ToolMessage | Command:
  1028 |             """Execute tool with given request. Can be called multiple times."""
  1029 |             return self._execute_tool_sync(req, input_type, config)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#674 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:1028`

High-risk permission pattern: """Execute tool with given request. Can be called multiple times."""

```
  1026 |         # Define execute callable that can be called multiple times
  1027 |         def execute(req: ToolCallRequest) -> ToolMessage | Command:
> 1028 |             """Execute tool with given request. Can be called multiple times."""
  1029 |             return self._execute_tool_sync(req, input_type, config)…
  1030 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#675 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:1031`

High-risk permission pattern: # Call wrapper with request and execute callable

```
  1029 |             return self._execute_tool_sync(req, input_type, config)
  1030 |
> 1031 |         # Call wrapper with request and execute callable
  1032 |         try:
  1033 |             return self._wrap_tool_call(tool_request, execute)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#676 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:1033`

High-risk permission pattern: return self._wrap_tool_call(tool_request, execute)

```
  1031 |         # Call wrapper with request and execute callable
  1032 |         try:
> 1033 |             return self._wrap_tool_call(tool_request, execute)
  1034 |         except Exception as e:
  1035 |             # Wrapper threw an exception
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#677 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:1053`

High-risk permission pattern: """Execute tool call asynchronously with configured error handling.

```
  1051 |         config: RunnableConfig,
  1052 |     ) -> ToolMessage | Command:
> 1053 |         """Execute tool call asynchronously with configured error handling.
  1054 |…
  1055 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#678 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:1069`

High-risk permission pattern: # Validate tool exists when we actually need to execute it

```
  1067 |         tool = request.tool
  1068 |
> 1069 |         # Validate tool exists when we actually need to execute it
  1070 |         if tool is None:
  1071 |             if invalid_tool_message := self._validate_tool_call(call):
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#679 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:1151`

High-risk permission pattern: """Execute single tool call asynchronously with awrap_tool_call wrapper if confi

```
  1149 |         tool_runtime: ToolRuntime,
  1150 |     ) -> ToolMessage | Command:
> 1151 |         """Execute single tool call asynchronously with awrap_tool_call wrapper if configured.
  1152 |
  1153 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#680 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:1176`

High-risk permission pattern: # No wrapper - execute directly

```
  1174 |
  1175 |         if self._awrap_tool_call is None and self._wrap_tool_call is None:
> 1176 |             # No wrapper - execute directly
  1177 |             return await self._execute_tool_async(tool_request, input_type, config)
  1178 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#681 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:1179`

High-risk permission pattern: # Define async execute callable that can be called multiple times

```
  1177 |             return await self._execute_tool_async(tool_request, input_type, config)
  1178 |
> 1179 |         # Define async execute callable that can be called multiple times
  1180 |         async def execute(req: ToolCallRequest) -> ToolMessage | Command:…
  1181 |             """Execute tool with given request. Can be called multiple times."""
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#682 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:1180`

High-risk permission pattern: async def execute(req: ToolCallRequest) -> ToolMessage | Command:

```
  1178 |
  1179 |         # Define async execute callable that can be called multiple times
> 1180 |         async def execute(req: ToolCallRequest) -> ToolMessage | Command:
  1181 |             """Execute tool with given request. Can be called multiple times."""
  1182 |             return await self._execute_tool_async(req, input_type, config)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#683 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/langgraph/prebuilt/tool_node.py:1181`

High-risk permission pattern: """Execute tool with given request. Can be called multiple times."""

```
  1179 |         # Define async execute callable that can be called multiple times
  1180 |         async def execute(req: ToolCallRequest) -> ToolMessage | Command:
> 1181 |             """Execute tool with given request. Can be called multiple times."""
  1182 |             return await self._execute_tool_async(req, input_type, config)
  1183 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#684 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/prebuilt/langgraph/prebuilt/tool_node.py:1185

High-risk permission pattern: """Sync execute fallback for sync wrapper."""

```
  1183 |
  1184 |         def _sync_execute(req: ToolCallRequest) -> ToolMessage | Command:
> 1185 |             """Sync execute fallback for sync wrapper."""
  1186 |             return self._execute_tool_sync(req, input_type, config)…
  1187 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#685 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/prebuilt/langgraph/prebuilt/tool_node.py:1188

High-risk permission pattern: # Call wrapper with request and execute callable

```
  1186 |             return self._execute_tool_sync(req, input_type, config)
  1187 |
> 1188 |         # Call wrapper with request and execute callable
  1189 |         try:
  1190 |             if self._awrap_tool_call is not None:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#686 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/prebuilt/langgraph/prebuilt/tool_node.py:1191

High-risk permission pattern: return await self._awrap_tool_call(tool_request, execute)

```
  1189 |         try:
  1190 |             if self._awrap_tool_call is not None:
> 1191 |                 return await self._awrap_tool_call(tool_request, execute)
  1192 |             # None check was performed above already
  1193 |             self._wrap_tool_call = cast("ToolCallWrapper", self._wrap_tool_call)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#687 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/prebuilt/langgraph/prebuilt/tool_node.py:1

No logging, auditing, or monitoring detected

```
>     1 | """Tool execution node for LangGraph workflows.
      2 |
      3 | This module provides prebuilt functionality for executing tools in LangGraph.
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#688 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

`libs/prebuilt/langgraph/prebuilt/tool_validator.py:132`

Dangerous execution: - A function (a schema will be created from the function signature)

```
  130 |                 - A pydantic BaseModel class
  131 |                 - A BaseTool instance (the args_schema will be used)
> 132 |                 - A function (a schema will be created from the function signature)
  133 |             format_error: A function that takes an exception, a ToolCall, and a schema…
  134 |                 and returns a formatted error string. By default, it returns the
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#689 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/prebuilt/langgraph/prebuilt/tool_validator.py:1`

No logging, auditing, or monitoring detected

```
>   1 | """This module provides a ValidationNode class that can be used to validate tool calls
    2 | in a langchain graph. It applies a pydantic schema to tool_calls in the models' outputs,
    3 | and returns a ToolMessage with the validated content. If the schema is not valid, it
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#690 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/prebuilt/tests/any_str.py:1`

No logging, auditing, or monitoring detected

```
>   1 | import re
    2 |
    3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#691 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/prebuilt/tests/conftest.py:1`

No logging, auditing, or monitoring detected

```
>   1 | import os
    2 | from collections.abc import AsyncIterator, Iterator
    3 | from uuid import UUID
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#692 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_checkpointer.py:32`

High-risk permission pattern: conn.execute(f"CREATE DATABASE {database}")

```
    30 |     # create unique db
    31 |     with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   32 |         conn.execute(f"CREATE DATABASE {database}")
    33 |     try:…
    34 |         # yield checkpointer
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#693 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_checkpointer.py:43`

High-risk permission pattern: conn.execute(f"DROP DATABASE {database}")

```
    41 |         # drop unique db
    42 |         with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   43 |             conn.execute(f"DROP DATABASE {database}")
    44 |
    45 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#694 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_checkpointer.py:51`

High-risk permission pattern: conn.execute(f"CREATE DATABASE {database}")

```
    49 |     # create unique db
    50 |     with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   51 |         conn.execute(f"CREATE DATABASE {database}")
    52 |     try:
    53 |         # yield checkpointer
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#695 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_checkpointer.py:65`

High-risk permission pattern: conn.execute(f"DROP DATABASE {database}")

```
    63 |         # drop unique db
    64 |         with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   65 |             conn.execute(f"DROP DATABASE {database}")
    66 |
    67 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#696 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_checkpointer.py:73`

High-risk permission pattern: conn.execute(f"CREATE DATABASE {database}")

```
    71 |     # create unique db
    72 |     with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   73 |         conn.execute(f"CREATE DATABASE {database}")
    74 |     try:…
    75 |         # yield checkpointer
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#697 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_checkpointer.py:85`

High-risk permission pattern: conn.execute(f"DROP DATABASE {database}")

```
    83 |         # drop unique db
    84 |         with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   85 |             conn.execute(f"DROP DATABASE {database}")
    86 |
    87 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#698 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_checkpointer.py:101`

High-risk permission pattern: await conn.execute(f"CREATE DATABASE {database}")

```
    99 |         DEFAULT_POSTGRES_URI, autocommit=True
   100 |     ) as conn:
>  101 |         await conn.execute(f"CREATE DATABASE {database}")
   102 |     try:
   103 |         # yield checkpointer
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#699 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_checkpointer.py:114`

High-risk permission pattern: await conn.execute(f"DROP DATABASE {database}")

```
   112 |             DEFAULT_POSTGRES_URI, autocommit=True
   113 |         ) as conn:
>  114 |             await conn.execute(f"DROP DATABASE {database}")
   115 |…
   116 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#700 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_checkpointer.py:124`

High-risk permission pattern: await conn.execute(f"CREATE DATABASE {database}")

```
   122 |         DEFAULT_POSTGRES_URI, autocommit=True
   123 |     ) as conn:
>  124 |         await conn.execute(f"CREATE DATABASE {database}")
   125 |     try:
   126 |         # yield checkpointer
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#701 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_checkpointer.py:140`

High-risk permission pattern: await conn.execute(f"DROP DATABASE {database}")

```
   138 |             DEFAULT_POSTGRES_URI, autocommit=True
   139 |         ) as conn:
>  140 |             await conn.execute(f"DROP DATABASE {database}")
   141 |
   142 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#702 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_checkpointer.py:150`

High-risk permission pattern: await conn.execute(f"CREATE DATABASE {database}")

```
   148 |         DEFAULT_POSTGRES_URI, autocommit=True
   149 |     ) as conn:
>  150 |         await conn.execute(f"CREATE DATABASE {database}")
   151 |     try:
   152 |         # yield checkpointer
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#703 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_checkpointer.py:164`

High-risk permission pattern: await conn.execute(f"DROP DATABASE {database}")

```
  162 |             DEFAULT_POSTGRES_URI, autocommit=True
  163 |         ) as conn:
> 164 |             await conn.execute(f"DROP DATABASE {database}")
  165 |…
  166 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#704 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/prebuilt/tests/conftest_checkpointer.py:1`

No logging, auditing, or monitoring detected

```
>   1 | from contextlib import asynccontextmanager, contextmanager
    2 | from uuid import uuid4
    3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#705 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_store.py:22`

High-risk permission pattern: conn.execute(f"CREATE DATABASE {database}")

```
   20 |     # create unique db
   21 |     with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>  22 |         conn.execute(f"CREATE DATABASE {database}")
   23 |     try:
   24 |         # yield store
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#706 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_store.py:31`

High-risk permission pattern: conn.execute(f"DROP DATABASE {database}")

```
    29 |         # drop unique db
    30 |         with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   31 |             conn.execute(f"DROP DATABASE {database}")
    32 |…
    33 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#707 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_store.py:39`

High-risk permission pattern: conn.execute(f"CREATE DATABASE {database}")

```
    37 |     # create unique db
    38 |     with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   39 |         conn.execute(f"CREATE DATABASE {database}")
    40 |     try:
    41 |         # yield store
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#708 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_store.py:51`

High-risk permission pattern: conn.execute(f"DROP DATABASE {database}")

```
    49 |         # drop unique db
    50 |         with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   51 |             conn.execute(f"DROP DATABASE {database}")
    52 |
    53 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#709 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_store.py:59`

High-risk permission pattern: conn.execute(f"CREATE DATABASE {database}")

```
    57 |     # create unique db
    58 |     with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   59 |         conn.execute(f"CREATE DATABASE {database}")
    60 |     try:
    61 |         # yield store
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#710 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_store.py:70`

High-risk permission pattern: conn.execute(f"DROP DATABASE {database}")

```
    68 |         # drop unique db
    69 |         with Connection.connect(DEFAULT_POSTGRES_URI, autocommit=True) as conn:
>   70 |             conn.execute(f"DROP DATABASE {database}")
    71 |…
    72 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#711 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_store.py:79`

High-risk permission pattern: await conn.execute(f"CREATE DATABASE {database}")

```
    77 |         DEFAULT_POSTGRES_URI, autocommit=True
    78 |     ) as conn:
>   79 |         await conn.execute(f"CREATE DATABASE {database}")
    80 |     try:
    81 |         async with AsyncPostgresStore.from_conn_string(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#712 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_store.py:90`

High-risk permission pattern: await conn.execute(f"DROP DATABASE {database}")

```
    88 |             DEFAULT_POSTGRES_URI, autocommit=True
    89 |         ) as conn:
>   90 |             await conn.execute(f"DROP DATABASE {database}")
    91 |
    92 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#713 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_store.py:99`

High-risk permission pattern: await conn.execute(f"CREATE DATABASE {database}")

```
    97 |         DEFAULT_POSTGRES_URI, autocommit=True
    98 |     ) as conn:
>   99 |         await conn.execute(f"CREATE DATABASE {database}")
   100 |     try:…
   101 |         async with AsyncPostgresStore.from_conn_string(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#714 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_store.py:113`

High-risk permission pattern: await conn.execute(f"DROP DATABASE {database}")

```
   111 |             DEFAULT_POSTGRES_URI, autocommit=True
   112 |         ) as conn:
>  113 |             await conn.execute(f"DROP DATABASE {database}")
   114 |
   115 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#715 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_store.py:122`

High-risk permission pattern: await conn.execute(f"CREATE DATABASE {database}")

```
   120 |         DEFAULT_POSTGRES_URI, autocommit=True
   121 |     ) as conn:
>  122 |         await conn.execute(f"CREATE DATABASE {database}")
   123 |     try:
   124 |         async with AsyncPostgresStore.from_conn_string(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#716 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/conftest_store.py:134`

High-risk permission pattern: await conn.execute(f"DROP DATABASE {database}")

```
   132 |             DEFAULT_POSTGRES_URI, autocommit=True
   133 |         ) as conn:
>  134 |             await conn.execute(f"DROP DATABASE {database}")
   135 |
   136 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#717 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/prebuilt/tests/conftest_store.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from contextlib import asynccontextmanager, contextmanager
     2 | from uuid import uuid4…
     3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#718 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/prebuilt/tests/memory_assert.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import os
     2 | import tempfile
     3 | from collections import defaultdict
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#719 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/prebuilt/tests/messages.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Redefined messages as a work-around for pydantic issue with AnyStr.
     2 |
     3 | The code below creates version of pydantic models
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#720 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/prebuilt/tests/model.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from collections.abc import Callable, Sequence
     2 | from typing import (
     3 |     Any,
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#721 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/prebuilt/tests/test_deprecation.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import pytest
     2 | from langgraph.warnings import LangGraphDeprecatedSinceV10…
     3 | from typing_extensions import TypedDict
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#722 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:57`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
    55 |     def passthrough_handler(
    56 |         request: ToolCallRequest,
>   57 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
    58 |     ) -> ToolMessage | Command:
    59 |         """Simple passthrough handler."""
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#723 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:60`

High-risk permission pattern: return execute(request)

```
    58 |     ) -> ToolMessage | Command:
    59 |         """Simple passthrough handler."""
>   60 |         return execute(request)
    61 |
    62 |     tool_node = ToolNode([add], wrap_tool_call=passthrough_handler)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#724 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:94`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
    92 |     def passthrough_handler(
    93 |         request: ToolCallRequest,
>   94 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
    95 |     ) -> ToolMessage | Command:…
    96 |         """Simple passthrough handler."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#725 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:97`

High-risk permission pattern: return execute(request)

```
    95 |     ) -> ToolMessage | Command:
    96 |         """Simple passthrough handler."""
>   97 |         return execute(request)
    98 |
    99 |     tool_node = ToolNode([add], wrap_tool_call=passthrough_handler)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#726 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:130`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
   128 |     def modify_args_handler(
   129 |         request: ToolCallRequest,
>  130 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   131 |     ) -> ToolMessage | Command:
   132 |         """Handler that doubles the input arguments."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#727 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:143`

High-risk permission pattern: return execute(modified_request)

```
   141 |         }
   142 |         modified_request = request.override(tool_call=modified_call)
>  143 |         return execute(modified_request)
   144 |
   145 |     tool_node = ToolNode([add], wrap_tool_call=modify_args_handler)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#728 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:176`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
   174 |     def handler_with_explicit_none(
   175 |         request: ToolCallRequest,
>  176 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   177 |     ) -> ToolMessage | Command:…
   178 |         """Handler that executes and returns result."""
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#729 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:179`

High-risk permission pattern: return execute(request)

```
   177 |     ) -> ToolMessage | Command:
   178 |         """Handler that executes and returns result."""
>  179 |         return execute(request)
   180 |
   181 |     tool_node = ToolNode([add], wrap_tool_call=handler_with_explicit_none)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#730 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:209`

High-risk permission pattern: """Test that handler that doesn't call execute returns None (bad behavior)."""

```
   207 |
   208 | def test_handler_validation_no_yield() -> None:
>  209 |     """Test that handler that doesn't call execute returns None (bad behavior)."""
   210 |
   211 |     def bad_handler(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#731 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:215`

High-risk permission pattern: """Handler that doesn't call execute - will cause type error."""

```
   213 |         _execute: Callable[[ToolCallRequest], ToolMessage | Command],
   214 |     ) -> ToolMessage | Command:
>  215 |         """Handler that doesn't call execute - will cause type error."""
   216 |         # Don't call execute, just return None (invalid)…
   217 |         return None  # type: ignore[return-value]
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#732 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:216`

High-risk permission pattern: # Don't call execute, just return None (invalid)

```
   214 |     ) -> ToolMessage | Command:
   215 |         """Handler that doesn't call execute - will cause type error."""
>  216 |         # Don't call execute, just return None (invalid)
   217 |         return None  # type: ignore[return-value]
   218 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#733 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:250`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
   248 |     def passthrough_handler(
   249 |         request: ToolCallRequest,
>  250 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   251 |     ) -> ToolMessage | Command:
   252 |         """Simple passthrough handler."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#734 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:253`

High-risk permission pattern: message = execute(request)

```
   251 |     ) -> ToolMessage | Command:
   252 |         """Simple passthrough handler."""
>  253 |         message = execute(request)
   254 |         # When handle_tool_errors=True, errors should be converted to error messages
   255 |         assert isinstance(message, ToolMessage)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#735 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:292`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
   290 |     def counting_handler(
   291 |         request: ToolCallRequest,
>  292 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   293 |     ) -> ToolMessage | Command:…
   294 |         """Handler that counts calls."""
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#736 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:297`

High-risk permission pattern: return execute(request)

```
   295 |         nonlocal call_count
   296 |         call_count += 1
>  297 |         return execute(request)
   298 |
   299 |     tool_node = ToolNode([add], wrap_tool_call=counting_handler)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#737 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:368`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
   366 |     def modifying_handler(
   367 |         request: ToolCallRequest,
>  368 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   369 |     ) -> ToolMessage | Command:
   370 |         """Handler that modifies arguments."""
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#738 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:381`

High-risk permission pattern: return execute(modified_request)

```
   379 |         }
   380 |         modified_request = request.override(tool_call=modified_call)
>  381 |         return execute(modified_request)
   382 |…
   383 |     tool_node = ToolNode([async_add], wrap_tool_call=modifying_handler)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#739 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:417`

High-risk permission pattern: # Return a ToolMessage directly instead of calling execute

```
   415 |     ) -> ToolMessage | Command:
   416 |         """Handler that returns cached result without executing tool."""
>  417 |         # Return a ToolMessage directly instead of calling execute
   418 |         return ToolMessage(
   419 |             content="cached_result",
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#740 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:497`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
   495 |     def conditional_handler(
   496 |         request: ToolCallRequest,
>  497 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   498 |     ) -> ToolMessage | Command:
   499 |         """Handler that caches even numbers, executes odd."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#741 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:510`

High-risk permission pattern: # Odd: execute normally

```
   508 |                 name=request.tool_call["name"],
   509 |             )
>  510 |         # Odd: execute normally
   511 |         return execute(request)
   512 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#742 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:511`

High-risk permission pattern: return execute(request)

```
   509 |             )
   510 |         # Odd: execute normally
>  511 |         return execute(request)
   512 |…
   513 |     tool_node = ToolNode([add], wrap_tool_call=conditional_handler)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#743 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:537`

High-risk permission pattern: # Test with odd number (should execute)

```
   535 |     assert tool_message1.content == "cached_2"
   536 |
>  537 |     # Test with odd number (should execute)
   538 |     result2 = tool_node.invoke(
   539 |         {
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#744 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:561`

High-risk permission pattern: """Test handler that returns ToolMessage directly without calling execute."""

```
   559 |
   560 | def test_direct_return_tool_message() -> None:
>  561 |     """Test handler that returns ToolMessage directly without calling execute."""
   562 |
   563 |     def direct_return_handler(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#745 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:568`

High-risk permission pattern: # Return ToolMessage directly instead of calling execute

```
   566 |     ) -> ToolMessage | Command:
   567 |         """Handler that returns ToolMessage directly."""
>  568 |         # Return ToolMessage directly instead of calling execute
   569 |         return ToolMessage(…
   570 |             content="direct_return",
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#746 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:603`

High-risk permission pattern: """Test async handler that returns ToolMessage directly without calling execute.

```
   601 |
   602 | async def test_direct_return_tool_message_async() -> None:
>  603 |     """Test async handler that returns ToolMessage directly without calling execute."""
   604 |
   605 |     def direct_return_handler(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#747 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:647`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
   645 |     def conditional_handler(
   646 |         request: ToolCallRequest,
>  647 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   648 |     ) -> ToolMessage | Command:
   649 |         """Handler that returns cached or executes based on condition."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#748 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:659`

High-risk permission pattern: # Execute tool normally

```
   657 |                 name=request.tool_call["name"],
   658 |             )
>  659 |         # Execute tool normally
   660 |         return execute(request)
   661 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#749 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:660`

High-risk permission pattern: return execute(request)

```
   658 |             )
   659 |         # Execute tool normally
>  660 |         return execute(request)
   661 |…
   662 |     tool_node = ToolNode([add], wrap_tool_call=conditional_handler)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#750 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:686`

High-risk permission pattern: # Test with non-zero (should execute)

```
   684 |     assert tool_message1.content == "zero_cached"
   685 |
>  686 |     # Test with non-zero (should execute)
   687 |     result2 = tool_node.invoke(
   688 |         {
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#751 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:714`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
   712 |     def throwing_handler(
   713 |         request: ToolCallRequest,
>  714 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   715 |     ) -> ToolMessage | Command:
   716 |         """Handler that throws an exception after receiving response."""
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#752 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:717`

High-risk permission pattern: response = execute(request)

```
    715 |     ) -> ToolMessage | Command:
    716 |         """Handler that throws an exception after receiving response."""
>   717 |         response = execute(request)
    718 |         # Check response and throw if invalid…
    719 |         if isinstance(response, ToolMessage):
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#753 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:759`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
    757 |     def throwing_handler(
    758 |         request: ToolCallRequest,
>   759 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
    760 |     ) -> ToolMessage | Command:
    761 |         """Handler that throws an exception."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#754 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:762`

High-risk permission pattern: execute(request)

```
    760 |     ) -> ToolMessage | Command:
    761 |         """Handler that throws an exception."""
>   762 |         execute(request)
    763 |         msg = "Handler error"
    764 |         raise ValueError(msg)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#755 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:791`

High-risk permission pattern: """Test retry middleware pattern that can call execute multiple times."""

```
    789 |
    790 | def test_retry_middleware_with_exception() -> None:
>   791 |     """Test retry middleware pattern that can call execute multiple times."""
    792 |     attempt_count = {"count": 0}
    793 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#756 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:796`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
   794 |     def retry_handler(
   795 |         request: ToolCallRequest,
>  796 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   797 |     ) -> ToolMessage | Command:…
   798 |         """Handler that can retry by calling execute multiple times."""
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#757 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:798`

High-risk permission pattern: """Handler that can retry by calling execute multiple times."""

```
   796 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   797 |     ) -> ToolMessage | Command:
>  798 |         """Handler that can retry by calling execute multiple times."""
   799 |         max_retries = 3
   800 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#758 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:803`

High-risk permission pattern: response = execute(request)

```
   801 |         for _attempt in range(max_retries):
   802 |             attempt_count["count"] += 1
>  803 |             response = execute(request)
   804 |
   805 |             # Simulate checking for retriable errors
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#759 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:849`

High-risk permission pattern: """Handler that throws an exception before calling execute."""

```
   847 |         _execute: Callable[[ToolCallRequest], ToolMessage | Command],
   848 |     ) -> ToolMessage | Command:
>  849 |         """Handler that throws an exception before calling execute."""
   850 |         # Throw exception before executing (to avoid async/await complications)…
   851 |         msg = "Async handler rejected the request"
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#760 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:892`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
   890 |     def single_return_handler(
   891 |         request: ToolCallRequest,
>  892 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   893 |     ) -> ToolMessage | Command:
   894 |         """Handler that returns once (as all handlers do)."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#761 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:895`

High-risk permission pattern: return execute(request)

```
   893 |     ) -> ToolMessage | Command:
   894 |         """Handler that returns once (as all handlers do)."""
>  895 |         return execute(request)
   896 |
   897 |     tool_node = ToolNode([add], wrap_tool_call=single_return_handler)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#762 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:1082`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
  1080 |     def command_inspector_handler(
  1081 |         request: ToolCallRequest,
> 1082 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
  1083 |     ) -> ToolMessage | Command:
  1084 |         """Handler that inspects Command returned by tool."""
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#763 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:1085`

High-risk permission pattern: result = execute(request)

```
  1083 |     ) -> ToolMessage | Command:
  1084 |         """Handler that inspects Command returned by tool."""
> 1085 |         result = execute(request)
  1086 |         # Should receive Command from tool…
  1087 |         if isinstance(result, Command):
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#764 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:1127`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
  1125 |     def command_modifier_handler(
  1126 |         request: ToolCallRequest,
> 1127 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
  1128 |     ) -> ToolMessage | Command:
  1129 |         """Handler that modifies Command returned by tool."""
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#765 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:1130`

High-risk permission pattern: result = execute(request)

```
  1128 |     ) -> ToolMessage | Command:
  1129 |         """Handler that modifies Command returned by tool."""
> 1130 |         result = execute(request)
  1131 |         # Modify the Command
  1132 |         if isinstance(result, Command):
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#766 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:1169`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
  1167 |     def state_inspector_handler(
  1168 |         request: ToolCallRequest,
> 1169 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
  1170 |     ) -> ToolMessage | Command:…
  1171 |         """Handler that records the state it receives."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#767 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:1173`

High-risk permission pattern: return execute(request)

```
  1171 |         """Handler that records the state it receives."""
  1172 |         state_seen.append(request.state)
> 1173 |         return execute(request)
  1174 |
  1175 |     tool_node = ToolNode([add], wrap_tool_call=state_inspector_handler)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#768 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:1204`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
  1202 |     def state_inspector_handler(
  1203 |         request: ToolCallRequest,
> 1204 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
  1205 |     ) -> ToolMessage | Command:
  1206 |         """Handler that records the state it receives."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#769 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:1208`

High-risk permission pattern: return execute(request)

```
  1206 |         """Handler that records the state it receives."""
  1207 |         state_seen.append(request.state)
> 1208 |         return execute(request)
  1209 |
  1210 |     tool_node = ToolNode([add], wrap_tool_call=state_inspector_handler)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#770 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:1238`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
  1236 |     def state_inspector_handler(
  1237 |         request: ToolCallRequest,
> 1238 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
  1239 |     ) -> ToolMessage | Command:…
  1240 |         """Handler that records the state it receives."""
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#771 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:1242`

High-risk permission pattern: return execute(request)

```
  1240 |         """Handler that records the state it receives."""
  1241 |         state_seen.append(request.state)
> 1242 |         return execute(request)
  1243 |
  1244 |     tool_node = ToolNode([add], wrap_tool_call=state_inspector_handler)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#772 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:1286`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
  1284 |     def state_inspector_handler(
  1285 |         request: ToolCallRequest,
> 1286 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
  1287 |     ) -> ToolMessage | Command:
  1288 |         """Handler that records the state it receives."""
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#773 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_on_tool_call.py:1290`

High-risk permission pattern: return execute(request)

```
  1288 |         """Handler that records the state it receives."""
  1289 |         state_seen.append(request.state)
> 1290 |         return execute(request)
  1291 |…
  1292 |     tool_node = ToolNode([add], wrap_tool_call=state_inspector_handler)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#774 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/prebuilt/tests/test_on_tool_call.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Unit tests for tool call interceptor in ToolNode."""
     2 |
     3 | from collections.abc import Callable
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#775 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/prebuilt/tests/test_react_agent.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import dataclasses
     2 | import inspect
     3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#776 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/prebuilt/tests/test_react_agent_graph.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from collections.abc import Callable
     2 |
     3 | import pytest
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#777 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node.py:1925`

High-risk permission pattern: def wrap_tool_call(request, execute):

```
  1923 |         return f"dynamic: x={x}, tool_call_id={runtime.tool_call_id}"
  1924 |
> 1925 |     def wrap_tool_call(request, execute):
  1926 |         """Middleware that swaps in a dynamic tool."""…
  1927 |         if request.tool_call["name"] == "dynamic_tool_with_runtime":
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#778 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node.py:1930`

High-risk permission pattern: return execute(new_request)

```
  1928 |             # Override tool to the dynamic one (not registered at init)
  1929 |             new_request = request.override(tool=dynamic_tool_with_runtime)
> 1930 |             return execute(new_request)
  1931 |         return execute(request)
  1932 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#779 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node.py:1931`

High-risk permission pattern: return execute(request)

```
  1929 |             new_request = request.override(tool=dynamic_tool_with_runtime)
  1930 |             return execute(new_request)
> 1931 |         return execute(request)
  1932 |
  1933 |     # ToolNode only knows about static_tool at init time
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#780 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node.py:1955`

High-risk permission pattern: # ToolRuntime should be injected and the tool should execute successfully

```
  1953 |     )
  1954 |
> 1955 |     # ToolRuntime should be injected and the tool should execute successfully
  1956 |     tool_message = result["messages"][-1]
  1957 |     assert tool_message.content == "dynamic: x=42, tool_call_id=call_dynamic_1"
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#781 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node.py:1978`

High-risk permission pattern: async def awrap_tool_call(request, execute):

```
  1976 |         return f"dynamic: x={x}, tool_call_id={runtime.tool_call_id}"
  1977 |
> 1978 |     async def awrap_tool_call(request, execute):
  1979 |         """Async middleware that swaps in a dynamic tool."""…
  1980 |         if request.tool_call["name"] == "dynamic_tool_with_runtime":
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#782 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node.py:1982`

High-risk permission pattern: return await execute(new_request)

```
  1980 |         if request.tool_call["name"] == "dynamic_tool_with_runtime":
  1981 |             new_request = request.override(tool=dynamic_tool_with_runtime)
> 1982 |             return await execute(new_request)
  1983 |         return await execute(request)
  1984 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#783 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node.py:1983`

High-risk permission pattern: return await execute(request)

```
  1981 |             new_request = request.override(tool=dynamic_tool_with_runtime)
  1982 |             return await execute(new_request)
> 1983 |         return await execute(request)
  1984 |
  1985 |     # ToolNode only knows about static_tool at init time
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#784 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/prebuilt/tests/test_tool_node.py:2007

High-risk permission pattern: # ToolRuntime should be injected and the tool should execute successfully

```
  2005 |     )
  2006 |
> 2007 |     # ToolRuntime should be injected and the tool should execute successfully
  2008 |     tool_message = result["messages"][-1]…
  2009 |     assert tool_message.content == "dynamic: x=42, tool_call_id=call_dynamic_2"
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#785 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/prebuilt/tests/test_tool_node.py:1

No logging, auditing, or monitoring detected

```
>    1 | import contextlib
     2 | import dataclasses
     3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#786 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:53

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
    51 |     def interceptor(
    52 |         request: ToolCallRequest,
>   53 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
    54 |     ) -> ToolMessage | Command:
    55 |         """Intercept and handle unregistered tools."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#787 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:57

High-risk permission pattern: # Short-circuit without calling execute for unregistered tool

```
    55 |         """Intercept and handle unregistered tools."""
    56 |         if request.tool_call["name"] == "unregistered_tool":
>   57 |             # Short-circuit without calling execute for unregistered tool
    58 |             return ToolMessage(
    59 |                 content="Handled by interceptor",
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#788 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:64`

High-risk permission pattern: return execute(request)

```
    62 |             )
    63 |         # Pass through for registered tools
>   64 |         return execute(request)
    65 |…
    66 |     node = ToolNode([registered_tool], wrap_tool_call=interceptor)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#789 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:115`

High-risk permission pattern: execute: Callable[[ToolCallRequest], Awaitable[ToolMessage | Command]],

```
   113 |     async def async_interceptor(
   114 |         request: ToolCallRequest,
>  115 |         execute: Callable[[ToolCallRequest], Awaitable[ToolMessage | Command]],
   116 |     ) -> ToolMessage | Command:
   117 |         """Intercept and handle unregistered tools."""
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#790 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:119`

High-risk permission pattern: # Short-circuit without calling execute for unregistered tool

```
   117 |         """Intercept and handle unregistered tools."""
   118 |         if request.tool_call["name"] == "unregistered_tool":
>  119 |             # Short-circuit without calling execute for unregistered tool
   120 |             return ToolMessage(
   121 |                 content="Handled by async interceptor",
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#791 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:126`

High-risk permission pattern: return await execute(request)

```
   124 |             )
   125 |         # Pass through for registered tools
>  126 |         return await execute(request)
   127 |…
   128 |     node = ToolNode([registered_tool], awrap_tool_call=async_interceptor)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#792 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:173`

High-risk permission pattern: """Test that unregistered tools error if interceptor tries to execute them."""

```
   171 |
   172 | def test_unregistered_tool_error_when_interceptor_calls_execute() -> None:
>  173 |     """Test that unregistered tools error if interceptor tries to execute them."""
   174 |
   175 |     def bad_interceptor(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#793 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:177`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
   175 |     def bad_interceptor(
   176 |         request: ToolCallRequest,
>  177 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   178 |     ) -> ToolMessage | Command:
   179 |         """Interceptor that tries to execute unregistered tool."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#794 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:179`

High-risk permission pattern: """Interceptor that tries to execute unregistered tool."""

```
   177 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   178 |     ) -> ToolMessage | Command:
>  179 |         """Interceptor that tries to execute unregistered tool."""
   180 |         # This should fail validation when execute is called
   181 |         return execute(request)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#795 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:180`

High-risk permission pattern: # This should fail validation when execute is called

```
   178 |     ) -> ToolMessage | Command:
   179 |         """Interceptor that tries to execute unregistered tool."""
>  180 |         # This should fail validation when execute is called
   181 |         return execute(request)…
   182 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#796 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:181`

High-risk permission pattern: return execute(request)

```
   179 |         """Interceptor that tries to execute unregistered tool."""
   180 |         # This should fail validation when execute is called
>  181 |         return execute(request)
   182 |
   183 |     node = ToolNode([registered_tool], wrap_tool_call=bad_interceptor)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#797 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:204`

High-risk permission pattern: # Unregistered tool should error when interceptor calls execute

```
   202 |     assert result[0].content == "Result: 42"
   203 |
>  204 |     # Unregistered tool should error when interceptor calls execute
   205 |     result = node.invoke(
   206 |         [
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#798 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:235`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
   233 |     def selective_interceptor(
   234 |         request: ToolCallRequest,
>  235 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   236 |     ) -> ToolMessage | Command:…
   237 |         """Handle unregistered tools, pass through registered ones."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#799 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:244`

High-risk permission pattern: return execute(request)

```
   242 |                 name="magic_tool",
   243 |             )
>  244 |         return execute(request)
   245 |
   246 |     node = ToolNode([registered_tool], wrap_tool_call=selective_interceptor)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#800 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:278`

High-risk permission pattern: # All tools should execute successfully

```
   276 |     )
   277 |
>  278 |     # All tools should execute successfully
   279 |     assert len(result) == 3
   280 |     assert result[0].content == "Result: 10"
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#801 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:293`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
   291 |     def command_interceptor(
   292 |         request: ToolCallRequest,
>  293 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   294 |     ) -> ToolMessage | Command:
   295 |         """Return Command for unregistered tools."""
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#802 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:307`

High-risk permission pattern: return execute(request)

```
   305 |                 goto="special_node",
   306 |             )
>  307 |         return execute(request)
   308 |…
   309 |     node = ToolNode([registered_tool], wrap_tool_call=command_interceptor)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#803 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:342`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
   340 |     def failing_interceptor(
   341 |         request: ToolCallRequest,
>  342 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   343 |     ) -> ToolMessage | Command:
   344 |         """Interceptor that throws exception for unregistered tools."""
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#804 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:348`

High-risk permission pattern: return execute(request)

```
   346 |             msg = "Interceptor failed"
   347 |             raise ValueError(msg)
>  348 |         return execute(request)
   349 |
   350 |     node = ToolNode(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#805 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:406`

High-risk permission pattern: execute: Callable[[ToolCallRequest], Awaitable[ToolMessage | Command]],

```
   404 |     async def failing_async_interceptor(
   405 |         request: ToolCallRequest,
>  406 |         execute: Callable[[ToolCallRequest], Awaitable[ToolMessage | Command]],
   407 |     ) -> ToolMessage | Command:…
   408 |         """Async interceptor that throws exception for unregistered tools."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#806 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:412`

High-risk permission pattern: return await execute(request)

```
   410 |             msg = "Async interceptor failed"
   411 |             raise RuntimeError(msg)
>  412 |         return await execute(request)
   413 |
   414 |     node = ToolNode(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#807 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:474`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
   472 |     def interceptor(
   473 |         request: ToolCallRequest,
>  474 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   475 |     ) -> ToolMessage | Command:
   476 |         """Intercept unregistered tools with dict input."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#808 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:483`

High-risk permission pattern: return execute(request)

```
   481 |                 name="dict_tool",
   482 |             )
>  483 |         return execute(request)
   484 |
   485 |     node = ToolNode([registered_tool], wrap_tool_call=interceptor)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#809 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:522`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
   520 |     def capturing_interceptor(
   521 |         request: ToolCallRequest,
>  522 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   523 |     ) -> ToolMessage | Command:…
   524 |         """Capture request to verify tool field."""
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#810 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:534`

High-risk permission pattern: return execute(request)

```
   532 |             )
   533 |         # Tool is registered
>  534 |         return execute(request)
   535 |
   536 |     node = ToolNode([registered_tool], wrap_tool_call=capturing_interceptor)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#811 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:597`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
   595 |     def hook(
   596 |         request: ToolCallRequest,
>  597 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   598 |     ) -> ToolMessage | Command:
   599 |         if request.tool_call["name"] == "custom_tool":
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#812 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:601`

High-risk permission pattern: return execute(request.override(tool=custom_tool_impl))

```
   599 |         if request.tool_call["name"] == "custom_tool":
   600 |             assert request.tool is None  # Unregistered tools have tool=None
>  601 |             return execute(request.override(tool=custom_tool_impl))
   602 |         return execute(request)…
   603 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#813 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:602`

High-risk permission pattern: return execute(request)

```
   600 |             assert request.tool is None  # Unregistered tools have tool=None
   601 |             return execute(request.override(tool=custom_tool_impl))
>  602 |         return execute(request)
   603 |
   604 |     node = ToolNode([registered_tool], wrap_tool_call=hook)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#814 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:636`

High-risk permission pattern: execute: Callable[[ToolCallRequest], Awaitable[ToolMessage | Command]],

```
   634 |     async def hook(
   635 |         request: ToolCallRequest,
>  636 |         execute: Callable[[ToolCallRequest], Awaitable[ToolMessage | Command]],
   637 |     ) -> ToolMessage | Command:
   638 |         if request.tool_call["name"] == "custom_async_tool":
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#815 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:640`

High-risk permission pattern: return await execute(request.override(tool=custom_async_tool_impl))

```
   638 |         if request.tool_call["name"] == "custom_async_tool":
   639 |             assert request.tool is None  # Unregistered tools have tool=None
>  640 |             return await execute(request.override(tool=custom_async_tool_impl))
   641 |         return await execute(request)
   642 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#816 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:641`

High-risk permission pattern: return await execute(request)

```
   639 |             assert request.tool is None  # Unregistered tools have tool=None
   640 |             return await execute(request.override(tool=custom_async_tool_impl))
>  641 |         return await execute(request)
   642 |…
   643 |     node = ToolNode([registered_tool], awrap_tool_call=hook)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#817 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:672`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
   670 |     def passthrough_hook(
   671 |         request: ToolCallRequest,
>  672 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   673 |     ) -> ToolMessage | Command:
   674 |         return execute(request)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#818 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:674`

High-risk permission pattern: return execute(request)

```
   672 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
   673 |     ) -> ToolMessage | Command:
>  674 |         return execute(request)
   675 |
   676 |     node = ToolNode(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#819 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:707`

High-risk permission pattern: execute: Callable[[ToolCallRequest], ToolMessage | Command],

```
    705 |     def passthrough_hook(
    706 |         request: ToolCallRequest,
>   707 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
    708 |     ) -> ToolMessage | Command:…
    709 |         return execute(request)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#820 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:709`

High-risk permission pattern: return execute(request)

```
    707 |         execute: Callable[[ToolCallRequest], ToolMessage | Command],
    708 |     ) -> ToolMessage | Command:
>   709 |         return execute(request)
    710 |
    711 |     node = ToolNode(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#821 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:743`

High-risk permission pattern: execute: Callable[[ToolCallRequest], Awaitable[ToolMessage | Command]],

```
    741 |     async def passthrough_hook(
    742 |         request: ToolCallRequest,
>   743 |         execute: Callable[[ToolCallRequest], Awaitable[ToolMessage | Command]],
    744 |     ) -> ToolMessage | Command:
    745 |         return await execute(request)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#822 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:745`

High-risk permission pattern: return await execute(request)

```
    743 |         execute: Callable[[ToolCallRequest], Awaitable[ToolMessage | Command]],
    744 |     ) -> ToolMessage | Command:
>   745 |         return await execute(request)
    746 |
    747 |     node = ToolNode(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#823 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:778`

High-risk permission pattern: execute: Callable[[ToolCallRequest], Awaitable[ToolMessage | Command]],

```
   776 |     async def passthrough_hook(
   777 |         request: ToolCallRequest,
>  778 |         execute: Callable[[ToolCallRequest], Awaitable[ToolMessage | Command]],
   779 |     ) -> ToolMessage | Command:…
   780 |         return await execute(request)
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#824 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:780`

High-risk permission pattern: return await execute(request)

```
   778 |         execute: Callable[[ToolCallRequest], Awaitable[ToolMessage | Command]],
   779 |     ) -> ToolMessage | Command:
>  780 |         return await execute(request)
   781 |
   782 |     node = ToolNode(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#825 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/prebuilt/tests/test_tool_node_interceptor_unregistered.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Test tool node interceptor handling of unregistered tools."""
     2 |
     3 | from collections.abc import Awaitable, Callable
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#826 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/prebuilt/tests/test_tool_node_validation_error_filtering.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Unit tests for ValidationError filtering in ToolNode.
     2 |…
     3 | This module tests that validation errors are filtered to only include arguments
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#827 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/prebuilt/tests/test_validation_node.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import sys
     2 | from typing import Any
     3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#828 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from langgraph_sdk.auth import Auth
     2 | from langgraph_sdk.client import get_client, get_sync_client
     3 | from langgraph_sdk.encryption import Encryption
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#829 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/_async/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Async client exports."""
     2 |
     3 | from langgraph_sdk._async.assistants import AssistantsClient
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#830 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/assistants.py:445`

High-risk permission pattern: async def delete(

```
    443 |         )
    444 |
>   445 |     async def delete(
    446 |         self,…
    447 |         assistant_id: str,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#831 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/assistants.py:453`

High-risk permission pattern: """Delete an assistant.

```
    451 |         params: QueryParamTypes | None = None,
    452 |     ) -> None:
>   453 |         """Delete an assistant.
    454 |
    455 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#832 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/assistants.py:456`

High-risk permission pattern: assistant_id: The assistant ID to delete.

```
    454 |
    455 |         Args:
>   456 |             assistant_id: The assistant ID to delete.
    457 |             delete_threads: If true, delete all threads with `metadata.assistant_id`
    458 |                 matching this assistant, along with runs and checkpoints belonging to
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#833 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/assistants.py:457`

High-risk permission pattern: delete_threads: If true, delete all threads with `metadata.assistant_id`

```
    455 |         Args:
    456 |             assistant_id: The assistant ID to delete.
>   457 |             delete_threads: If true, delete all threads with `metadata.assistant_id`
    458 |                 matching this assistant, along with runs and checkpoints belonging to
    459 |                 those threads.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#834 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/assistants.py:470`

High-risk permission pattern: await client.assistants.delete(

```
   468 |             ```python
   469 |             client = get_client(url="http://localhost:2024")
>  470 |             await client.assistants.delete(
   471 |                 assistant_id="my_assistant_id"…
   472 |             )
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#835 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/assistants.py:481`

High-risk permission pattern: await self.http.delete(

```
   479 |         if params:
   480 |             query_params.update(params)
>  481 |         await self.http.delete(
   482 |             f"/assistants/{assistant_id}",
   483 |             headers=headers,
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#836 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/assistants.py:706`

High-risk permission pattern: assistant_id: The assistant ID to delete.

```
   704 |
   705 |         Args:
>  706 |             assistant_id: The assistant ID to delete.
   707 |             version: The version to change to.
   708 |             headers: Optional custom headers to include with the request.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#837 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/sdk-py/langgraph_sdk/_async/assistants.py:1

No logging, auditing, or monitoring detected

```
>    1 | """Async client for managing assistants in LangGraph."""
     2 |…
     3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#838 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/sdk-py/langgraph_sdk/_async/cron.py:88

High-risk permission pattern: schedule: The cron schedule to execute this job on.

```
    86 |             assistant_id: The assistant ID or graph name to use for the cron job.
    87 |                 If using graph name, will default to first assistant created from that graph.
>   88 |             schedule: The cron schedule to execute this job on.
    89 |                 Schedules are interpreted in UTC unless a timezone is specified.
    90 |             input: The input to the graph.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#839 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/sdk-py/langgraph_sdk/_async/cron.py:204

High-risk permission pattern: schedule: The cron schedule to execute this job on.

```
   202 |             assistant_id: The assistant ID or graph name to use for the cron job.
   203 |                 If using graph name, will default to first assistant created from that graph.
>  204 |             schedule: The cron schedule to execute this job on.
   205 |                 Schedules are interpreted in UTC unless a timezone is specified.
   206 |             input: The input to the graph.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#840 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/sdk-py/langgraph_sdk/_async/cron.py:216

High-risk permission pattern: Must be one of 'delete' (default) or 'keep'. 'delete' removes the thread

```
   214 |             webhook: Webhook to call after LangGraph API call is done.
   215 |             on_run_completed: What to do with the thread after the run completes.
>  216 |                 Must be one of 'delete' (default) or 'keep'. 'delete' removes the thread
   217 |                 after execution. 'keep' creates a new thread for each execution but does not
   218 |                 clean them up. Clients are responsible for cleaning up kept threads.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#841 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/cron.py:290`

High-risk permission pattern: async def delete(

```
   288 |         )
   289 |
>  290 |     async def delete(
   291 |         self,…
   292 |         cron_id: str,
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#842 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/cron.py:297`

High-risk permission pattern: """Delete a cron.

```
   295 |         params: QueryParamTypes | None = None,
   296 |     ) -> None:
>  297 |         """Delete a cron.
   298 |
   299 |         Args:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#843 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/cron.py:300`

High-risk permission pattern: cron_id: The cron ID to delete.

```
   298 |
   299 |         Args:
>  300 |             cron_id: The cron ID to delete.
   301 |             headers: Optional custom headers to include with the request.
   302 |             params: Optional query parameters to include with the request.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#844 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/cron.py:311`

High-risk permission pattern: await client.crons.delete(

```
    309 |             ```python
    310 |             client = get_client(url="http://localhost:2024")
>   311 |             await client.crons.delete(
    312 |                 cron_id="cron_to_delete"…
    313 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#845 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/cron.py:317`

High-risk permission pattern: await self.http.delete(f"/runs/crons/{cron_id}", headers=headers, params=params)

```
    315 |
    316 |         """
>   317 |         await self.http.delete(f"/runs/crons/{cron_id}", headers=headers, params=params)
    318 |
    319 |     async def update(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#846 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/cron.py:346`

High-risk permission pattern: schedule: The cron schedule to execute this job on.

```
    344 |         Args:
    345 |             cron_id: The cron ID to update.
>   346 |             schedule: The cron schedule to execute this job on.
    347 |                 Schedules are interpreted in UTC unless a timezone is specified.
    348 |             end_time: The end date to stop running the cron.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#847 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/cron.py:357`

High-risk permission pattern: Must be one of 'delete' or 'keep'. 'delete' removes the thread

```
    355 |             interrupt_after: Nodes to interrupt immediately after they get executed.
    356 |             on_run_completed: What to do with the thread after the run completes.
>   357 |                 Must be one of 'delete' or 'keep'. 'delete' removes the thread
    358 |                 after execution. 'keep' creates a new thread for each execution but does not
    359 |                 clean them up.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#848 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/_async/cron.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Async client for managing recurrent runs (cron jobs) in LangGraph."""
     2 |…
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#849 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/http.py:118`

High-risk permission pattern: async def delete(

```
   116 |         return await _adecode_json(r)
   117 |
>  118 |     async def delete(
   119 |         self,
   120 |         path: str,
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#850 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/http.py:127`

High-risk permission pattern: """Send a `DELETE` request."""

```
   125 |         on_response: Callable[[httpx.Response], None] | None = None,
   126 |     ) -> None:
>  127 |         """Send a `DELETE` request."""
   128 |         r = await self.client.request(
   129 |             "DELETE", path, json=json, params=params, headers=headers
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#851 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/http.py:129`

High-risk permission pattern: "DELETE", path, json=json, params=params, headers=headers

```
   127 |         """Send a `DELETE` request."""
   128 |         r = await self.client.request(
 >  129 |             "DELETE", path, json=json, params=params, headers=headers
   130 |         )…
   131 |         if on_response:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#852 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/runs.py:228`

High-risk permission pattern: command: A command to execute. Cannot be combined with input.

```
   226 |                 If using graph name, will default to first assistant created from that graph.
   227 |             input: The input to the graph.
 >  228 |             command: A command to execute. Cannot be combined with input.
   229 |             stream_mode: The stream mode(s) to use.
   230 |             stream_subgraphs: Whether to stream output from subgraphs.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#853 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/runs.py:244`

High-risk permission pattern: on_completion: Whether to delete or keep the thread created for a stateless run.

```
   242 |             on_disconnect: The disconnect mode to use.
   243 |                 Must be one of 'cancel' or 'continue'.
 >  244 |             on_completion: Whether to delete or keep the thread created for a stateless run.
   245 |                 Must be one of 'delete' or 'keep'.
   246 |             webhook: Webhook to call after LangGraph API call is done.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#854 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/runs.py:245`

High-risk permission pattern: Must be one of 'delete' or 'keep'.

```
   243 |                 Must be one of 'cancel' or 'continue'.
   244 |             on_completion: Whether to delete or keep the thread created for a stateless run.
 >  245 |                 Must be one of 'delete' or 'keep'.
   246 |             webhook: Webhook to call after LangGraph API call is done.
   247 |             multitask_strategy: Multitask strategy to use.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#855 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/runs.py:443`

High-risk permission pattern: command: A command to execute. Cannot be combined with input.

```
   441 |                 If using graph name, will default to first assistant created from that graph.
   442 |             input: The input to the graph.
 >  443 |             command: A command to execute. Cannot be combined with input.
   444 |             stream_mode: The stream mode(s) to use.…
   445 |             stream_subgraphs: Whether to stream output from subgraphs.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#856 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/runs.py:459`

High-risk permission pattern: on_completion: Whether to delete or keep the thread created for a stateless run.

```
   457 |             multitask_strategy: Multitask strategy to use.
   458 |                 Must be one of 'reject', 'interrupt', 'rollback', or 'enqueue'.
 >  459 |             on_completion: Whether to delete or keep the thread created for a stateless run.
   460 |                 Must be one of 'delete' or 'keep'.
   461 |             if_not_exists: How to handle missing thread. Defaults to 'reject'.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#857 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/runs.py:460`

High-risk permission pattern: Must be one of 'delete' or 'keep'.

```
   458 |                 Must be one of 'reject', 'interrupt', 'rollback', or 'enqueue'.
   459 |             on_completion: Whether to delete or keep the thread created for a stateless run.
 >  460 |                 Must be one of 'delete' or 'keep'.
   461 |             if_not_exists: How to handle missing thread. Defaults to 'reject'.
   462 |                 Must be either 'reject' (raise error if missing), or 'create' (create new thread).
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#858 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/runs.py:695`

High-risk permission pattern: command: A command to execute. Cannot be combined with input.

```
   693 |                 If using graph name, will default to first assistant created from that graph.
   694 |             input: The input to the graph.
>  695 |             command: A command to execute. Cannot be combined with input.
   696 |             metadata: Metadata to assign to the run.…
   697 |             config: The configuration for the assistant.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#859 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/runs.py:707`

High-risk permission pattern: on_completion: Whether to delete or keep the thread created for a stateless run.

```
   705 |             on_disconnect: The disconnect mode to use.
   706 |                 Must be one of 'cancel' or 'continue'.
>  707 |             on_completion: Whether to delete or keep the thread created for a stateless run.
   708 |                 Must be one of 'delete' or 'keep'.
   709 |             multitask_strategy: Multitask strategy to use.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#860 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/runs.py:708`

High-risk permission pattern: Must be one of 'delete' or 'keep'.

```
   706 |                 Must be one of 'cancel' or 'continue'.
   707 |             on_completion: Whether to delete or keep the thread created for a stateless run.
>  708 |                 Must be one of 'delete' or 'keep'.
   709 |             multitask_strategy: Multitask strategy to use.
   710 |                 Must be one of 'reject', 'interrupt', 'rollback', or 'enqueue'.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#861 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/runs.py:1128`

High-risk permission pattern: async def delete(

```
  1126 |         )
  1127 |
> 1128 |     async def delete(
  1129 |         self,
  1130 |         thread_id: str,
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#862 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/runs.py:1136`

High-risk permission pattern: """Delete a run.

```
  1134 |         params: QueryParamTypes | None = None,
  1135 |     ) -> None:
> 1136 |         """Delete a run.
  1137 |…
  1138 |         Args:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#863 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/runs.py:1139`

High-risk permission pattern: thread_id: The thread ID to delete.

```
  1137 |
  1138 |         Args:
> 1139 |             thread_id: The thread ID to delete.
  1140 |             run_id: The run ID to delete.
  1141 |             headers: Optional custom headers to include with the request.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#864 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/runs.py:1140`

High-risk permission pattern: run_id: The run ID to delete.

```
  1138 |         Args:
  1139 |             thread_id: The thread ID to delete.
> 1140 |             run_id: The run ID to delete.
  1141 |             headers: Optional custom headers to include with the request.
  1142 |             params: Optional query parameters to include with the request.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#865 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/sdk-py/langgraph_sdk/_async/runs.py:1151

High-risk permission pattern: await client.runs.delete(

```
  1149 |             ```python
  1150 |             client = get_client(url="http://localhost:2024")
> 1151 |             await client.runs.delete(
  1152 |                 thread_id="thread_id_to_delete",…
  1153 |                 run_id="run_id_to_delete"
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#866 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/sdk-py/langgraph_sdk/_async/runs.py:1158

High-risk permission pattern: await self.http.delete(

```
  1156 |
  1157 |         """
> 1158 |         await self.http.delete(
  1159 |             f"/threads/{thread_id}/runs/{run_id}", headers=headers, params=params
  1160 |         )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#867 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/sdk-py/langgraph_sdk/_async/runs.py:1

No logging, auditing, or monitoring detected

```
>    1 | """Async client for managing runs in LangGraph."""
     2 |
     3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#868 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

libs/sdk-py/langgraph_sdk/_async/runs.py:811

Dynamic HTTP with sensitive data context

```
   809 |                 on_run_created(metadata)
   810 |
>  811 |         response = await self.http.request_reconnect(
   812 |             endpoint,
   813 |             "POST",
```

Remediation:
1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#869 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

`libs/sdk-py/langgraph_sdk/_async/runs.py:959`

Dynamic HTTP with sensitive data context

```
   957 |             query_params.update(params)
   958 |         if wait:
>  959 |             return await self.http.request_reconnect(
   960 |                 f"/threads/{thread_id}/runs/{run_id}/cancel",…
   961 |                 "POST",
```

Remediation:
1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#870 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

`libs/sdk-py/langgraph_sdk/_async/runs.py:1062`

Dynamic HTTP with sensitive data context

```
  1060 |
  1061 |         """
> 1062 |         return await self.http.request_reconnect(
  1063 |             f"/threads/{thread_id}/runs/{run_id}/join",
  1064 |             "GET",
```

Remediation:
1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#871 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/store.py:152`

High-risk permission pattern: """Delete an item.

```
   150 |         params: QueryParamTypes | None = None,
   151 |     ) -> None:
>  152 |         """Delete an item.
   153 |
   154 |         Args:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#872 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/store.py:173`

High-risk permission pattern: await self.http.delete(

```
  171 |             ```
  172 |         """
> 173 |         await self.http.delete(
  174 |             "/store/items",…
  175 |             json={"namespace": namespace, "key": key},
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#873 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/_async/store.py:1`

No logging, auditing, or monitoring detected

```
>   1 | """Async Store client for LangGraph SDK."""
    2 |
    3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#874 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/threads.py:123`

High-risk permission pattern: `strategy` (defaults to "delete").

```
  121 |             ttl: Optional time-to-live in minutes for the thread. You can pass an
  122 |                 integer (minutes) or a mapping with keys `ttl` and optional
> 123 |                 `strategy` (defaults to "delete").
  124 |             headers: Optional custom headers to include with the request.
  125 |             params: Optional query parameters to include with the request.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#875 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/threads.py:167`

High-risk permission pattern: payload["ttl"] = {"ttl": ttl, "strategy": "delete"}

```
  165 |         if ttl is not None:
  166 |             if isinstance(ttl, (int, float)):
> 167 |                 payload["ttl"] = {"ttl": ttl, "strategy": "delete"}
  168 |             else:
  169 |                 payload["ttl"] = ttl
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#876 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/threads.py:191`

High-risk permission pattern: `strategy` (defaults to "delete").

```
   189 |             ttl: Optional time-to-live in minutes for the thread. You can pass an
   190 |                 integer (minutes) or a mapping with keys `ttl` and optional
>  191 |                 `strategy` (defaults to "delete").
   192 |             headers: Optional custom headers to include with the request.…
   193 |             params: Optional query parameters to include with the request.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#877 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/threads.py:212`

High-risk permission pattern: payload["ttl"] = {"ttl": ttl, "strategy": "delete"}

```
   210 |         if ttl is not None:
   211 |             if isinstance(ttl, (int, float)):
>  212 |                 payload["ttl"] = {"ttl": ttl, "strategy": "delete"}
   213 |             else:
   214 |                 payload["ttl"] = ttl
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#878 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/threads.py:222`

High-risk permission pattern: async def delete(

```
   220 |         )
   221 |
>  222 |     async def delete(
   223 |         self,
   224 |         thread_id: str,
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#879 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/threads.py:229`

High-risk permission pattern: """Delete a thread.

```
   227 |         params: QueryParamTypes | None = None,
   228 |     ) -> None:
>  229 |         """Delete a thread.
   230 |…
   231 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#880 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/threads.py:232`

High-risk permission pattern: thread_id: The ID of the thread to delete.

```
   230 |
   231 |         Args:
>  232 |             thread_id: The ID of the thread to delete.
   233 |             headers: Optional custom headers to include with the request.
   234 |             params: Optional query parameters to include with the request.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#881 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/threads.py:243`

High-risk permission pattern: await client.threads.delete(

```
   241 |             ```python
   242 |             client = get_client(url="http://localhost2024)
>  243 |             await client.threads.delete(
   244 |                 thread_id="my_thread_id"
   245 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#882 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/threads.py:249`

High-risk permission pattern: await self.http.delete(f"/threads/{thread_id}", headers=headers, params=params)

```
   247 |
   248 |         """
>  249 |         await self.http.delete(f"/threads/{thread_id}", headers=headers, params=params)
   250 |
   251 |     async def search(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#883 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/threads.py:399`

High-risk permission pattern: strategy: PruneStrategy = "delete",

```
    397 |         thread_ids: Sequence[str],
    398 |         *,
>   399 |         strategy: PruneStrategy = "delete",
    400 |         headers: Mapping[str, str] | None = None,…
    401 |         params: QueryParamTypes | None = None,
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#884 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/threads.py:407`

High-risk permission pattern: strategy: The prune strategy. `"delete"` removes threads entirely.

```
    405 |         Args:
    406 |             thread_ids: List of thread IDs to prune.
>   407 |             strategy: The prune strategy. `"delete"` removes threads entirely.
    408 |                 `"keep_latest"` prunes old checkpoints but keeps threads and their
    409 |                 latest state. Defaults to `"delete"`.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#885 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/threads.py:409`

High-risk permission pattern: latest state. Defaults to `"delete"`.

```
    407 |             strategy: The prune strategy. `"delete"` removes threads entirely.
    408 |                 `"keep_latest"` prunes old checkpoints but keeps threads and their
>   409 |                 latest state. Defaults to `"delete"`.
    410 |             headers: Optional custom headers to include with the request.
    411 |             params: Optional query parameters to include with the request.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#886 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_async/threads.py:430`

High-risk permission pattern: if strategy != "delete":

```
  428 |             "thread_ids": thread_ids,
  429 |         }
> 430 |         if strategy != "delete":
  431 |             payload["strategy"] = strategy…
  432 |         return await self.http.post(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#887 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/_async/threads.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Async client for managing threads in LangGraph."""
     2 |
     3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#888 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/_shared/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Shared utilities for async and sync clients."""
     2 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#889 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/_shared/types.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Type aliases and constants."""
     2 |
     3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#890 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/sdk-py/langgraph_sdk/_shared/utilities.py:1

No logging, auditing, or monitoring detected

```
>    1 | """Shared utility functions for async and sync clients."""
     2 |…
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#891 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

libs/sdk-py/langgraph_sdk/_sync/__init__.py:1

No logging, auditing, or monitoring detected

```
>    1 | """Sync client exports."""
     2 |
     3 | from langgraph_sdk._sync.assistants import SyncAssistantsClient
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#892 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/sdk-py/langgraph_sdk/_sync/assistants.py:447

High-risk permission pattern: def delete(

```
   445 |         )
   446 |
>  447 |     def delete(
   448 |         self,
   449 |         assistant_id: str,
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#893 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/sdk-py/langgraph_sdk/_sync/assistants.py:455

High-risk permission pattern: """Delete an assistant.

```
   453 |         params: QueryParamTypes | None = None,
   454 |     ) -> None:
>  455 |         """Delete an assistant.
   456 |
   457 |         Args:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#894 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/sdk-py/langgraph_sdk/_sync/assistants.py:458

High-risk permission pattern: assistant_id: The assistant ID to delete.

```
   456 |
   457 |         Args:
>  458 |             assistant_id: The assistant ID to delete.
   459 |             delete_threads: If true, delete all threads with `metadata.assistant_id`…
   460 |                 matching this assistant, along with runs and checkpoints belonging to
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#895 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/sdk-py/langgraph_sdk/_sync/assistants.py:459

High-risk permission pattern: delete_threads: If true, delete all threads with `metadata.assistant_id`

```
   457 |         Args:
   458 |             assistant_id: The assistant ID to delete.
>  459 |             delete_threads: If true, delete all threads with `metadata.assistant_id`
   460 |                 matching this assistant, along with runs and checkpoints belonging to
   461 |                 those threads.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#896 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/sdk-py/langgraph_sdk/_sync/assistants.py:472

High-risk permission pattern: client.assistants.delete(

```
   470 |             ```python
   471 |             client = get_sync_client(url="http://localhost:2024")
>  472 |             client.assistants.delete(
   473 |                 assistant_id="my_assistant_id"
   474 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#897 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/sdk-py/langgraph_sdk/_sync/assistants.py:483

High-risk permission pattern: self.http.delete(

```
   481 |         if params:
   482 |             query_params.update(params)
>  483 |         self.http.delete(
   484 |             f"/assistants/{assistant_id}",
   485 |             headers=headers,
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#898 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/assistants.py:705`

High-risk permission pattern: assistant_id: The assistant ID to delete.

```
   703 |
   704 |         Args:
>  705 |             assistant_id: The assistant ID to delete.
   706 |             version: The version to change to.…
   707 |             headers: Optional custom headers to include with the request.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#899 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/_sync/assistants.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Synchronous client for managing assistants in LangGraph."""
     2 |
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#900 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/_sync/client.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Sync LangGraph client."""
     2 |
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#901 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/cron.py:82`

High-risk permission pattern: schedule: The cron schedule to execute this job on.

```
    80 |             assistant_id: The assistant ID or graph name to use for the cron job.
    81 |                 If using graph name, will default to first assistant created from that graph.
>   82 |             schedule: The cron schedule to execute this job on.
    83 |                 Schedules are interpreted in UTC unless a timezone is specified.…
    84 |             input: The input to the graph.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#902 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/cron.py:194`

High-risk permission pattern: schedule: The cron schedule to execute this job on.

```
   192 |             assistant_id: The assistant ID or graph name to use for the cron job.
   193 |                 If using graph name, will default to first assistant created from that graph.
>  194 |             schedule: The cron schedule to execute this job on.
   195 |                 Schedules are interpreted in UTC unless a timezone is specified.
   196 |             input: The input to the graph.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#903 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/cron.py:206`

High-risk permission pattern: Must be one of 'delete' (default) or 'keep'. 'delete' removes the thread

```
   204 |             webhook: Webhook to call after LangGraph API call is done.
   205 |             on_run_completed: What to do with the thread after the run completes.
>  206 |                 Must be one of 'delete' (default) or 'keep'. 'delete' removes the thread
   207 |                 after execution. 'keep' creates a new thread for each execution but does not
   208 |                 clean them up. Clients are responsible for cleaning up kept threads.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#904 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/cron.py:279`

High-risk permission pattern: def delete(

```
   277 |         )
   278 |
>  279 |     def delete(
   280 |         self,
   281 |         cron_id: str,
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#905 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/cron.py:286`

High-risk permission pattern: """Delete a cron.

```
   284 |         params: QueryParamTypes | None = None,
   285 |     ) -> None:
>  286 |         """Delete a cron.
   287 |…
   288 |         Args:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#906 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/cron.py:289`

High-risk permission pattern: cron_id: The cron ID to delete.

```
   287 |
   288 |         Args:
>  289 |             cron_id: The cron ID to delete.
   290 |             headers: Optional custom headers to include with the request.
   291 |             params: Optional query parameters to include with the request.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#907 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/cron.py:300`

High-risk permission pattern: client.crons.delete(

```
   298 |             ```python
   299 |             client = get_sync_client(url="http://localhost:8123")
>  300 |             client.crons.delete(
   301 |                 cron_id="cron_to_delete"
   302 |             )
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#908 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/cron.py:306`

High-risk permission pattern: self.http.delete(f"/runs/crons/{cron_id}", headers=headers, params=params)

```
   304 |
   305 |         """
>  306 |         self.http.delete(f"/runs/crons/{cron_id}", headers=headers, params=params)
   307 |…
   308 |     def update(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#909 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/cron.py:335`

High-risk permission pattern: schedule: The cron schedule to execute this job on.

```
   333 |         Args:
   334 |             cron_id: The cron ID to update.
>  335 |             schedule: The cron schedule to execute this job on.
   336 |                 Schedules are interpreted in UTC unless a timezone is specified.
   337 |             end_time: The end date to stop running the cron.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#910 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/cron.py:346`

High-risk permission pattern: Must be one of 'delete' or 'keep'. 'delete' removes the thread

```
   344 |             interrupt_after: Nodes to interrupt immediately after they get executed.
   345 |             on_run_completed: What to do with the thread after the run completes.
>  346 |                 Must be one of 'delete' or 'keep'. 'delete' removes the thread
   347 |                 after execution. 'keep' creates a new thread for each execution but does not
   348 |                 clean them up.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#911 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/_sync/cron.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Synchronous cron client for LangGraph SDK."""
     2 |
     3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#912 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/http.py:118`

High-risk permission pattern: def delete(

```
   116 |         return _decode_json(r)
   117 |
>  118 |     def delete(
   119 |         self,…
   120 |         path: str,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#913 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/http.py:127`

High-risk permission pattern: """Send a `DELETE` request."""

```
   125 |         on_response: Callable[[httpx.Response], None] | None = None,
   126 |     ) -> None:
>  127 |         """Send a `DELETE` request."""
   128 |         r = self.client.request(
   129 |             "DELETE", path, json=json, params=params, headers=headers
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#914 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/http.py:129`

High-risk permission pattern: "DELETE", path, json=json, params=params, headers=headers

```
   127 |         """Send a `DELETE` request."""
   128 |         r = self.client.request(
>  129 |             "DELETE", path, json=json, params=params, headers=headers
   130 |         )
   131 |         if on_response:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#915 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/runs.py:228`

High-risk permission pattern: command: The command to execute.

```
   226 |                 If using graph name, will default to first assistant created from that graph.
   227 |             input: The input to the graph.
>  228 |             command: The command to execute.
   229 |             stream_mode: The stream mode(s) to use.
   230 |             stream_subgraphs: Whether to stream output from subgraphs.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#916 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/runs.py:244`

High-risk permission pattern: on_completion: Whether to delete or keep the thread created for a stateless run.

```
   242 |             on_disconnect: The disconnect mode to use.
   243 |                 Must be one of 'cancel' or 'continue'.
 >  244 |             on_completion: Whether to delete or keep the thread created for a stateless run.
   245 |                 Must be one of 'delete' or 'keep'.…
   246 |             webhook: Webhook to call after LangGraph API call is done.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#917 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/runs.py:245`

High-risk permission pattern: Must be one of 'delete' or 'keep'.

```
   243 |                 Must be one of 'cancel' or 'continue'.
   244 |             on_completion: Whether to delete or keep the thread created for a stateless run.
 >  245 |                 Must be one of 'delete' or 'keep'.
   246 |             webhook: Webhook to call after LangGraph API call is done.
   247 |             multitask_strategy: Multitask strategy to use.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#918 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/runs.py:438`

High-risk permission pattern: command: The command to execute.

```
   436 |                 If using graph name, will default to first assistant created from that graph.
   437 |             input: The input to the graph.
 >  438 |             command: The command to execute.
   439 |             stream_mode: The stream mode(s) to use.
   440 |             stream_subgraphs: Whether to stream output from subgraphs.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#919 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/runs.py:454`

High-risk permission pattern: on_completion: Whether to delete or keep the thread created for a stateless run.

```
  452 |             multitask_strategy: Multitask strategy to use.
  453 |                 Must be one of 'reject', 'interrupt', 'rollback', or 'enqueue'.
> 454 |             on_completion: Whether to delete or keep the thread created for a stateless run.
  455 |                 Must be one of 'delete' or 'keep'.…
  456 |             if_not_exists: How to handle missing thread. Defaults to 'reject'.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#920 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/runs.py:455`

High-risk permission pattern: Must be one of 'delete' or 'keep'.

```
  453 |                 Must be one of 'reject', 'interrupt', 'rollback', or 'enqueue'.
  454 |             on_completion: Whether to delete or keep the thread created for a stateless run.
> 455 |                 Must be one of 'delete' or 'keep'.
  456 |             if_not_exists: How to handle missing thread. Defaults to 'reject'.
  457 |                 Must be either 'reject' (raise error if missing), or 'create' (create new thread).
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#921 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/runs.py:690`

High-risk permission pattern: command: The command to execute.

```
  688 |                 If using graph name, will default to first assistant created from that graph.
  689 |             input: The input to the graph.
> 690 |             command: The command to execute.
  691 |             metadata: Metadata to assign to the run.
  692 |             config: The configuration for the assistant.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#922 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/runs.py:702`

High-risk permission pattern: on_completion: Whether to delete or keep the thread created for a stateless run.

```
  700 |             on_disconnect: The disconnect mode to use.
  701 |                 Must be one of 'cancel' or 'continue'.
> 702 |             on_completion: Whether to delete or keep the thread created for a stateless run.
  703 |                 Must be one of 'delete' or 'keep'.
  704 |             multitask_strategy: Multitask strategy to use.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#923 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/runs.py:703`

High-risk permission pattern: Must be one of 'delete' or 'keep'.

```
   701 |                 Must be one of 'cancel' or 'continue'.
   702 |             on_completion: Whether to delete or keep the thread created for a stateless run.
>  703 |                 Must be one of 'delete' or 'keep'.
   704 |             multitask_strategy: Multitask strategy to use.…
   705 |                 Must be one of 'reject', 'interrupt', 'rollback', or 'enqueue'.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#924 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/runs.py:1109`

High-risk permission pattern: def delete(

```
  1107 |         )
  1108 |
> 1109 |     def delete(
  1110 |         self,
  1111 |         thread_id: str,
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#925 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/runs.py:1117`

High-risk permission pattern: """Delete a run.

```
  1115 |         params: QueryParamTypes | None = None,
  1116 |     ) -> None:
> 1117 |         """Delete a run.
  1118 |
  1119 |         Args:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#926 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/runs.py:1120`

High-risk permission pattern: thread_id: The thread ID to delete.

```
  1118 |
  1119 |         Args:
> 1120 |             thread_id: The thread ID to delete.
  1121 |             run_id: The run ID to delete.…
  1122 |             headers: Optional custom headers to include with the request.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#927 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/runs.py:1121`

High-risk permission pattern: run_id: The run ID to delete.

```
  1119 |         Args:
  1120 |             thread_id: The thread ID to delete.
> 1121 |             run_id: The run ID to delete.
  1122 |             headers: Optional custom headers to include with the request.
  1123 |             params: Optional query parameters to include with the request.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#928 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/runs.py:1132`

High-risk permission pattern: client.runs.delete(

```
  1130 |             ```python
  1131 |             client = get_sync_client(url="http://localhost:2024")
> 1132 |             client.runs.delete(
  1133 |                 thread_id="thread_id_to_delete",
  1134 |                 run_id="run_id_to_delete"
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#929 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/runs.py:1139`

High-risk permission pattern: self.http.delete(

```
  1137 |
  1138 |         """
> 1139 |         self.http.delete(
  1140 |             f"/threads/{thread_id}/runs/{run_id}", headers=headers, params=params
  1141 |         )
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#930 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/_sync/runs.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Synchronous client for managing runs in LangGraph."""
     2 |…
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#931 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

`libs/sdk-py/langgraph_sdk/_sync/runs.py:809`

Dynamic HTTP with sensitive data context

```
   807 |             f"/threads/{thread_id}/runs/wait" if thread_id is not None else "/runs/wait"
   808 |         )
>  809 |         return self.http.request_reconnect(
   810 |             endpoint,
   811 |             "POST",
```

Remediation:
1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#932 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

`libs/sdk-py/langgraph_sdk/_sync/runs.py:941`

Dynamic HTTP with sensitive data context

```
   939 |             query_params.update(params)
   940 |         if wait:
>  941 |             return self.http.request_reconnect(
   942 |                 f"/threads/{thread_id}/runs/{run_id}/cancel",
   943 |                 "POST",
```

Remediation:
1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#933 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

`libs/sdk-py/langgraph_sdk/_sync/runs.py:1044`

Dynamic HTTP with sensitive data context

```
  1042 |
  1043 |         """
> 1044 |         return self.http.request_reconnect(
  1045 |             f"/threads/{thread_id}/runs/{run_id}/join",…
  1046 |             "GET",
```

Remediation:
1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#934 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/store.py:152`

High-risk permission pattern: """Delete an item.

```
  150 |         params: QueryParamTypes | None = None,
  151 |     ) -> None:
> 152 |         """Delete an item.
  153 |
  154 |         Args:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#935 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/store.py:173`

High-risk permission pattern: self.http.delete(

```
  171 |             ```
  172 |         """
> 173 |         self.http.delete(
  174 |             "/store/items",
  175 |             json={"key": key, "namespace": namespace},
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#936 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/_sync/store.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Synchronous store client for LangGraph SDK."""
     2 |
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#937 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/threads.py:121`

High-risk permission pattern: `strategy` (defaults to "delete").

```
   119 |             ttl: Optional time-to-live in minutes for the thread. You can pass an
   120 |                 integer (minutes) or a mapping with keys `ttl` and optional
>  121 |                 `strategy` (defaults to "delete").
   122 |             headers: Optional custom headers to include with the request.…
   123 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#938 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/threads.py:165`

High-risk permission pattern: payload["ttl"] = {"ttl": ttl, "strategy": "delete"}

```
   163 |         if ttl is not None:
   164 |             if isinstance(ttl, (int, float)):
>  165 |                 payload["ttl"] = {"ttl": ttl, "strategy": "delete"}
   166 |             else:
   167 |                 payload["ttl"] = ttl
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#939 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/threads.py:187`

High-risk permission pattern: `strategy` (defaults to "delete").

```
   185 |             ttl: Optional time-to-live in minutes for the thread. You can pass an
   186 |                 integer (minutes) or a mapping with keys `ttl` and optional
>  187 |                 `strategy` (defaults to "delete").
   188 |             headers: Optional custom headers to include with the request.
   189 |             params: Optional query parameters to include with the request.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#940 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/threads.py:208`

High-risk permission pattern: payload["ttl"] = {"ttl": ttl, "strategy": "delete"}

```
  206 |         if ttl is not None:
  207 |             if isinstance(ttl, (int, float)):
> 208 |                 payload["ttl"] = {"ttl": ttl, "strategy": "delete"}
  209 |             else:…
  210 |                 payload["ttl"] = ttl
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#941 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/threads.py:218`

High-risk permission pattern: def delete(

```
  216 |         )
  217 |
> 218 |     def delete(
  219 |         self,
  220 |         thread_id: str,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#942 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/threads.py:225`

High-risk permission pattern: """Delete a thread.

```
  223 |         params: QueryParamTypes | None = None,
  224 |     ) -> None:
> 225 |         """Delete a thread.
  226 |
  227 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#943 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/threads.py:228`

High-risk permission pattern: thread_id: The ID of the thread to delete.

```
  226 |
  227 |         Args:
> 228 |             thread_id: The ID of the thread to delete.
  229 |             headers: Optional custom headers to include with the request.
  230 |             params: Optional query parameters to include with the request.
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#944 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/threads.py:238`

High-risk permission pattern: client.threads.delete(

```
   236 |
   237 |             ```python
>  238 |             client.threads.delete(
   239 |                 thread_id="my_thread_id"…
   240 |             )
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#945 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/threads.py:244`

High-risk permission pattern: self.http.delete(f"/threads/{thread_id}", headers=headers, params=params)

```
   242 |
   243 |         """
>  244 |         self.http.delete(f"/threads/{thread_id}", headers=headers, params=params)
   245 |
   246 |     def search(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#946 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/threads.py:390`

High-risk permission pattern: strategy: PruneStrategy = "delete",

```
   388 |         thread_ids: Sequence[str],
   389 |         *,
>  390 |         strategy: PruneStrategy = "delete",
   391 |         headers: Mapping[str, str] | None = None,
   392 |         params: QueryParamTypes | None = None,
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#947 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/threads.py:398`

High-risk permission pattern: strategy: The prune strategy. `"delete"` removes threads entirely.

```
   396 |         Args:
   397 |             thread_ids: List of thread IDs to prune.
>  398 |             strategy: The prune strategy. `"delete"` removes threads entirely.
   399 |                 `"keep_latest"` prunes old checkpoints but keeps threads and their…
   400 |                 latest state. Defaults to `"delete"`.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#948 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/threads.py:400`

High-risk permission pattern: latest state. Defaults to `"delete"`.

```
   398 |             strategy: The prune strategy. `"delete"` removes threads entirely.
   399 |                 `"keep_latest"` prunes old checkpoints but keeps threads and their
>  400 |                 latest state. Defaults to `"delete"`.
   401 |             headers: Optional custom headers to include with the request.
   402 |             params: Optional query parameters to include with the request.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#949 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/_sync/threads.py:421`

High-risk permission pattern: if strategy != "delete":

```
   419 |             "thread_ids": thread_ids,
   420 |         }
>  421 |         if strategy != "delete":
   422 |             payload["strategy"] = strategy
   423 |         return self.http.post(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#950 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/_sync/threads.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Synchronous client for managing threads in LangGraph."""
     2 |
     3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#951 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/__init__.py:175`

High-risk permission pattern: @auth.on.threads.delete

```
  173 |
  174 |             ```python
> 175 |             @auth.on.threads.delete
  176 |             async def allow_admin_thread_deletion(ctx: AuthContext, value: Any) -> bool:…
  177 |                 # Only admins can delete threads
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#952 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/__init__.py:177`

High-risk permission pattern: # Only admins can delete threads

```
  175 |             @auth.on.threads.delete
  176 |             async def allow_admin_thread_deletion(ctx: AuthContext, value: Any) -> bool:
> 177 |                 # Only admins can delete threads
  178 |                 return "admin" in ctx.user.permissions
  179 |             ```
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#953 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/__init__.py:178`

High-risk permission pattern: return "admin" in ctx.user.permissions

```
  176 |             async def allow_admin_thread_deletion(ctx: AuthContext, value: Any) -> bool:
  177 |                 # Only admins can delete threads
> 178 |                 return "admin" in ctx.user.permissions
  179 |             ```
  180 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#954 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/__init__.py:324`

High-risk permission pattern: "create", "read", "update", "delete", "search", "create_run"

```
  322 |         resource: typing.Literal["threads", "crons", "assistants"],
  323 |         action: typing.Literal[
> 324 |             "create", "read", "update", "delete", "search", "create_run"
  325 |         ],
  326 |         value: type[T],
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#955 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/__init__.py:356`

High-risk permission pattern: Delete: type[VDelete]

```
  354 |     Read: type[VRead]
  355 |     Update: type[VUpdate]
> 356 |     Delete: type[VDelete]
  357 |     Search: type[VSearch]…
  358 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#956 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/__init__.py:375`

High-risk permission pattern: self.delete: _ResourceActionOn[VDelete] = _ResourceActionOn(

```
  373 |             auth, resource, "update", self.Update
  374 |         )
> 375 |         self.delete: _ResourceActionOn[VDelete] = _ResourceActionOn(
  376 |             auth, resource, "delete", self.Delete
  377 |         )
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#957 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/__init__.py:376`

High-risk permission pattern: auth, resource, "delete", self.Delete

```
  374 |         )
  375 |         self.delete: _ResourceActionOn[VDelete] = _ResourceActionOn(
> 376 |             auth, resource, "delete", self.Delete
  377 |         )
  378 |         self.search: _ResourceActionOn[VSearch] = _ResourceActionOn(
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#958 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/__init__.py:459`

High-risk permission pattern: Delete = types.AssistantsDelete

```
   457 |     Read = types.AssistantsRead
   458 |     Update = types.AssistantsUpdate
>  459 |     Delete = types.AssistantsDelete
   460 |     Search = types.AssistantsSearch…
   461 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#959 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/__init__.py:483`

High-risk permission pattern: Delete = types.ThreadsDelete

```
   481 |     Read = types.ThreadsRead
   482 |     Update = types.ThreadsUpdate
>  483 |     Delete = types.ThreadsDelete
   484 |     Search = types.ThreadsSearch
   485 |     CreateRun = types.RunsCreate
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#960 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/__init__.py:518`

High-risk permission pattern: Delete = types.CronsDelete

```
   516 |     Read = types.CronsRead
   517 |     Update = types.CronsUpdate
>  518 |     Delete = types.CronsDelete
   519 |     Search = types.CronsSearch
   520 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#961 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/__init__.py:528`

High-risk permission pattern: action: typing.Literal["put", "get", "search", "delete", "list_namespaces"],

```
   526 |         self,
   527 |         auth: Auth,
>  528 |         action: typing.Literal["put", "get", "search", "delete", "list_namespaces"],
   529 |         value: type[T],
   530 |     ) -> None:
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#962 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/__init__.py:586`

High-risk permission pattern: self.delete = _StoreActionOn(auth, "delete", types.StoreDelete)

```
   584 |             ```
   585 |         """
>  586 |         self.delete = _StoreActionOn(auth, "delete", types.StoreDelete)
   587 |         """Register a handler for store delete operations.…
   588 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#963 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/__init__.py:587`

High-risk permission pattern: """Register a handler for store delete operations.

```
   585 |         """
   586 |         self.delete = _StoreActionOn(auth, "delete", types.StoreDelete)
>  587 |         """Register a handler for store delete operations.
   588 |
   589 |         ???+ example "Example"
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#964 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/__init__.py:591`

High-risk permission pattern: delete operations (scoped to the user's namespace):

```
   589 |         ???+ example "Example"
   590 |             If using `@auth.on` to deny by default, register this handler to allow
>  591 |             delete operations (scoped to the user's namespace):
   592 |
   593 |             ```python
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#965 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/sdk-py/langgraph_sdk/auth/__init__.py:594

High-risk permission pattern: @auth.on.store.delete

```
   592 |
   593 |             ```python
>  594 |             @auth.on.store.delete
   595 |             async def allow_store_delete(ctx: Auth.types.AuthContext, value:
Auth.types.on.store.delete.value):
   596 |                 # Allow deletes, scoped to user's namespace
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#966 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/sdk-py/langgraph_sdk/auth/__init__.py:595

High-risk permission pattern: async def allow_store_delete(ctx: Auth.types.AuthContext, value: Auth.types.on.s

```
   593 |             ```python
   594 |             @auth.on.store.delete
>  595 |             async def allow_store_delete(ctx: Auth.types.AuthContext, value:
Auth.types.on.store.delete.value):
   596 |                 # Allow deletes, scoped to user's namespace
   597 |                 value["namespace"] = (ctx.user.identity, *value["namespace"])
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#967 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/sdk-py/langgraph_sdk/auth/__init__.py:622

High-risk permission pattern: typing.Literal["put", "get", "search", "list_namespaces", "delete"]

```
   620 |         *,
   621 |         actions: (
>  622 |             typing.Literal["put", "get", "search", "list_namespaces", "delete"]
   623 |             | Sequence[
   624 |                 typing.Literal["put", "get", "search", "list_namespaces", "delete"]
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#968 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

libs/sdk-py/langgraph_sdk/auth/__init__.py:624

High-risk permission pattern: typing.Literal["put", "get", "search", "list_namespaces", "delete"]

```
   622 |             typing.Literal["put", "get", "search", "list_namespaces", "delete"]
   623 |             | Sequence[
>  624 |                 typing.Literal["put", "get", "search", "list_namespaces", "delete"]
   625 |             ]
   626 |             | None
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#969 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/__init__.py:638`

High-risk permission pattern: typing.Literal["put", "get", "search", "list_namespaces", "delete"]

```
   636 |         *,
   637 |         actions: (
>  638 |             typing.Literal["put", "get", "search", "list_namespaces", "delete"]
   639 |             | Sequence[…
   640 |                 typing.Literal["put", "get", "search", "list_namespaces", "delete"]
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#970 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/__init__.py:640`

High-risk permission pattern: typing.Literal["put", "get", "search", "list_namespaces", "delete"]

```
   638 |             typing.Literal["put", "get", "search", "list_namespaces", "delete"]
   639 |             | Sequence[
>  640 |                 typing.Literal["put", "get", "search", "list_namespaces", "delete"]
   641 |             ]
   642 |             | None
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#971 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/__init__.py:652`

High-risk permission pattern: @auth.on.store(actions=("put", "get", "search", "delete"))

```
   650 |         async def handler(): ... # Handle all store ops
   651 |
>  652 |         @auth.on.store(actions=("put", "get", "search", "delete"))
   653 |         async def handler(): ... # Handle specific store ops
   654 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#972 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/auth/__init__.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |…
     3 | import inspect
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#973 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/auth/exceptions.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Exceptions used in the auth system."""
     2 |
     3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#974 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`libs/sdk-py/langgraph_sdk/auth/types.py:341`

Potential secret: possible hardcoded secret

```
   339 |
   340 |     ```python
>  341 |     MY_SECRET = "my-secret-key"
   342 |     @auth.authenticate
   343 |     async def get_current_user(request: Request) -> Auth.types.MinimalUserDict:
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#975 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/types.py:404`

High-risk permission pattern: "delete",

```
   402 |         "read",
   403 |         "update",
>  404 |         "delete",
   405 |         "search",
   406 |         "create_run",
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#976 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/types.py:417`

High-risk permission pattern: - delete: Delete a resource

```
  415 |     - read: Read information about a resource
  416 |     - update: Update an existing resource
> 417 |     - delete: Delete a resource
  418 |     - search: Search for resources…
  419 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#977 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/types.py:424`

High-risk permission pattern: - delete: Delete an item from the store

```
  422 |     - get: Get an item from the store
  423 |     - search: Search for items within a namespace prefix
> 424 |     - delete: Delete an item from the store
  425 |     - list_namespaces: List the namespaces in the store
  426 |     """
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#978 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/types.py:436`

High-risk permission pattern: strategy: typing.Literal["delete"]

```
  434 |     """
  435 |
> 436 |     strategy: typing.Literal["delete"]
  437 |     """TTL strategy. Currently only 'delete' is supported."""
  438 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#979 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/types.py:437`

High-risk permission pattern: """TTL strategy. Currently only 'delete' is supported."""

```
  435 |
  436 |     strategy: typing.Literal["delete"]
> 437 |     """TTL strategy. Currently only 'delete' is supported."""
  438 |
  439 |     ttl: int
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#980 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/types.py:937`

High-risk permission pattern: """Operation to store, update, or delete an item in the store.

```
   935 |
   936 | class StorePut(typing.TypedDict):
>  937 |     """Operation to store, update, or delete an item in the store.
   938 |…
   939 |     This dict is mutable — auth handlers can modify `namespace` to enforce
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#981 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/types.py:960`

High-risk permission pattern: """Operation to delete an item from the store.

```
   958 |
   959 | class StoreDelete(typing.TypedDict):
>  960 |     """Operation to delete an item from the store.
   961 |
   962 |     This dict is mutable — auth handlers can modify `namespace` to enforce
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#982 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/types.py:979`

High-risk permission pattern: This class organizes type definitions for create, read, update, delete,

```
   977 |     """Namespace for type definitions of different API operations.
   978 |
>  979 |     This class organizes type definitions for create, read, update, delete,
   980 |     and search operations across different resources (threads, assistants, crons).
   981 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#983 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/types.py:1036`

High-risk permission pattern: class delete:

```
  1034 |             value = ThreadsUpdate
  1035 |
> 1036 |         class delete:
  1037 |             """Type for thread deletion parameters."""…
  1038 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#984 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/types.py:1072`

High-risk permission pattern: class delete:

```
  1070 |             value = AssistantsUpdate
  1071 |
> 1072 |         class delete:
  1073 |             """Type for assistant deletion parameters."""
  1074 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#985 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/types.py:1102`

High-risk permission pattern: class delete:

```
  1100 |             value = CronsUpdate
  1101 |
> 1102 |         class delete:
  1103 |             """Type for cron deletion parameters."""
  1104 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#986 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/types.py:1132`

High-risk permission pattern: class delete:

```
  1130 |             value = StoreSearch
  1131 |
> 1132 |         class delete:
  1133 |             """Type for store delete parameters."""
  1134 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#987 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/auth/types.py:1133`

High-risk permission pattern: """Type for store delete parameters."""

```
  1131 |
  1132 |         class delete:
> 1133 |             """Type for store delete parameters."""
  1134 |…
  1135 |             value = StoreDelete
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#988 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/auth/types.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Authentication and authorization types for LangGraph.
     2 |
     3 | This module defines the core types used for authentication, authorization, and
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#989 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/cache.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Key/value cache for use inside LangGraph deployments.
     2 |
     3 | Thin wrapper around ``langgraph_api.cache``.
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#990 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/client.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """The LangGraph client implementations connect to the LangGraph API.
     2 |…
     3 | This module provides both asynchronous (`get_client(url="http://localhost:2024")` or
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#991 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/encryption/types.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Encryption and decryption types for LangGraph.
     2 |
     3 | This module defines the core types used for custom at-rest encryption
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#992 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/runtime.py:62`

High-risk permission pattern: - `threads.update` (`graph.aupdate_state`) — does NOT execute node

```
    60 |       (nodes + edges). `context` is available (use `.execution_runtime`
    61 |       to narrow).
>   62 |     - `threads.update` (`graph.aupdate_state`) — does NOT execute node
    63 |       functions or evaluate edges. Only runs the node's channel writers
    64 |       to apply the provided values to state channels as if the specified
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#993 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/runtime.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import sys
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#994 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/schema.py:97`

High-risk permission pattern: OnCompletionBehavior = Literal["delete", "keep"]

```
    95 | """
    96 |
>   97 | OnCompletionBehavior = Literal["delete", "keep"]
    98 | """…
    99 | Defines action after completion:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#995 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/schema.py:100`

High-risk permission pattern: - "delete": Delete resources after completion.

```
    98 | """
    99 | Defines action after completion:
>  100 | - "delete": Delete resources after completion.
   101 | - "keep": Retain resources after completion.
   102 | """
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#996 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/schema.py:120`

High-risk permission pattern: PruneStrategy = Literal["delete", "keep_latest"]

```
   118 | """
   119 |
>  120 | PruneStrategy = Literal["delete", "keep_latest"]
   121 | """
   122 | Strategy for pruning threads:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#997 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/schema.py:123`

High-risk permission pattern: - "delete": Remove threads entirely.

```
   121 | """
   122 | Strategy for pruning threads:
>  123 | - "delete": Remove threads entirely.
   124 | - "keep_latest": Prune old checkpoints but keep threads and their latest state.
   125 | """
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#998 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/schema.py:131`

High-risk permission pattern: - "rollback": Cancel the run. Then delete the run and associated checkpoints.

```
   129 | Action to take when cancelling the run.
   130 | - "interrupt": Simply cancel the run.
>  131 | - "rollback": Cancel the run. Then delete the run and associated checkpoints.
   132 | """…
   133 |
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#999 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/schema.py:329`

High-risk permission pattern: """The next nodes to execute. If empty, the thread is done until new input is

```
   327 |     """The state values."""
   328 |     next: Sequence[str]
>  329 |     """The next nodes to execute. If empty, the thread is done until new input is
   330 |     received."""
   331 |     checkpoint: Checkpoint
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1000 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/schema.py:340`

High-risk permission pattern: """Tasks to execute in this step. If already attempted, may contain an error."""

```
   338 |     """The ID of the parent checkpoint. If missing, this is the root checkpoint."""
   339 |     tasks: Sequence[ThreadTask]
>  340 |     """Tasks to execute in this step. If already attempted, may contain an error."""
   341 |     interrupts: list[Interrupt]
   342 |     """Interrupts which were thrown in this thread."""
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1001 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/schema.py:410`

High-risk permission pattern: """The cron schedule to execute this job on."""

```
   408 |
   409 |     schedule: str
>  410 |     """The cron schedule to execute this job on."""
   411 |     timezone: str…
   412 |     """IANA timezone for the cron schedule (e.g. 'America/New_York')."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1002 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/schema.py:669`

High-risk permission pattern: """Names of the nodes scheduled to execute next."""

```
   667 |     """Current state values at the time of this checkpoint."""
   668 |     next: list[str]
>  669 |     """Names of the nodes scheduled to execute next."""
   670 |     parent_config: dict[str, Any] | None
   671 |     """Configuration of the parent checkpoint, or `None` if this is the first checkpoint."""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1003 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/schema.py:892`

High-risk permission pattern: - A Send object to execute a node with specific input

```
   890 |
   891 |         - A string node name to navigate to
>  892 |         - A Send object to execute a node with specific input
   893 |         - A sequence of node names or Send objects to execute in order
   894 |     """
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1004 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

`libs/sdk-py/langgraph_sdk/schema.py:893`

High-risk permission pattern: - A sequence of node names or Send objects to execute in order

```
   891 |         - A string node name to navigate to
   892 |         - A Send object to execute a node with specific input
>  893 |         - A sequence of node names or Send objects to execute in order
   894 |     """
   895 |     update: dict[str, Any] | Sequence[tuple[str, Any]]
```

Remediation:
1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#1005 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/schema.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Data models for interacting with the LangGraph API."""
     2 |…
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1006 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/langgraph_sdk/sse.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Adapted from httpx_sse to split lines on \n, \r, \r\n per the SSE spec."""
     2 |
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1007 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/tests/test_api_parity.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import inspect
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1008 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/tests/test_assistants_client.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | import httpx
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1009 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/tests/test_client_exports.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Test that all expected symbols are exported from langgraph_sdk.client.
     2 |…
     3 | This test ensures backwards compatibility during refactoring.
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1010 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/tests/test_client_stream.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from collections.abc import Iterator, Sequence
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1011 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/tests/test_crons_client.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Tests for the crons client."""
     2 |
     3 | from __future__ import annotations
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1012 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/tests/test_encryption.py:1`

No logging, auditing, or monitoring detected

```
>    1 | import pytest
     2 |…
     3 | from langgraph_sdk.encryption import DuplicateHandlerError, Encryption
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1013 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/tests/test_errors.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from __future__ import annotations
     2 |
     3 | from typing import cast
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1014 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/tests/test_serde.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from typing import Any
     2 |
     3 | import orjson
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1015 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/tests/test_serde_schema.py:1`

No logging, auditing, or monitoring detected

```
>    1 | from dataclasses import dataclass
     2 | from typing import runtime_checkable
     3 |
```

Remediation:
1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#1016 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`libs/sdk-py/tests/test_skip_auto_load_api_key.py:37`

Potential secret: possible hardcoded secret

```
    35 |         client = get_client(
    36 |             url="http://localhost:8123",
>   37 |             api_key="explicit-key",
    38 |         )…
    39 |         assert "x-api-key" in client.http.client.headers
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#1017 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

`libs/sdk-py/tests/test_skip_auto_load_api_key.py:66`

Potential secret: possible hardcoded secret

```
    64 |         client = get_sync_client(
    65 |             url="http://localhost:8123",
>   66 |             api_key="explicit-key",
    67 |         )
    68 |         assert "x-api-key" in client.http.client.headers
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#1018 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`libs/sdk-py/tests/test_skip_auto_load_api_key.py:1`

No logging, auditing, or monitoring detected

```
>    1 | """Tests for api_key parameter behavior."""
     2 |
     3 | import pytest
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

Remediation Checklist

Prioritized by severity. Address CRITICAL items first.

Quick Win `npm install mcp-secure`

Adds cryptographic passports, signed messages, tool verification, and audit logging.

CRITICAL (2)

- [ ] **AS-005: injection pattern**
  Validate and sanitize all inputs with strict allowlists.
- [ ] **AS-001: unsafe execution**
  Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code).

HIGH (3)

- [ ] **AS-004: prompt injection**
  Sanitize all file contents before injecting into prompts (strip control chars, limit length).
- [ ] **AS-011: data exfiltration**
  Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains.
- [ ] **AS-002: secret scan**
  Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv).

MEDIUM (2)

- [ ] **AS-010: logging monitoring**
  Add structured logging (JSON) for every agent action, tool call, and decision.
- [ ] **AS-003: excessive permissions**
  Apply principle of least privilege — grant only permissions the agent needs for its specific task.

LOW (1)

- [ ] **AS-007: supply chain**
  Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes).

Methodology & Standards

Scanner	**mcps-audit v1.0.0**
Rules Version	**1.1.0**
Scanned At	**15/03/2026, 16:30:23**
Report ID	**MCPS-MMRZ0M0E**

Referenced Standards

OWASP MCP Top 10
Security risks for Model Context Protocol servers and clients.
owasp.org/www-project-mcp-top-10

OWASP Agentic AI Top 10
Security risks for autonomous AI agents.
owasp.org/www-project-agentic-ai-top-10

MCPS -- IETF Internet-Draft
Cryptographic security layer for MCP: draft-sharif-mcps-secure-mcp.
datatracker.ietf.org/doc/draft-sharif-mcps-secure-mcp

MITRE ATT&CK
Adversary tactics and techniques knowledge base.
attack.mitre.org

STRIDE Threat Model
Microsoft threat classification framework.
microsoft.com/en-us/security/blog/stride

AgentSign
Cryptographic identity and security for AI agents
agentsign.dev